

선박 자동화 시스템의 사이버복원력 승인/검사 가이드



2024 (Rev.0)

Marine & Ocean Equipment Team

발 간 사

친애하는 고객 여러분,

오늘, 한국선급은 선박 자동화 시스템의 사이버복원력 승인 및 검사 가이드를 발간하게 되어 매우 기쁩니다. 이 가이드는 급변하는 사이버 위협으로부터 선박 자동화 시스템을 보호하고, 안전한 해양 운송 환경을 조성하기 위한 저희의 노력의 결실입니다.

이번 가이드는 고객 여러분이 이러한 위협에 효과적으로 대응하고, 더욱 안전한 해양 운송을 실현할 수 있도록 돕기 위해 최신 기술과 사례 연구를 바탕으로 구성되었습니다.

이를 통해 고객 여러분이 사이버복원력을 갖추기 위해 알아야 할 유용한 정보와 검사 항목에 대한 정보를 확인하고, 선박에 탑재되는 시스템을 체계적으로 관리하고 강화할 수 있기를 기대합니다.

앞으로도 한국선급은 다양한 분야에서 본 가이드와 같은 승인 및 검사를 위한 중요한 정보들을 담은 기술서를 지속적으로 개발하고 공유하여 고객 여러분께 도움이 될 수 있도록 최선을 다할 것입니다. 고객 여러분의 많은 성원과 격려를 부탁드립니다. 더 안전하고 신뢰할 수 있는 해사 환경 구축을 위해 노력하는 한국선급이 되도록 하겠습니다.

감사합니다.

한 국 선 급

기술본부장 **김연태**



공 지

국제 항해 선박에 ICT(정보통신) 기술의 적용이 광범위하게 확대되고 있으며, 위성통신의 발달로 선박과 육상 간의 데이터 전송을 위한 연결이 점점 빈번해지고 있습니다. 따라서 사이버 위협에 대한 노출이 증가하게 되었으며, 실제 해사 업계에 대한 사이버 공격 및 피해 사례가 증가하고 있는 추세입니다. 이와 관련하여, IMO 및 화주협회 등 국제 해사 단체들은 선박의 사이버보안에 대한 규제를 강화하고 있습니다. 특히, IACS(국제선급연합회)는 2022년에 시스템 및 장비의 사이버복원력에 대한 공통규칙 IACS UR E27를 최초 발행하였으며, 이후 개정 버전인 UR E27 Rev.1을 통해 2024년 7월 1일 이후 건조 계약되는 국제 항해 선박에 탑재되는 주요 시스템 및 장비에 대한 사이버복원력 요건이 강제 적용될 예정입니다.

한국선급은 IACS UR E27 Rev.1의 요건을 토대로 선박 및 시스템의 사이버복원력 지침을 2024년 4월에 최초로 발행하였습니다. 본 문서는 선박에 탑재되는 시스템에 대하여 적용하는 선박 및 시스템의 사이버복원력 지침 1장 및 3장에 대한 요건에 대한 세부 적용 지침을 포함하고 있습니다. 또한, 본 문서는 한국선급이 다년간에 걸쳐 해상 사이버보안 적합성 인증 지침에 따라 장비에 대한 사이버보안 기술서비스를 수행하고 얻은 경험을 바탕으로 작성되었습니다. 본 문서는 제조사 관계자 및 한국선급 검사원을 대상으로 사이버복원력 요건의 적용에 대한 이해를 돕고 승인 및 검사에 대한 사전 준비 및 이행을 돕기 위한 목적으로 작성되었습니다.

본 문서를 상업적으로 판매하거나 제작 취지에 맞지 않는 행위로 인하여 발생할 수 있는 법적 불이익에 대하여는 한국선급이 책임지지 않습니다. 또한 사이버복원력과 관련된 업무를 수행하면서 본 문서로 인하여 논쟁 또는 분쟁이 발생할 경우, 본 문서는 어떠한 효과 또는 효력이 없음을 알려드립니다.

아울러, 본 문서에 실려 있는 그림은 해당 내용의 이해를 돕기 위한 자료로서, 해당 내용과 직접적인 관련이 없음을 주지하여 주시하시길 바랍니다.

본 문서 중 오역 또는 오타를 발견한 경우 한국선급(기자재팀)에 연락을 주시면, 개정시 반영하도록 할 것입니다. 본 문서에 대하여 관심을 주신 모든 분들께 감사드립니다.

2024.06.28.

한 국 선 급
기자재팀

개 정 기 록

Revision No.	Date	Descriptions	Remarks
0	2024.06	Established	

목 차

제 1 장 서론.....	6
제 1 절 일반 사항.....	6
제 2 절 적용 대상의 판별.....	10
제 3 절 적용 제외를 위한 리스크 평가.....	12
제 2 장 형식승인 절차 안내.....	16
제 1 절 형식승인 신청 방법.....	16
제 2 절 형식승인 절차.....	17
제 3 장 호선용 기자재 승인 절차 안내.....	20
제 1 절 도면승인 신청 방법.....	20
제 2 절 호선용 도면승인 및 검사 절차.....	22
제 4 장 제출 문서 안내.....	25
제 1 절 승인 문서 및 자료 목록.....	25
제 5 장 보안 기능 요구사항.....	34
제 1 절 일반 사항.....	34
제 2 절 필수 보안 기능 요구사항 해설 및 적용 사례.....	35
제 3 절 추가 보안 기능 요구 사항 설명 및 적용 예시.....	64

제 1 장 서론

제 1 절 일반 사항

1. 사이버복원력 요건의 도입 배경

(1) 해상 영역 사이버 위험 증가

스마트 선박, 자율운항 선박 및 화물 터미널 등 해상 영역에서의 ICT(정보통신) 기술의 융합이 가속화되고 있다. 이미 선박 내 추진 및 조타, 항해 시스템과 같은 다수의 중요 시스템들의 제어 방식이 컴퓨터 기반 시스템으로 변경되고 있으며, 기존 독립된(Stand-alone) 형식의 선박 내 추진 시스템, 조타 시스템 및 항해 시스템과 같은 주요 OT(운영 기술) 시스템이 IT(정보 기술) 시스템들과 서로 연결되어 상호 의존도가 높아짐에 따라 사이버 공격의 가능성과 위험이 높아지게 되었다.

과거에는 주로 육상 기관 및 회사들을 대상으로 한 해커들의 사이버 공격이 2010년대 후반부터 해상 영역으로 옮겨가고 있으며 실제 선주 회사, 항만시설, 국제기구, 선급협회 등 해상 단체들이 사이버 공격을 받아 피해를 받은 사례들이 다수 보고되고 있으며 앞으로 더욱 증가할 것으로 전망된다.

이러한 시대적인 흐름 속에서 개인 정보, 인명 안전, 선박 안전 및 해양 환경에 심각한 영향을 줄 수 있는 선박 내 중요 시스템들에 대한 사이버 공격으로부터 보호하기 위해 사이버보안은 더 이상 선택이 아닌 필수가 되고 있으며, 사이버보안의 중요성에 대한 국제적인 인식은 점점 높아질 것으로 전망된다.

(2) 선내 OT 시스템의 취약성

사이버 공격자는 자신의 목표를 달성하기 위해 선내 시스템과 육상 간의 원격 연결이나 접근 가능한 곳이면 어디든 사이버 공격의 표적으로 삼을 수 있다. 사이버 공격의 기술과 정교함은 해마다 진화하고 있기 때문에, 현재 및 새로운 사이버 위협으로부터 선박을 보호하기 위해서는 지속적으로 발전하고 관리되는 다양한 보호조치가 필요하다.

일반적으로 OT 시스템은 IT 시스템과 달리 설치 후 최대 20년 간 운영 및 관리가 필요하며, 선박의 운영 환경 상 최신 보안 패치의 적용 및 취약성 관리가 어렵기 때문에 이에 대한 고려가 필요하다.

또한, 현재까지 중요 OT 시스템을 구성하는 컴퓨터 기반 시스템(CBS)은 우리 선급 규칙 6편 2장에 따라 시스템 카테고리 II 및 카테고리 III 시스템에 대해 하드웨어 환경시험 및 소프트웨어의 기능시험만을 요구하고 있고, 사이버보안에 대한 검증은 요구되지 않고 있었다. 따라서, 선내 중요 시스템들이 사이버 공격에 취약한 상황이기 때문에 선박의 중대한 사이버 사고가 발생하기 전에 사전에 대응하여 조치하는 것이 매우 중요하다.

(3) 국제선급연합회(IACS)의 논의 경과

국제적으로 선박의 사이버보안 규정의 도입 필요성이 국제적으로 논의되고 있는 상황에서, IACS는 이에 대응하기 위하여 2016년에 사이버시스템 패널을 신설하였다.

IACS는 2020년 사이버시스템 패널의 작업을 통해 선박 사이버보안에 대한 권고서인 Rec. 166을

2020년에 발행하였다. 그 이후 IACS는 권고서의 내용을 바탕으로 선박 및 기자재에 대한 사이버복원력 강화 요건에 대한 공통규칙인 UR E26 및 UR 27을 2022년에 최초 발행하였다.

- UR E26 : Cyber resilience of ships
- UR E27 : Cyber resilience of on-board systems and equipment

IACS UR E26은 선박의 사이버복원력에 대한 최소 요구사항을 포함하고 있으며, NIST(미국표준기술 연구소) CSF(사이버보안 프레임워크)에 따라 식별-보호-탐지-대응-복구의 5개 구성요소의 단계 별 사이버보안 기본 요구사항 및 세부 요구사항을 정의하고 있다.

IACS UR E27은 선박 내 설치되는 중요 시스템 및 장비의 사이버복원력에 대한 최소 요구사항을 포함하고 있다. 이는 국제적으로 산업계 자동화 시스템의 사이버보안에 대한 국제표준인 IEC 62443-3-3에 포함된 요구사항 중에서 IACS에서 선박에 적용이 가능한 사이버보안 기능 요구사항들을 선택하여 포함한 요구사항을 제공하고 있다.

IACS는 사이버복원력에 대한 공통규칙의 적용을 2024년 1월 1일 이후 건조계약되는 선박 및 선내 시스템으로 대상으로 시행할 예정이었다. 그러나, 최초 발행 버전인 UR E26 및 E27에는 선박 및 시스템의 사이버복원력 요건의 실제 적용 및 이행을 위해 필요한 문서 승인 및 검사 관련 요구사항이 포함되어 있지 않은 상태였다. 따라서, IACS는 선주, 조선소 및 제조사를 포함한 이해관계자들에 의해 실제 적용이 가능하도록 기존 공통규칙에 문서화 및 검사에 대한 요구사항을 추가로 반영하기 위해서 후속 개정작업을 진행하고, 개정된 공통규칙 UR E26 Rev.1과 UR E27 Rev.1을 2023년 하반기에 공식 발행하였다. 또한, 기존 발행된 최초 버전인 UR E26 및 E27을 철회함과 동시에 개정된 공통규칙의 적용 시기를 6개월 늦추어 2024년 7월 1일 건조 계약되는 선박으로 최종 변경하였다.

IACS는 UR E26 및 E27에서 고려되는 사이버 사고는 선박의 OT 시스템을 표적으로 하는 사이버 공격으로 인해 발생하는 사건임을 강조하고 있다. 즉, 시스템 및 장비 하드웨어의 고장이나 소프트웨어 버그로 인한 기능 오류에 대해서는 사이버복원력 요건이 아닌 우리 선급 규칙 6편 2장에 따른 요구사항을 기본으로 만족하는 것이 필요하다.

2. 기술정보문서의 목표 및 목적

KR 선박 및 시스템의 사이버복원력 지침(이하 KR 사이버복원력 지침)은 항해 및 운항에 필요한 여러 시스템들을 포함하고 있는 집합체로서 선박의 사이버복원력을 확보하는 것을 최종 목표로 하고 있다.

사이버복원력을 가진 선박을 달성하기 위해서는 선박의 구성요소로서 중요한 기능을 수행하는 중요 OT 시스템 들에 대한 사이버복원력 능력을 확보하는 것이 필수적이다. 그러므로, 시스템에 대한 사이버복원력을 확보하는 것이 사이버복원력을 가진 선박을 만드는데 필요한 시작점이자 전제 조건이라고 볼 수 있다. 이와 관련하여, KR의 사이버복원력 지침은 2장에서 선박에 대한 사이버복원력 요건을 규정하고 있으며, 3장에서 선박의 사이버복원력을 위해 필요한 선박 내 시스템들에 대한 사이버복

원력 요구사항을 규정하고 있다.

본 기술정보문서는 사이버복원력 지침 3장과 관련하여 주로 시스템 제조사 담당자들을 대상으로 시스템에 대한 사이버복원력 요건의 적용 방향을 제시하고 있다. 또한, KR의 사이버복원력 형식승인 및 호선용 기자재 검사를 위해 필요한 준비 사항과 검사 절차에 대한 상세 정보를 제공함으로써 고객들의 KR에 의한 사이버복원력 검사 준비 및 이행에 대한 시행착오를 줄이고 나아가 고객들의 KR 검사 서비스 만족도 향상을 목표로 작성하였다.

3. 사이버복원력의 기초

다음에서 지침의 내용을 이해하기 위해 최소로 필요한 사이버보안 및 사이버복원력에 대한 기초 이론을 아래에서 설명하고자 한다.

(1) 정보보안, 사이버보안 및 사이버복원력의 이해

정보보안은 일반적으로 IT 시스템을 대상으로 한 보안을 의미한다. 정보보안에 대하여 가장 대중적으로 적용되는 국제 표준은 ISO 27001이 있으며, 국제적인 인증 체계가 잘 구축되어 매우 활성화되어 있는 분야이다. ISO 27000에 따르면 정보보안은 정보 자산에 대한 기밀성, 무결성, 가용성을 보존하는 것으로 정의하고 있다.

정보보안이 정보 자산의 보호에 중점을 두고 있는 것과 달리 사이버보안은 OT 시스템이 제공하는 서비스의 보호에 초점을 맞추고 있다. 사이버보안에 대하여 가장 대표적인 표준은 ISA(국제보안협회)에서 개발한 IEC 62443 시리즈 표준이다. IEC 62443-1-1에서 사이버보안은 중요한 시스템 또는 정보 자산의 무단 사용, 서비스 거부, 수정, 공개, 수익 손실 또는 파괴를 방지하기 위해 필요한 조치로서 정의하고 있다. 사이버보안의 근본 목적은 OT 시스템에 대한 기밀성, 무결성, 가용성을 보호하는 것으로 이해될 수 있다. 정보보안에서 정보의 기밀성을 가장 중요한 요소로 인식되는 반면, 사이버보안에서는 자산의 가용성을 가장 중요하게 보는 특징이 있다.

마지막으로 사이버복원력은 기존의 사이버보안 개념에서 복구 및 대응에 대한 영역을 한층 강화한 것으로 특히 선박의 사이버사고 발생 시에도 선박의 최소 안전 운항을 유지 및 보호하는 것을 목적으로 IACS에서 새로 도입한 개념이다. UR E26 Rev.1에 따르면, 사이버복원력은 “잠재적으로 인명의 안전, 선박의 안전 및/또는 환경 위협에 대하여 위험한 상황으로 이어질 수 있으며, 선박의 안전한 운항을 위해 이용되는 운영 기술(OT)의 중단 또는 손상으로 인해 발생하는 사이버 사고의 발생을 줄이고 영향을 완화하는 능력을 말한다.”고 정의하고 있다.

이와 같이 정보보안, 사이버보안은 보호 대상의 유형이 다를 뿐 근본적으로 사이버공격으로부터 자산을 보호하기 위한 목적이 동일하며, 사이버복원력은 사이버보안과 보호 대상은 동일하지만 사이버보안의 사고 발생 시에도 지속적인 최소 운항 능력을 확보하는데 중점을 두고 있다는 것에 일부 차이가 있다.

(2) 사이버 보안의 기본 목적

일반적으로 산업계에서 자주 언급되는 사이버보안의 3요소는 기밀성, 무결성, 가용성을 의미하며 이를 CIA 모델이라고도 한다. 아래는 각 요소에 대한 의미를 보여주고 있다.

1) 가용성 : 시스템 정보 및 기능에 대한 적시의 신뢰성 있는 접근 및 사용을 보장하는 속성

- 2) 무결성 : 자산의 정확성과 완전성을 보호하는 속성
 3) 기밀성 : 정보 접근 및 공개에 대한 공인된 제한을 보존하는 속성



[그림 1] 보안의 3요소

사이버보안의 기본 목적은 외부의 사이버 위협으로부터 OT 시스템의 기밀성, 무결성, 가용성을 보호하는 것을 의미한다. 이들 3가지 기본요소 중에서 사이버보안 관점에서 우선순위는 가용성, 무결성, 기밀성 순으로 중요하다고 볼 수 있다.

Category	IT system	OT system
Security Priority	C > I > A	A > I > C
Security Target	Information, IT Asset	Field devices, OT asset
Risk factor	Data	Cyber Physical System
OS	OS (Windows, Linux..)	Industrial OS
Communication	IT Protocol (TCP/IP)	OT Protocol (S7, Modbus, etc)
Component Lifetime	3~5 years	15~20 years
System Patch	Essential	Operational impact

[그림 2] IT 및 OT 시스템의 특성 비교

예를 들어, 선박의 경우 중요 서비스를 제공하는 추진 시스템의 가용성에 문제가 발생을 한 경우 운항 중단과 같은 비상상황이 발생할 수 있으며, ECDIS와 같은 항해장비의 무결성에 문제가 발생한 경우 항해사의 판단 실수를 유발하여 선박 사고가 발생하는 단초가 될 수도 있다. 마지막으로 기밀성이 손상되어 선박 내 중요 화물 정보가 해적에 유출될 경우 해적의 주요 공격 대상이 될 가능성이 있다.

(3) 선내 컴퓨터기반 시스템

KR 사이버복원력 지침 1장 103항에 따르면 선박 내 사이버복원력의 적용 대상 시스템은 중요 용도 서비스를 제공하는 컴퓨터 기반 시스템으로 한정하고 있다.

사이버복원력의 적용 대상을 컴퓨터기반 시스템으로 한정하는 이유는 물리적 공격을 제외하고 실제 사이버 공격은 소프트웨어로 구동되는 컴퓨터기반 시스템을 주요 대상으로 하기 때문이다.

KR 사이버복원력 지침 1장 2절에 따르면 컴퓨터기반 시스템은 “정보의 수집, 처리, 유지, 사용, 공유, 보급 또는 처리와 같은 하나 이상의 특정 목적을 달성하기 위해 구성된 프로그래밍 가능한 전자 장치 또는 상호 운용 가능한 프로그래밍 가능한 전자 장치의 집합.”이라고 정의하고 있다.

상기 정의에 따라서 컴퓨터 기반 시스템은 서버, PC와 같이 일반적인 IT 장비들과 PLC를 기반으로 작동하는 산업제어시스템 뿐만이 아니라 펌웨어 소프트웨어 기반 구동 방식의 시스템들도 여기에 포함된다고 볼 수 있다.

4. 제한 사항

본 기술 가이드는 KR 사이버복원력 지침의 시행일 이전에 작성된 최초 문서로서, 시스템 및 장비에 대한 사이버복원력 기능 설계에 대한 일부 적용 예시를 포함하고 있다. 다만, 고객들의 시스템에 대한 실제 설계 및 구현은 고객사의 개발 환경과 시스템의 고유 특성 상 다른 방식으로 적용될 수 있다. 즉, 고객들에게 반드시 지침에서 제시하는 방향을 따를 것을 요구하는 것이 아니며, 고객의 적용 상 이해를 돕도록 하나의 적용 예시를 보여주는 것이므로 설계 및 구현에 대한 최종 책임은 고객에게 있다.

본 기술정보는 지침의 문서화 요구사항 및 검사 절차에 대한 일부 해석 내용을 포함하고 있으나, 실제 시행 과정에서 해석상 오류가 발견될 가능성이 있음을 주지할 필요가 있으며 향후 발견되는 오류 사항에 대해서는 기술 정보의 업데이트 버전을 통해 올바르게 수정할 예정이다.

제 2 절 적용 대상의 판별

1. 일반 사항

실제 선박 내 시스템의 사이버복원력 적용 대상 여부는 신조 단계에서 조선소에서 제출하는 자산 목록표 및 적용 제외 리스크 평가서의 선급 승인을 통해서 최종적으로 확정된다. 그러나, 사전에 사이버복원력 기능을 구현하고 형식승인 준비가 필요한 시스템 제조사 입장에서 신조 단계에서 적용 대상 여부를 확인하기에는 시점이 너무 늦기 때문에 후속 대응이 어려울 수 있다. 따라서, 제조사에서 제공하는 시스템에 대한 사이버복원력 지침의 적용 가능성을 미리 식별하여 사전에 준비하는 것이 필요하다.

2. 시스템의 적용 대상 판별

일반적으로 시스템의 사이버복원력 적용 대상 판별은 다음의 순서에 따른 기준으로 검토가 가능하다.

(1) 시스템이 탑재되는 선박이 강제 적용 대상인가?

KR 사이버복원력 지침 1장에 따라 사이버복원력 요건은 2024년 7월 1일 이후 건조 계약되는 선박에 적용되며, 강제 적용 대상 선박의 유형은 다음과 같다.

- 1) 국제항해에 종사하는 여객선(고속여객선 포함)
- 2) 국제항해에 종사하는 500GT 이상의 화물선

- 3) 국제항해에 종사하는 500GT 이상의 고속선
- 4) 500GT 이상의 이동식 해양 시추선
- 5) 건설에 종사하는 자체 추진 이동식 해양 구조물(예: 풍력 터빈 설치, 유지 보수 및 수리, 크레인 유닛, 시추부속선(tender), 숙박 시설 등)적용 대상 선박

(2) 시스템이 사이버복원력의 적용 범위에 포함되는가?

사이버복원력의 적용 범위에 해당하는 시스템은 강제 적용 대상 선박에 설치되며 해당 시스템의 사이버 사고 발생시 인명의 안전, 선박의 안전 및 해양 오염에 영향을 줄 수 있는 컴퓨터기반 시스템으로 한정하고 있다. 이와 관련하여, KR 사이버복원력 지침 1장 103.2항에서 규정하고 있는 강제 적용되는 시스템의 범위는 다음과 같다.

1) 선박 내 운영 기술(OT) 시스템

즉 물리적 프로세스를 제어 또는 감시하기 위해 사이버 공격에 취약할 수 있는 데이터를 사용하고, 만약 손상될 경우, 인명의 안전, 선박의 안전 및/또는 환경 위협에 대한 위험한 상황을 초래할 수 있는 컴퓨터기반 시스템(이하: CBS), 특히 다음의 중요 용도에 사용되는 CBS가 고려 대상이다.

- (가) 추진
- (나) 조타
- (다) 앵커링 및 무어링
- (라) 발전 및 배전
- (마) 화재 탐지 및 소화 시스템
- (바) 빌지 및 평형수 시스템, 로딩 컴퓨터
- (사) 수밀 무결성 및 침수 탐지
- (아) 조명 (예: 비상 조명, 저위치 조명, 항해등 등)
- (자) 중단 또는 기능 손상이 선박 운항에 위협을 초래할 수 있는 어떠한 규정상 요구되는 안전 시스템 (예: 비상정지 시스템, 화물 안전 시스템, 압력 선박 안전시스템, 가스 탐지 시스템 등)

2) 항해 및 통신 시스템

- (가) 협약 규정에서 요구되는 항해시스템
- (나) 선급 규칙 및 협약 규정에서 요구되는 내부 및 외부 통신 시스템

위에서 언급된 시스템 목록에 포함되어 있지 않더라도 KR 규칙 6편 2장 4절에 따라 시스템이 시스템 카테고리 II 또는 III에 해당할 경우 사이버복원력의 적용 범위에 포함되어야 한다.

(3) 시스템이 적용 제외 리스크 평가가 가능한가?

상기 (1) ~ (2)의 기준을 모두 만족하는 시스템이라 할지라도 사이버복원력 지침 1장 3절에 따라 적용 제외를 위한 기본 허용 기준을 모두 만족하고 사이버리스크 평가를 통해 추가의 허용 기준을 만족하는 것으로 우리 선급에 확인된 시스템에 대해서는 적용 제외가 가능하다. 이에 대한 세부 지침은 3절의 내용을 참조할 수 있다.

3. 적용 제외 관련 시스템 제조사의 대응 권고사항

(1) 기본 허용 기준 4가지를 모두 만족 못하는 시스템의 경우

적용 제외가 어려울 것으로 판단되기 때문에 사전에 사이버복원력 형식승인을 포함한 선급 검사를 준비를 할 필요가 있다.

(2) 기본 허용 기준 4가지를 모두 만족하는 시스템의 경우

이 경우에는 3절에서 서술하고 있는 내용을 참고하여 시스템의 적용 제외 가능성을 확인하고 대응할 것을 권고한다.

시스템의 자체 검토 결과 적용 제외 가능성이 높은 경우에는 신조 단계에서 적용 제외 리스크 평가를 통해 선급으로부터 적용 제외를 받는 것이 가능할 것으로 예상된다.

그러나, 시스템 카테고리가 III이고 복잡한 시스템의 경우 적용 제외 가능성이 낮기 때문에 리스크 평가를 통한 적용 제외가 어려울 수도 있다는 점을 사전에 인지하는 것이 필요하다. 적용 제외 가능성 검토에 대한 세부 내용은 3절을 참조할 수 있다.

제 3 절 적용 제외를 위한 리스크 평가

1. 일반 사항

시스템이 적용 범위에 포함됨에도 불구하고 KR 사이버복원력 지침 1장 3절에 따라서 시스템의 적용 제외를 위한 리스크 평가를 수행하고 우리 선급에 KR 사이버복원력 지침 1장 304의 관련 허용 기준을 만족하는 것으로 확인되는 경우 적용 제외가 가능하다.

적용 제외를 위한 리스크 평가는 특정 선박에 설치 예정인 OT 시스템들을 대상으로 수행되며, 시스템 통합자(또는 조선소)는 리스크 평가를 실시하고 평가서를 선급에 제출할 책임이 있다. 적절한 리스크 평가를 수행을 위해서는 시스템 제조사들의 기술 지원 및 협조가 필요하며, 시스템 통합자가 리스크 평가에 대한 업무를 외부 전문기관에 위탁하여 수행하는 것도 가능하다.

(1) 리스크 평가서의 내용

리스크 평가서는 특정 신조 선박에 실제 설치되는 시스템들을 대상으로 하며, 적용 제외를 받기 위한 모든 시스템들을 포함하여야 한다.

리스크 평가서의 내용은 선급으로부터 적용 제외를 인정받기 위한 시스템에 관련된 사이버 리스크가 허용 가능한 위험 수준 미만 인지를 증거자료 제공을 통해 증명해야 한다.

(2) 리스크 평가의 방법

리스크 평가의 방법론은 리스크 평가를 수행하기에 앞서 사전에 정의되고 문서화되어야 한다.

사이버리스크 평가 방법 및 프로세스는 국제표준인 ISO 27005, IEC 62443-3-2, NIST SP 800-30 및 선박 내 사이버보안 가이드라인 등 다양한 문서들을 참고할 수 있다.

다음은 BIMCO, ICS, OCIMF 등 국제 해사 단체에서 공동으로 발행한 선박 사이버보안 가이드라인에서 제시하고 있는 사이버 리스크 평가의 예시이다.

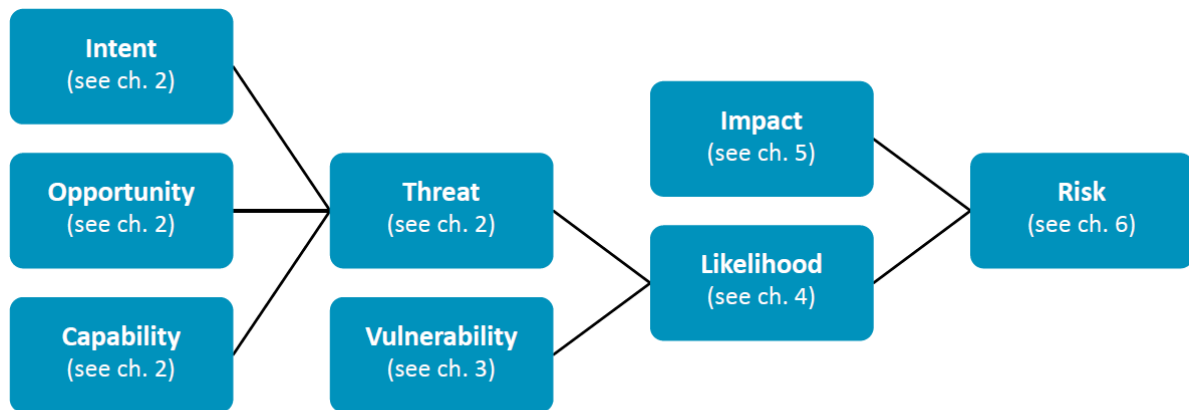


Figure 9: The relationship between different factors influencing the risk. The lines represent multiplication, ie "Likelihood" is multiplied with "Impact" to produce "Risk".

[그림 3] 리스크 평가 예시

일반적으로 여러 국제표준 또는 지침에서 사이버 사고에 대한 리스크 수준은 아래와 같이 사이버 위협 지수와 취약성 지수 그리고 사고의 영향 지수를 곱한 값으로 정의하고 있다.

▪ Cyber Security Risk

$$\text{Risk} = \text{Threat} \times \text{Vulnerability} \times \text{Consequence}$$



[그림 4] 사이버 리스크 계산 방식 예시

상기에서 사이버 위협(Threat) 지수와 취약성(Vulnerability) 지수를 곱한 값을 사고 가능성(Likelihood) 지수로 볼 수 있으며, 사고 영향(Consequence) 지수는 선박 내 대상 시스템의 사이버 사고의 심각도에 관련한 것으로 시스템 카테고리(I, II, III)와 밀접하게 연관되어 있다. 이와 관련하여, KR 사이버복원력 지침 1장 3절에서 사이버 리스크 평가를 수행할 때는 아래의 사항들이 추가로 고려하도록 하고 있다.

- 1) 시스템의 취약점
- 2) 내부 및 외부의 위협
- 3) 인명 안전, 선박 안전 및/또는 환경 위협 상 자산에 영향을 주는 사이버 사고의 잠재적 영향
- 4) 선내에 없는 시스템을 포함하여(예: 선내 시스템에 대한 원격 접근이 제공되는 경우) 시스템의 통합 또는 시스템 간의 인터페이스와 관련된 가능한 영향

(3) 리스크 평가서의 제출 및 승인

사이버 리스크 평가서는 시스템 통합자(또는 조선소)가 우리 선급 도면승인팀에 호선용으로 제출되어야 하며, 우리 선급의 검토 및 확인을 통해서 특정 시스템들에 대한 적용 제외가 허용될 수 있다.

2. 리스크 평가를 통한 시스템의 적용 제외 가능성의 검토

앞서 설명한 바와 같이 KR 사이버복원력 지침으로부터 시스템의 적용 제외를 받기 위해서는 시스템 통합자(또는 조선소)가 선박의 설계 및 건조 단계에서 리스크 평가서를 우리 선급에 제출하여 승인을 받는 프로세스를 거쳐야 한다. 그러나, 제조사 입장에서는 시스템의 사이버복원력 적용 대상 판정 시점이 너무 늦기 때문에 선박의 건조단계에서 적용 여부를 확인 후에 선급 검사를 대응하는 것은 매우 어려울 수 있다.

그러므로, 시스템 제조사 입장에서는 자사가 제공하는 시스템에 대해서 적용 제외 가능성을 조기에 검토하여 적용 제외 가능성이 높으면 적용 제외를 위한 리스크 평가를 준비하고, 이와 반대로 가능성이 낮을 경우 사이버복원력 요건에 대한 형식승인을 사전에 득할지에 대한 정책적 판단이 필요하다. 시스템의 적용 제외 가능성은 아래 (1)에서 (2)의 검토 기준을 토대로 판단해볼 수 있다.

(1) 기본 허용 기준 모두 만족

아래의 4가지 허용 기준을 모두 만족하는 지에 대한 여부는 리스크 평가 수행이 가능한지에 대한 전제 조건이 된다.

- 1) CBS가 격리되어 설치됨 : 다른 시스템 또는 네트워크에 어떠한 IP-네트워크 연결도 없어야 한다.
- 2) CBS에 접근이 가능한 물리적 인터페이스 포트가 없어야 함 : 미사용 인터페이스는 논리적으로 비활성 되어야 하고, 무허가 장치는 CBS에 연결할 수 없어야 한다.
- 3) CBS는 물리적 접근이 통제되는 구역 내에 위치해야 한다.
- 4) CBS는 지침의 적용 범위(지침 1장 103. 참조) 내 명시된 다중의 선박 기능을 제공하는 통합 제어 시스템이 아니어야 한다.

(2) 추가의 허용 기준 만족 여부

아래의 3가지 추가의 허용 기준에 대해서는 리스크 평가서를 제출하고 적절한 증거자료 제시를 통해 우리 선급으로부터 적절히 만족하는지가 확인되어야 한다.

- 1) CBS는 카테고리 III의 선박 기능을 제공하지 않아야 한다.
- 2) CBS에 영향을 주는 알려진 취약점, 위협, 사이버 사고로 파생하는 잠재적 영향이 위험도 평가에서 적절하게 고려 해야 한다.
- 3) CBS에 대한 공격 표면은 무선 접근 지점을 포함하여 복잡성, 연결성, 물리적 및 논리적 접근 지점을 고려하여 최소화해야 한다.

상기의 추가의 기준과 관련하여 시스템 카테고리 I 또는 II의 경우 리스크 평가를 통한 추가의 허용 기준을 만족하는 것이 쉽기 때문에 적용 제외가 가능하다고 볼 수 있다. 그러나, 시스템 카테고리 III의 경우 KR 사이버복원력 지침 3절에서 추가의 허용 기준은 모두 만족할 필요가 없다고 규정하고 있음에도 불구하고 특별한 주의가 필요하다.

앞에서 설명한 바와 같이 사이버 리스크는 자산(시스템)의 영향도 지수와 사고 발생가능성(위험 지수 X 취약성 지수) 지수를 곱한 값이다. 따라서, 시스템의 영향도(또는 심각도)가 시스템 카테고리 III일 경우 높기 때문에 발생 가능성이 거의 없는 경우를 제외하고 사이버 리스크 평가 결과로서 리스크가 낮게 나오기 어려울 것이다.

예를 들어, 시스템 카테고리 III로 간주될 수 있는 VHF 무선설비와 ECO Sounder의 경우 시스템이

단순하며 유지보수가 필요 없기 때문에 사이버 공격이 가능한 접근 지점이 매우 적고, 가능한 사이버 공격 시나리오가 거의 없는 장비에 대하여 예외적으로 적용 제외가 가능할 수 있다. 이와 반대로 일반적인 PC 기반의 장비(서버, 워크스테이션 등)와 PLC 기반의 복잡한 제어 시스템의 경우 공격 표면이 다수이면서 가능한 사이버 공격 가능성이 낮지 않을 것으로 예상되기 때문에 사이버 리스크 평가를 통한 적용 제외가 어려울 수 있다.

(3) 시스템 사례 별 적용 제외 가능성

아래의 표는 독자의 이해하기 쉽도록 시스템의 유형에 따라 적용 제외 가능성을 가상으로 평가한 예시로서 포함한 것으로 참고하기 바란다.

- 1) A 시스템과 B 시스템의 경우 선박 설계 및 건조 단계에서 쉽게 사이버 리스크 평가를 통해 적용 제외가 가능할 것으로 예상된다.
- 2) C 시스템과 D 시스템의 경우, 리스크 평가 결과 사이버 리스크가 낮은 것으로 우리 선급의 확인 되는 경우 적용 제외될 가능성이 있다고 볼 수 있다. 이 경우에는 우리 선급이 요청하는 경우 리스크 저감을 위한 추가의 보호 조치가 요구될 수 있다.
- 3) E 시스템의 경우 시스템의 복잡도가 높고 공격 가능 지점이 많으므로 사이버 공격 가능성이 낮지 않기 때문에 적용 제외 가능성이 낮다고 볼 수 있다.

검토 기준	A 시스템	B 시스템	C 시스템	D 시스템	E 시스템
시스템 카테고리 (I / II / III)	I	II	II	III	III
필수 기준 모두 만족 (네 / 아니오)	네	네	네	네	네
공격 가능 지점 (많음 / 적음)	많음	적음	많음	적음	많음
리스크 평가를 통한 적용 제외 가능성	높음	높음	중간	중간	낮음

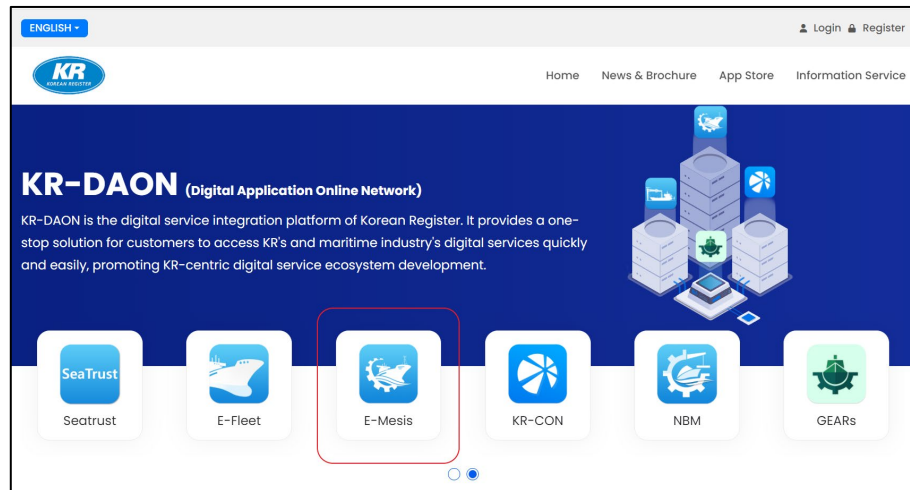
[표 1] 적용 제외 가능성 평가 예시

제 2 장 형식승인 절차 안내

제 1 절 형식승인 신청 방법

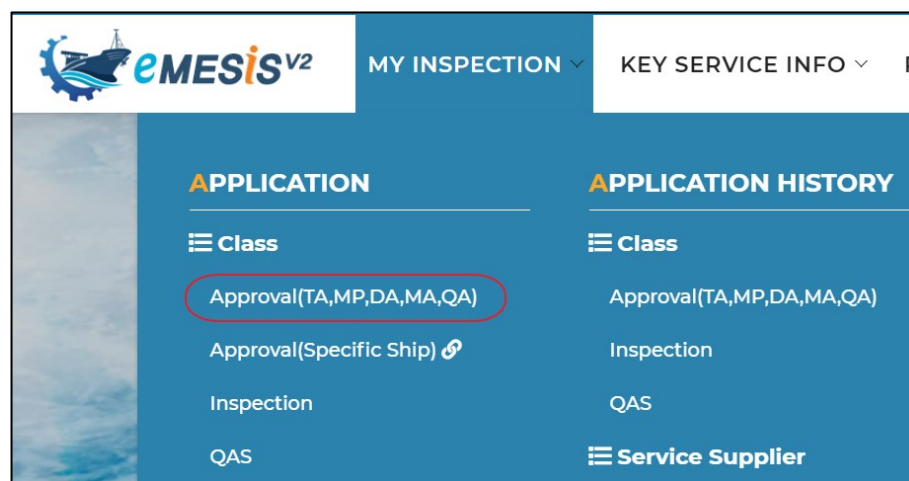
형식승인을 받고자 하는 제조사는 KR-DAON -> eMESIS를 통해 온라인으로 신청이 가능하며 주소는 다음과 같다.

- <https://daon.krs.co.kr/>



[그림 5] KR-DAON

eMESIS는 KR-DAON 회원가입 후 사용이 가능¹하며 기존의 사용자는 로그인 후, 나의 검사 내역 -> 신청 -> Class -> Approval(TA,MP,DA,MA,QA) 메뉴에서 신청이 가능하다.



[그림 6] 사이버복원력 형식승인 신청 메뉴 예시

¹ 2024년 12월까지 eMESIS에서 직접 회원가입/접속이 가능하며, 2025년 부터는 KR-DAON을 통해서만 사용이 가능함

신청화면에서는 제조사 및 시스템의 필요 정보 등을 입력하며, ‘Kind of Approval’ 메뉴에서 ‘1. If you are applying for Cyber resilience, please mark the check box.’ 항목에 체크한다.

Kind of Approval

-- Approval -- *
-- Survey -- *

For Renewal of MP, TA, DA, the following documents to be submitted

- ① Data related to the corrective action for approved product, if any
- ② Alteration to the approved manufacturing process or specification
- ③ Service records of approved products or similar products which are approved by this Society(minimum 6 months and over)

TA : Type Approval
MP : Approval of Manufacturing Process
DA : Design Approval
MA : Approval of Manufacturer
QA : Approval of Quality Assurance System
MR : Mutual Recognition

1. If you are applying for Cyber resilience, please mark the check box.
☒ TA Ref.No.

2. If you are applying for Renewal, Annual, Change or Occasional, please input the Certificate number.

3. Where there are alterations to the product or documentation since previous approval contents, please describe details.

[그림 7] 사이버복원력 형식승인 신청 메뉴 예시

‘Product Information’ 메뉴에서는 ‘Kind of Product’ 항목에서 CS00 Cyber Resilience를 선택한다.

Product Information

Kind of Product *

CODE	PRODUCT
VV05	Cryogenic Valve
CS00	Cyber Resilience
GR01	Cycloid Reducer Type Gear
DE00	Diesel Engine
DC05	Diesel Engine Components
DC04	Diesel Engine Components - Connecting Rod/Piston

Model(Brand) or Grade *

Approval Range

Date of Approval Test (Desired date)

Date to be Approval (Desired date)

[그림 8] 사이버복원력 형식승인 신청 메뉴 예시

빨간색 *로 표시된 항목은 필수로 값을 입력하여야 하며, 승인 문서 첨부 및 필요한 정보를 모두 입력 후 제출(Submit) 버튼을 누르면 신청하기는 완료된다.

제 2 절 형식승인 절차

형식승인의 신청에 대한 접수가 완료되면 제출 문서에 대한 검토가 진행되며, 제출되어야 하는 승인 문서 및 참고 문서는 다음과 같다.

1. 승인문서

(1) CBS² 자산 목록

² CBS(Computer Based System) : 컴퓨터 기반 시스템

- (2) 토폴로지 다이어그램
- (3) 보안 기능 기술서
- (4) 보안 기능 시험절차
- (5) SDLC³ 문서

2. 참고문서

- (1) 보안 설정 지침
- (2) 유지보수 및 검증 계획
- (3) 사고 대응 및 복구 계획 지원 정보
- (4) 변경관리 계획
- (5) 시험 보고서

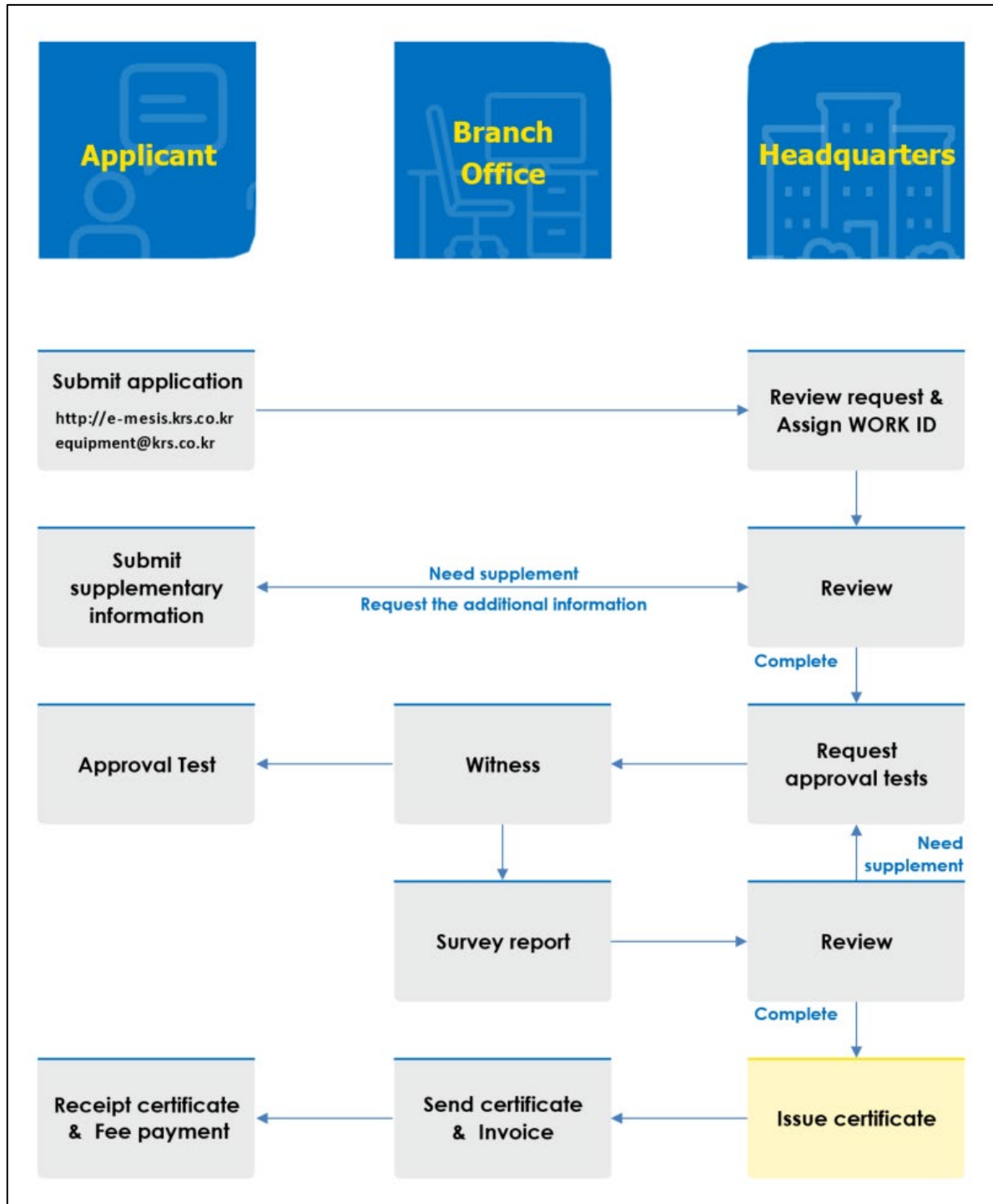
참고 문서 중 (5) 시험 보고서⁴의 경우, 형식 시험 전 제출되고 승인되어야 하는 다른 문서와 달리 시험 완료 후 제출한다.

시험 보고서를 제외한 모든 문서가 우리 선급의 승인을 받은 경우 형식 시험을 실시한다. 형식 시험은 승인된 ‘보안 기능 시험절차서’에 따라 우리 선급 검사원의 입회 하에 진행되며, 별도의 외부 시험기관에 의뢰하여 진행하지 않는다. 또한 형식승인 단계에서 공장 조사(Plant audit)⁵는 요구되지 않는다. 형식시험이 완료된 후 제조사는 시험 결과(e.g. 사진 등)를 기존의 승인된 보안 기능 시험절차에 업데이트 하여 우리 선급에 제출하여야 하며, 제출 완료 후 우리 선급에서는 사이버복원력 형식 승인 증서를 제조사에 발행하고 형식승인의 절차는 완료된다.

³ SDLC(Secure Development Life-Cycle) : 보안 개발 수명주기 문서

⁴ 보안 기능 시험절차에 따른 형식 시험 완료 후 결과 사진을 업데이트 하여 우리 선급에 제출하는 문서로 형식승인을 받는 경우, 형식 시험 완료 후 작성 가능한 문서

⁵ 공장조사 면제는 사이버 복원력의 형식승인만으로 한정되며, 제조법 및 형식승인 등에 관한 지침에 따른 기존의 형식승인에서는 공장 조사가 요구된다



[그림 9] 사이버복원력 형식승인 절차

제 3 장 호선용 기자재 승인 절차 안내

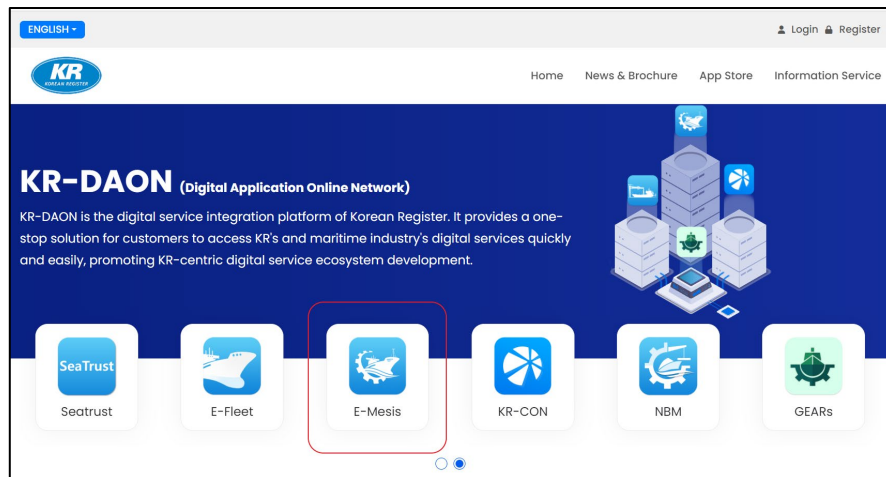
제 1 절 도면승인 신청 방법

1. 호선용 기자재 도면승인 신청 방법

(1) eMESIS 웹페이지 접근 및 EDAS 화면 이동

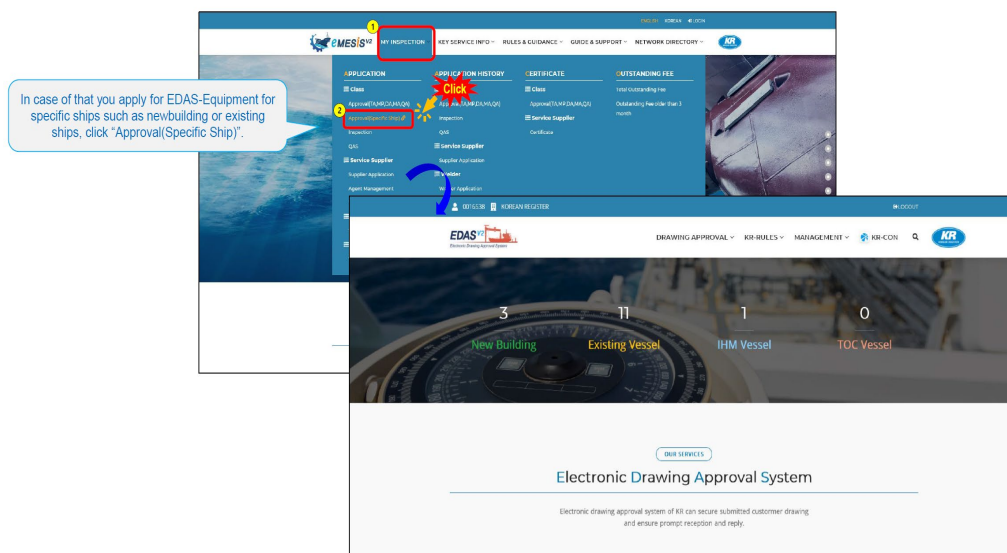
도면승인을 받고자 하는 제조사는 KR-DAON -> eMESIS를 통해 온라인으로 신청이 가능하며 주소는 다음과 같다.

- <https://daon.krs.co.kr/>



[그림 10] KR-DAON

eMESIS는 KR-DAON 회원가입 후 로그인하여 사용이 가능⁶하며, eMESIS 화면에서 “나의 검사 내역 -> 신청 -> Class -> Approval(Specific Ship)” 순서로 클릭하여 들어간다.

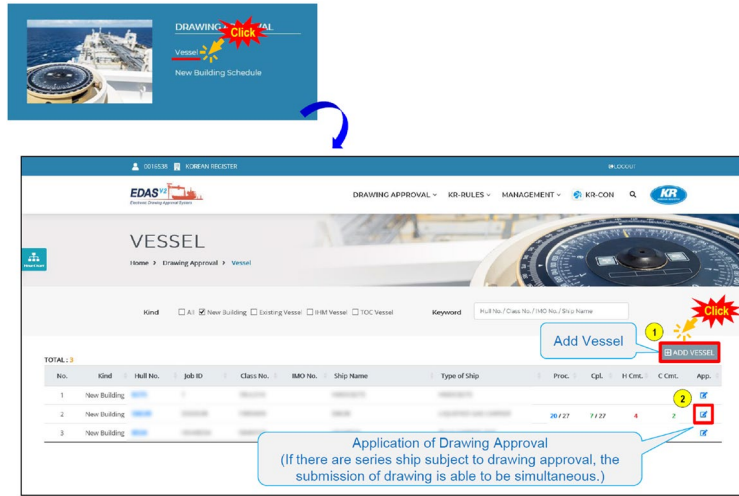


[그림 11] 사이버복원력 도면 승인 신청 메뉴 예시

⁶ 2024년 12월까지 eMESIS에서 직접 회원가입/접속이 가능하며, 2025년 부터는 KR-DAON을 통해서만 사용이 가능함

(2) eMESIS 화면에서 도면 승인 신청화면(EDAS) 접근

화면 상단의 DRAWING APPROVAL -> Vessel을 클릭하면 아래 그림과 같이 선박 목록이 나온다. 해당 선박이 목록에 없을 경우 먼저 ADD VESSEL을 클릭하여 선박 목록을 추가한 후 App. 항목의 아이콘을 클릭하면 호선용 기자재 도면승인 접수 화면으로 이동하며, 목록에 있을 경우에는 목록에서 바로 App. 항목의  아이콘을 클릭하여 도면승인 신청 화면으로 이동한다.



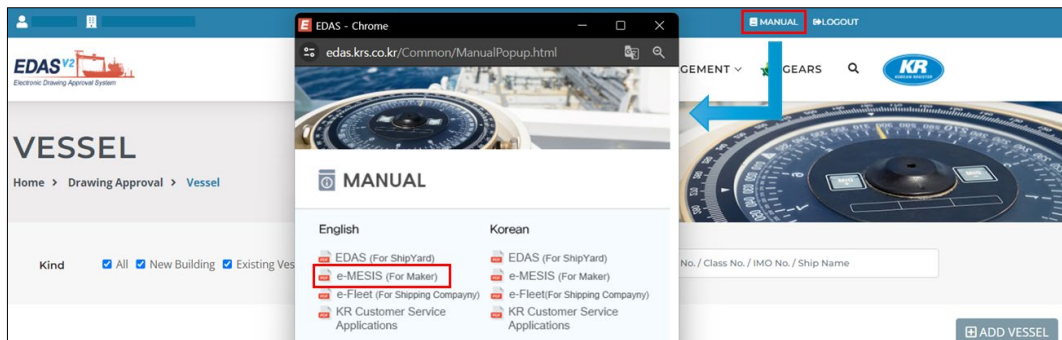
[그림 12] 사이버복원력 기자재검사 신청 메뉴 예시

2. 호선용 기자재 도면승인 신청

도면승인 신청화면에서는 관련 신청 정보를 입력하고 승인용 도면 및 문서 파일을 업로드한다.

[그림 13] 호선용 기자재 도면승인 신청 예시

도면승인 신청화면에서 정보 입력 및 자료의 업로드와 관련된 제반 사항은 EDAS 화면 오른쪽 상단의 부분을 클릭하여 e-MESIS 매뉴얼의 세부 지침을 참고한다.

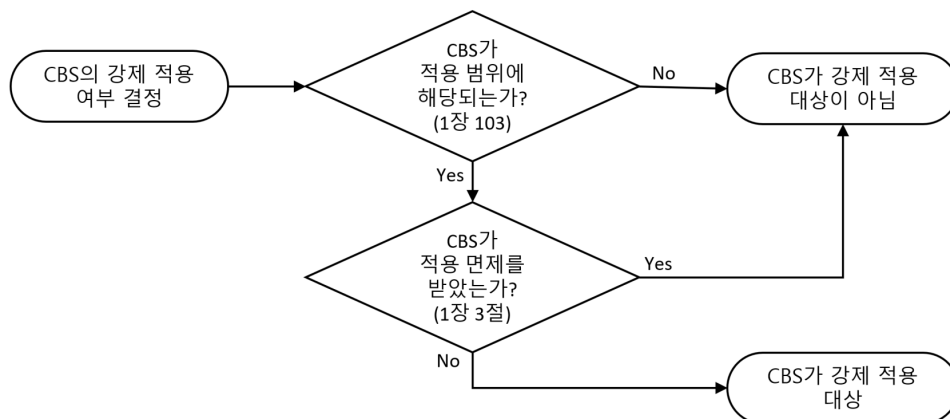


[그림 14] 호선용 기자재 도면승인 신청 예시

제 2 절 호선용 도면승인 및 검사 절차

1. 사이버복원력 적용 대상 여부 결정

시스템 제조사는 시스템 통합자(또는 조선소)와 협의하여 시스템이 적용 대상인지를 결정해야 한다.

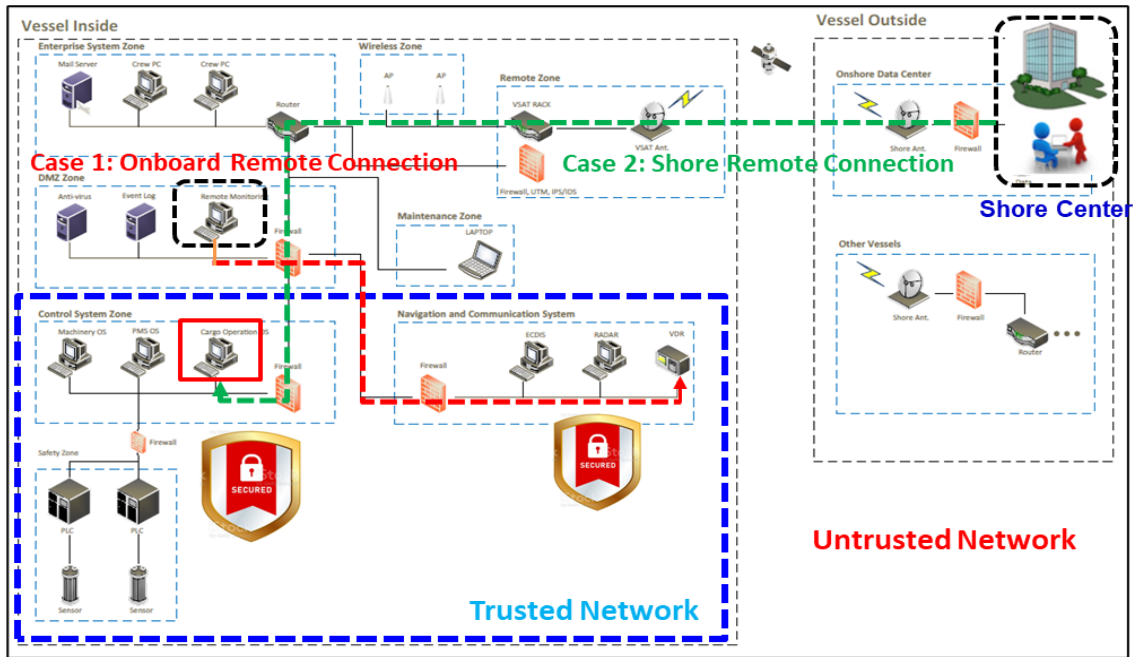


[그림 15] 사이버복원력 적용 대상 여부 결정

2. 시스템의 원격 연결 인터페이스 확인

호선용으로 탑재되는 시스템이 사이버복원력의 적용 대상으로 확인되면, 제조사는 시스템 통합자와 협의하여 시스템이 원격 연결 인터페이스를 제공 여부를 사전에 확인해야 한다.

원격 연결은 본 지침의 적용을 받는 시스템과 비신뢰 네트워크 간의 연결을 말한다. 즉, 사이버복원력 지침의 적용을 받는 시스템은 신뢰된 네트워크로 간주하고 있으며, 본 지침의 적용을 받지 않는 시스템 또는 장비는 비신뢰 네트워크로 간주하고 있다.



[그림 16] 원격 연결 인터페이스 연결 예시

선박 내에서 크게 2가지 경우의 원격 연결이 존재할 수 있다.

- 1) 적용 범위 내의 시스템이 선박 외부 육상의 시스템과 연결되는 경우 (예: 원격 유지보수 등)
- 2) 적용 범위 내의 시스템이 선박 내 비신뢰 네트워크에 위치한 다른 시스템 또는 장비와 연결되는 경우 (예: 선주의 데이터 수집 용도)

(1) 원격 연결이 없는 시스템의 경우

KR 사이버복원력 지침 3장 401에 따른 보안 기능을 만족해야 한다:

- 필수 보안 기능 30개 요구사항

(2) 원격 연결이 있는 시스템의 경우

KR 사이버복원력 지침 3장 401 및 402에 따른 보안 기능을 모두 만족해야 한다:

- 총 41개 요구사항 : 필수 보안 기능 30개 + 추가 보안 기능 11개

3. 호선용 시스템의 도면승인 및 검사 절차

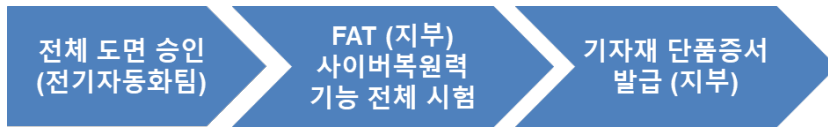
(1) 사이버복원력 형식승인을 받은 시스템의 경우



사이버복원력 형식승인을 받은 시스템의 경우 간소화된 목록의 문서들(4장 1절 참조)에 대해서 도면 승인을 득하면 된다. 또한, 별도 지적사항이 있는 경우를 제외하고는 제조사 공장에서 실시하는 FAT 에서 사이버복원력에 대한 시험은 요구되지 않는다. 다만, 규칙 6편 2장 3절 301.2에 따른 완성 시

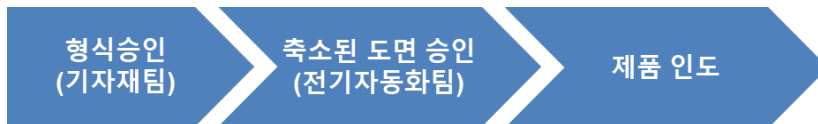
험은 수행 되어야 한다.

(2) 사이버복원력 형식승인을 받지 않은 시스템의 경우



사이버복원력 형식승인을 사전에 받지 않은 시스템의 경우 형식승인에 동등한 수준으로 규정에서 요구되는 전체 목록의 도면승인이 요구되며, FAT에서 규칙 6편 2장 3절 301.2에 따른 완성 시험과 함께 승인된 사이버복원력 시험절차서에 따른 전체 시험 및 검사가 요구된다.

(3) 사이버복원력 형식승인을 받았으나, KR 규칙 6편 2장에서 승인 및 검사가 요구되지 않는 시스템 (예: GMDSS, RADAR, ECDIS 등)



일부 시스템의 경우는 KR 사이버복원력 지침 1장에 따른 사이버복원력 적용 대상임에도 불구하고 KR 규칙 6편 2장에 따른 기자재 검사 대상에 포함되지 않을 수도 있다. 이러한 시스템의 대표적인 예는 SOLAS에서 요구되는 항해 및 통신설비 또는 MARPOL 협약에서 요구되는 배출가스저감설비들을 들 수 있다. 이러한 장비들에 대해서는 사이버복원력 형식승인을 받은 경우, 기자재 검사가 요구되지 않으므로 호선용 장비에 대한 간소화된 도면승인을 받고 시스템 통합자에 제품 인도가 가능하다.

4. 호선용 기자재 도면 승인 절차

앞에서 설명한 바와 같이 형식승인을 받은 시스템의 경우 아래와 같이 간소화된 도면승인을 우리 선급에 받을 수 있다. 다만, 그렇지 못한 경우에 대해서는 형식승인과 동등한 수준으로 호선용 도면승인을 받아야 한다.

제조사의 호선용 기자재에 대한 도면승인 신청은 EDAS를 통해 진행하며, 사이버복원력 관련 제출 문서에 대한 세부 내용은 4장을 참조한다.

5. 항해 및 무선통신 장비의 예외 적용

KR 사이버복원 지침 1장 106에 따라서 항해 및 무선통신 장비는 IEC 61162-460과 같은 동등한 표준의 적용이 우리 선급에 허용될 수 있다.

동등 표준이 적용되는 KR 사이버복원력 지침 3장 4절의 보안 기능 요건을 대신하여 적용되는 경우에는 호선용 도면승인을 득하고 제조사 공장에서 필요시 시험 및 검사를 실시해야 한다.

호선용 기자재 도면승인 단계에서 사이버복원력 지침 2장에서 요건을 만족하는지에 대한 추가 검증이 필요하며, 우리 선급이 필요하다고 인정하는 경우 추가의 자료 제출 및 시험이 요구될 수 있다.

제 4 장 제출 문서 안내

제 1 절 승인 문서 및 자료 목록

1. 승인문서 및 자료의 제출 목록

사이버복원력 적용 대상에 포함되는 시스템의 제조사는 형식승인(TA), 호선용 기자재 검사와 관련하여 KR 사이버복원력 지침 3장 202에 따라 도면승인을 받아야 한다.

아래의 표 3.2.1은 형식승인 또는 호선용 승인에 따른 제조사가 승인용으로 제출해야 할 문서 목록과 요구사항을 나타내고 있다.

3장에서 언급한 바와 같이 호선용 기자재 검사 단계에서 형식승인을 받은 시스템의 경우 축소된 목록의 문서들에 대한 도면승인이 요구된다. 다만, 형식승인이 없는 경우, 형식승인에 준하는 전체 문서 목록에 대한 도면승인이 요구된다.

표 3.2.1 제출 문서 목록

번호	문서명	요구사항	TA	호선용 승인	
				TA 있음	TA 없음
1	CBS 자산 목록	선박 자산 인벤토리에 포함될 내용 (2장 401.의 1항)	승인	승인	승인
2	토폴로지 다이어그램	시스템 통합자가 보안구역 및 전송로 설계를 가능하게 해야 함 (2장 402.의 1항)	승인	승인	승인
3	보안 기능 기술서	요구되는 보안 기능들 (401.) 만약 적용되는 경우, 추가의 보안 기능들 (402.)	승인		승인
4	보안 기능 시험절차	요구되는 보안 기능들 (401.) 만약 적용되는 경우, 추가의 보안 기능들 (402.)	승인		승인
5	보안 설정 지침	네트워크 및 보안 설정 (401./29번 항목)	참고		참고
6	SDLC 문서	SDLC 요구사항 (5절)	승인		승인
7	유지보수 및 검증 계획	보안 기능 검증 (401./19번 항목)	참고		참고
8	사고 대응 및 복구 계획 지원 정보	감사 이벤트 (401./13번 항목)	참고		참고
		결정론적 출력 (401./20번 항목)	참고		참고
		시스템 백업 (401./26번 항목)	참고		참고
		시스템 복구 및 재구성 (401./27번 항목)	참고		참고
9	변경관리 계획	변경관리 프로세스 (선급 및 강선규칙 6편 2장 4절)	참고		참고
10	시험 보고서	보안 기능 설정 및 강화 (301.의 5항, 501.의 7항)	참고	참고	참고

7

⁷ 표 3.2.1의 요구사항의 번호는 사이버복원력 지침의 요구 사항 번호를 의미함

2. 승인문서 및 자료의 내용

(1) CBS 자산 목록(CBS Asset Inventory)

CBS 자산 목록은 시스템을 구성하는 자산(구성품)에 대한 정보를 목록으로 작성한 문서로 제조사 하드웨어에 대한 구성품 목록 및 소프트웨어에 대한 구성품 목록을 작성하여야 한다.

1) 하드웨어 구성품 목록

명칭, 브랜드/제조사, 모델/형식, 기능/목적의 간략한 설명, 물리적 인터페이스, 시스템 소프트웨어의 명칭/형식, 시스템 소프트웨어⁸의 버전 및 패치 수준, 지원되는 통신 프로토콜 정보를 포함하여 작성하여야 한다.

2) 소프트웨어 구성품 목록

소프트웨어가 설치되는 하드웨어 구성품, 브랜드/제조사, 모델/형식, 기능/목적의 간략한 설명, 소프트웨어 버전 정보를 포함하여 작성하여야 한다.

(2) 토폴로지 다이어그램(Topology Diagram)

토폴로지 다이어그램은 시스템을 구성하는 구성품의 연결 관계를 나타내는 자료로서 물리적 토폴로지 다이어그램과 논리적 토폴로지 다이어그램을 작성하여야 한다. 하나로 결합된 토폴로지 다이어그램에 모든 요청되는 정보를 포함하여 작성하는 것도 가능하다.

1) 물리적 토폴로지 다이어그램

물리적 아키텍처(구성)를 확인할 수 있는 구성도로, CBS 자산 목록 내 하드웨어 구성품을 식별할 수 있도록 작성하여야 한다. 또한, 네트워크를 구성하는 모든 단말 장치와 네트워크 장치가 표시되어야 하며, 이중화 구성을 지원하는 경우 이를 알 수 있도록 작성하여야 한다. 케이블 정보는 입출력(hardwired I/O) 정보, RS 422/485를 포함하는 시리얼 통신, 이더넷 통신을 포함한 모든 통신 케이블 정보가 표시되어야 한다. 다른 시스템과 연결되는 경우 이에 대한 네트워크 및 통신 케이블 정보 또한 표시되어야 한다.

2) 논리적 토폴로지 다이어그램

논리적인 네트워크의 구성도로서 시스템 구성요소 간 데이터 흐름을 알 수 있도록 작성하여야 한다. 통신 즉, 데이터의 흐름을 알 수 있도록 네트워크 장치(e.g. 스위치, 라우터, 방화벽 등)와 통신의 종단점에 위치하는 단말 장치(e.g. 서버, 워크스테이션, HMI, PLC 장치 등) 정보가 표시되어야 하며, 장치 간의 통신 프로토콜 정보를 표시하여야 한다. 단말기는 가상 컴퓨터(e.g. VMWARE)를 사용하는 경우 표시되어야 하며, 물리적 및 가상의 통신 경로(e.g. VLAN)가 표현되어야 한다.

(3) 보안 기능 기술서(Description of security capabilities)

⁸ 시스템 소프트웨어 : 하드웨어 요소들을 직접 제어, 통합, 관리하는 소프트웨어로 운영체제(OS), 드라이버, 유틸리티, 펌웨어, 데이터베이스 관리 시스템(DBMS) 등을 포함한다. 응용 소프트웨어(Application software)의 반대 개념이다.

보안 기능 기술서는 지침 3장 4절 보안 기능 요구사항에 명시된 보안 기능 요구 사항을 제조사의 시스템이 어떻게 만족하는지 기술하는 문서로 필수 보안 기능 30개 항목 및 추가 보안 기능 11개 항목에 대해 요구 사항을 만족함을 설명하는 내용을 각각의 장으로 작성하여야 한다.

시스템 내부 및 외부의 모든 네트워크 인터페이스가 기술되어야 하며 이는 CBS 자산 목록 및 토폴로지 다이어그램의 정보를 활용할 수 있다. 네트워크 인터페이스 정보를 바탕으로 비신뢰 네트워크⁹와의 연결을 알 수 있으며 연결이 있는 경우 추가 보안 기능 11개 항목이 적용되어야 한다. 비신뢰 네트워크와의 연결이 없는 경우 필수 보안 기능 30개 항목에 대해서만 보안 기능 기술서를 작성한다.

(4) 보안 기능 시험절차서(Test procedure of security capabilities)

보안 기능 시험절차서는 지침 3장 4절 보안 기능 요구사항에 명시된 보안 기능 요구 사항을 제조사의 시스템이 어떻게 만족하는지를 시험하여 증명하는 방법을 기술하는 문서이다.

문서의 형식에 있어서는 동일한 예상 결과로 시험을 반복할 수 있음을 보장하기 위한 필요한 시험 설정, 시험 대상이 되는 장비, 시험을 위한 초기 조건(설정), 상세한 시험 단계 및 방법을 안내하는 시험 방법론, 예상되는 결과 및 합격 기준을 포함하여 작성하여야 한다.

형식시험이 완료된 후 제조사는 시험 결과(예: 사진 등)를 시험절차서에 업데이트 하여 시험 보고서를 우리 선급에 제출하여야 하므로 이를 위한 공간(여백)을 포함하여 작성하여야 한다.

(5) 보안 설정(Security configuration) 지침

보안 설정 지침은 보안 기능의 권장되는 구성 설정과 초기값을 안내하는 문서로 다음의 내용을 포함하여 작성한다. 시스템이 실제 선박에 설치될 때 보안 설정 지침에 따라 올바르게 설정되어야 하며, 설치 후 선내에서 보안 설정의 적절성이 확인되어야 한다.

- 1) 사용자 계정
- 2) 권한 부여
- 3) 비밀번호 정책
- 4) 제품의 안전한 상태
- 5) 방화벽 정책(방화벽이 제공되는 경우)

(6) 보안 개발 수명주기(SDLC: Secure Development Life-Cycle) 문서

보안 개발 수명주기(이하: SDLC) 요구 사항은 제품의 개발에서 폐기까지의 전 생애 주기 동안 제품의 보안을 지키기 위한 프로세스(절차) 요구 사항으로 IEC 62443-4-1의 요건을 기반으로 시스템이 납품된 이후의 관리를 위한 제조사의 7가지 품질 프로세스(절차)를 포함한다. 제조사는 SDLC 요구 사항에 따른 프로세스를 수립하고 이와 관련된 제조사의 정책/절차서를 작성하고 이를 이행하여야 한다.

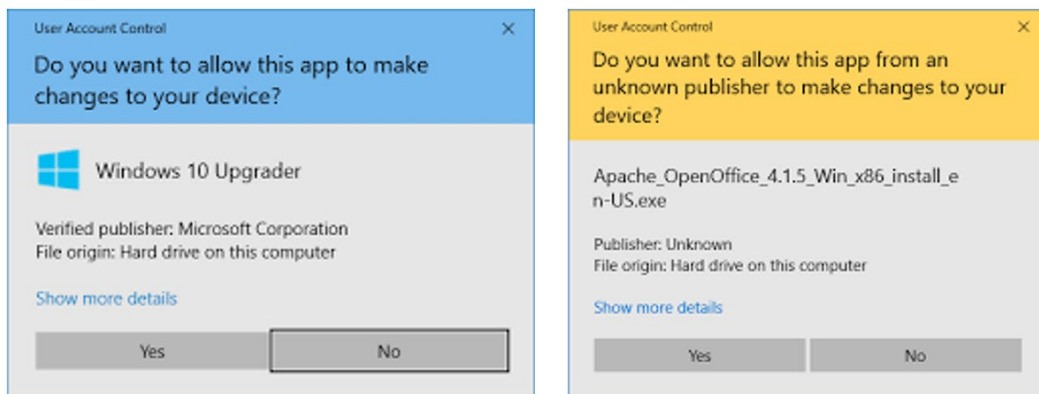
- 1) 개인키 통제(IEC 62443-4-1/SM-8)

⁹ 사이버복원력 지침의 적용 대상이 아닌 네트워크(e.g. 육상에서의 연결, 지침 미적용 대상인 선 내 시스템과의 네트워크 연결 등)

코드 서명(code signing)을 사용하는 경우, 서명을 위한 개인키를 보호하기 위한 절차 및 기술적 통제를 마련해야 한다.

코드 서명은 응용 프로그램(Application software)에 디지털 서명을 하여 사용자가 프로그램의 출처(제조사/제공자)를 알 수 있도록 하고 원본으로부터 위변조가 되지 않았음을 알 수 있도록 하는 방법의 하나이다.

[그림 17]의 왼쪽과 같이 제조사가 코드 서명 후 배포한 프로그램을 사용자가 실행한 경우 제품의 제조사 정보를 알 수 있다. 배포된 프로그램에 위변조가 일어난 경우 서명이 훼손되며 프로그램 실행 시 [그림 17]의 오른쪽과 같이 서명된 정보를 알 수 없음을 알리는 경고 문구를 띄우게 된다. 코드 서명이 되어있지 않은 프로그램을 실행할 경우에도 [그림 17]의 오른쪽과 같은 경고 문구가 발생한다. 코드 서명을 위해서는 온라인 बैं킹을 사용할 때 사용하는 공동인증서와 유사한 코드 서명을 위한 인증서를 제조사가 발급받아야 하며 코드 서명을 위한 도구(e.g. 디지털 서명 마법사 등)를 이용하여 실행 파일, 업데이트 파일 등에 서명을 할 수 있다.



[그림 17] 코드 서명된 파일 실행(왼쪽) 및 서명되지 않은 파일 실행(오른쪽) 예시

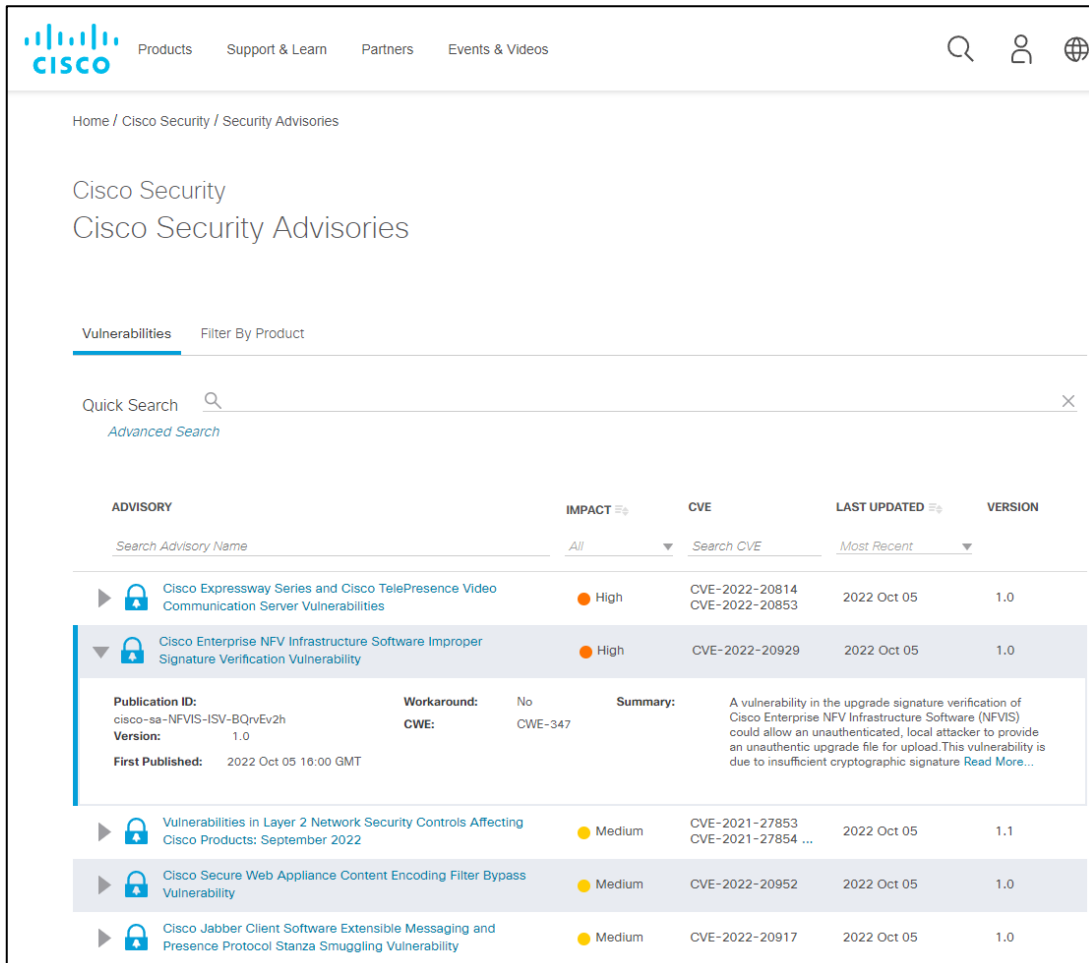
개인키는 코드 서명을 위한 인증서에 포함되어 있으며, 인증서 및 서명시에 사용되는 비밀번호가 외부에 유출되는 경우 해당 제조사의 이름으로 악성코드를 심은 실행 파일, 업데이트 파일 등을 배포하더라도 사용자는 제조사에서 공급한 것으로 알고 프로그램을 실행하여 악성코드에 감염될 수 있다. 따라서 제조사가 코드 서명을 사용하는 경우 개인키가 외부에 유출되지 않도록 보호(인증서, 서명시의 비밀번호 등)하기 위한 개인키의 생성, 유지, 변경, 폐기에 대한 기준과 절차를 마련하고 관리 대장 등을 통해 꾸준히 관리하여야 한다.

2) 보안 업데이트 문서(IEC 62443-4-1/SUM-2)

보안 업데이트는 제조사에서 공급한 승인된 패치 파일로 수행되어야 하며 이를 안전하게 제공하기 위한 프로세스를 보유해야 한다. 제품 공급자가 가용한 보안 패치, 승인된 패치를 설치하는 방법, 구성품의 패치 상태를 판단하는 방법 및 승인되지 않은 패치를 교정하는 방법을 식별하고 설명한 문서를 제공하거나 만들어야 한다. 제공 방식은 문서 제공, 메일 송부, 홈페이지 안내 등 다양한 방법을 사용할 수 있으며 프로세스에는 최소한 다음의 세부 사항들을 포함하여야 한다.

- 보안 패치가 적용되는 제품 버전 번호
- 승인된 패치를 수동 및 자동 프로세스를 통해 적용하는 방법에 대한 설명

- 재부팅을 포함하여 제품에 패치를 적용할 경우 미칠 수 있는 영향에 대한 기술
- 승인된 패치가 적용되었는지를 검증하는 방법에 대한 설명
- 자산 소유자가 제조사에서 승인 및 배포하지 않은 패치를 사용하거나 혹은 패치를 하지 않을 경우의 위험



[그림 18] 보안 업데이트 제공 예시 <출처 : CISCO>

3) 종속 구성요소나 운영체제 보안 업데이트 문서 (IEC 62443-4-1/SUM-3)

종속 구성요소는 제품이 의존하는 외부의 구성요소로 예를 들어, 제조사의 시스템이 Oracle 사의 MySQL 을 구매하여 사용하며 MySQL 이 없는 경우 시스템의 작동에 문제가 발생하는 경우 MySQL 은 시스템의 종속 구성요소가 된다. 시스템을 구성하는 종속 구성 요소 및 운영 체제(e.g. 윈도우, 리눅스 등)에서는 보안 업데이트를 제공하지만 사용자 입장에서는 시스템에 오작동을 일으킬 수 있는 위험으로 인해 업데이트를 주저하게 되므로 제조사에서는 사용자에게 운영체제 및 종속 구성요소의 보안 업데이트가 제품과 호환되는지 여부에 관한 정보를 제공해야 하며 이를 위한 프로세스를 보유해야 한다.

4) 보안 업데이트 제공 (IEC 62443-4-1/SUM-4)

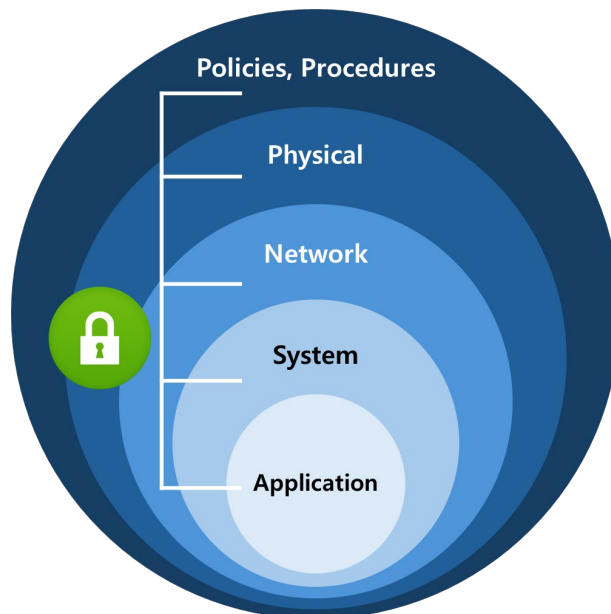
사용자에게 공급되는 보안 업데이트는 진위 여부를 손쉽게 판별할 수 있도록 해야 한다. 악성 코드가 숨어있는 패치 파일, 손상된 파일등으로 인한 업데이트는 시스템에 심각한 문제를 일으킬 수 있다. 이에 대한 예시로는 코드 서명된 패치 파일의 배포 등이 있으며 이를 위한 프로세스를 보유해야 하며 또한 배포 전 내부 시험을 위한 프로세스 또한 보유해야 한다.

5) 제품 심층 방어(IEC 62443-4-1/SG-1)

심층 방어(Defense in depth)는 시스템 전반에 걸쳐 여러 계층의 독립적인 보안 통제를 적용하여, 특정 공격으로 하나의 보안 통제(방어) 수단이 무효화 되어도 나머지 유효한 보안 통제를 통해 시스템을 안전하게 보호하는 개념이다.

심층방어의 보호 계층은 크게 물리적, 기술적, 관리적 세 가지 영역으로 나눌 수 있다.

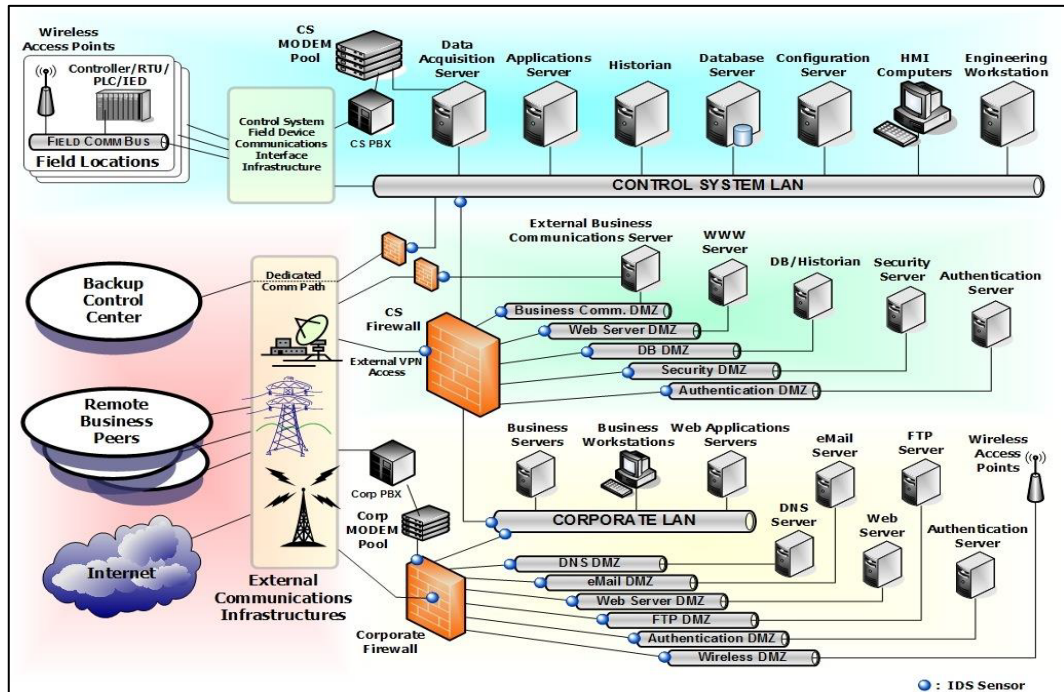
- 1) 관리적 통제 : 조직의 정책과 절차, 보안 관련 지침, 교육 훈련 등
- 2) 물리적 통제 : 시스템에 대한 사람의 물리적 접근을 제한하는 수단
- 3) 기술적 통제 : 시스템 하드웨어 또는 소프트웨어 및 네트워크에 대한 기술적 보안 수단



[그림 19] 심층 방어 모델 예시

IEC 62443 4-1의 'SG'는 보안 지침(Security guidelines)을 의미한다. KR 사이버복원력 지침에서 명시된 SDLC의 요구 사항은 납품 이후의 관리에 초점을 두고 있으며 제조사는 이에 따라 제품의 설치, 운영 및 유지보수를 지원하기 위한 심층 방어 전략을 수립하고 이에 대한 내용을 기술하는 문서를 생성하기 위한 프로세스를 수립하여야 한다. 프로세스에는 최소한 다음을 포함하여야 한다.

- 제품에서 구현된 보안 기능과 심층 방어 전략에서의 역할
- 심층 방어 전략에 의해 고려된 위협
- 레거시 코드(legacy code)와 관련된 위험을 포함하여, 제품과 관련하여 알려진 보안 위험에 대한 제품의 사용자 완화 전략



[그림 20] 심층 방어 전략 구성 예시 <출처 : NIST SP 800-82 R.2>

6) 환경에서 예상되는 심층 방어 조치 (IEC 62443-4-1/SG-2)

시스템이 설치 및 사용되는 환경에서 제공되어야 하는 보안 심층 방어 조치를 사용자에게 설명하는 안내 문서를 작성하기 위한 프로세스 또한 채택되어야 한다. 보안과 관련된 환경의 예시는 다음을 참고할 수 있다.

- 네트워크상에서 위치
- 제품이 적용되는 환경에서 제공되는 물리적 보안이나 사이버 보안
- (네트워크 관점에서의) 격리
- (확인이 가능한 경우) 환경에 미치는 잠재적 영향(e.g. 인명 손실, 부상, 생산 손실 등)

7) 보안 강화 지침 (IEC 62443-4-1/SG-3)

시스템의 설치 및 유지보수의 관점에서 사용자 역시 보안을 지속적으로 강화할 수 있도록 하여야 하며 제조사는 이를 지원하기 위한 지침(가이드라인)을 제공하기 위한 프로세스를 보유해야 한다. 지침에 포함되어야 할 사항들은 다음과 같다.

- 운영에 필요한 외부 장치(제3자 구성품)를 포함하여 시스템의 통합 관점에서의 보안을 위해 필요한 사항
- 사용자가 사용하는 소프트웨어 어플리케이션이 시스템과 통합되는 경우, API¹⁰ 및 프로토콜의 통합 관점에서의 보안을 위해 필요한 사항
- 시스템의 심층 방어 전략의 적용 방법 및 유지보수 방법 안내

¹⁰ API(Application Programming Interface, 응용 프로그래밍 인터페이스) : 컴퓨터나 컴퓨터 프로그램 사이의 연결. 컴퓨터와 인간을 연결시키는 사용자 인터페이스의 반대 개념으로 컴퓨터나 소프트웨어를 서로 연결하는 인터페이스

- 사용자가 직접 사용하는 시스템의 각 부분(로컬)의 사용에 대한 보안 정책을 지원하기 위한 권고되는 구성 및 보안 옵션/기능 등의 사용방법 안내
- 시스템의 보안을 위한 관리, 감시, 사고 대응, 평가와 관련된 모든 보안 관련 도구/유틸리티의 사용 방법 및 권장 사항 안내
- 권고되는 정기적인 보안 유지보수 활동 방법 안내
- 시스템의 유지보수 및 관리에 대한 모범 사례 설명

(7) CBS의 유지보수 및 검증 계획

CBS의 유지보수 및 검증 계획은 시스템의 보안 관련 유지보수 및 시험을 위한 절차를 포함하는 자료로 KR 사이버복원력 지침 3장 401의 19번 요구사항에서 요구되는 시스템 보안 기능의 올바른 작동 검증을 지원하는 문서이다. 이 요구사항의 참고가 되는 IEC 62443-3-3 SR 3.3에 따르면, 해당 표준의 근거 및 보충 지침에 따른 보안 검증 기능의 예시는 다음과 같다.

1) EICAR 테스트 파일을 이용한 안티바이러스 백신 프로그램의 탐지 기능 검증

EICAR (European Institute for Computer Antivirus Research) 테스트 파일은 아래의 주소에서 받을 수 있다.

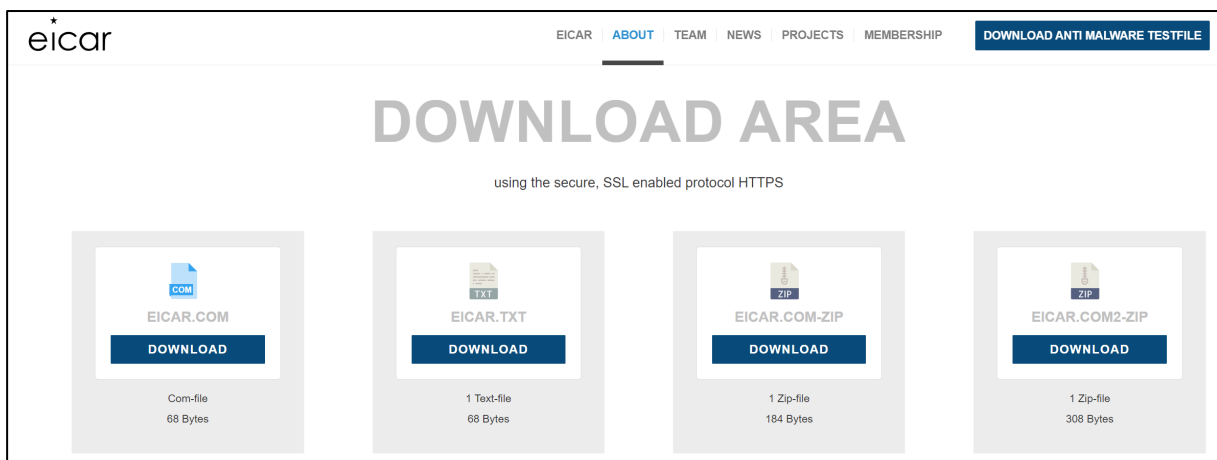
- <https://www.eicar.org/download-anti-malware-testfile/>

안티바이러스 백신 프로그램이 제공되는 경우 해당 프로그램이 악성코드를 탐지하는지를 확인하기 위해서 실제 바이러스 프로그램을 사용하는 것은 위험하며 안전한 테스트를 위해 EICAR에서는 안티바이러스 백신 업체와 협력하여 실제 바이러스는 아니지만 프로그램에서 바이러스로 인식하여 테스트를 수행할 수 있도록 하는 EICAR 테스트 파일을 배포하고 있다.

EICAR 테스트 파일은 다음과 같다.

X5O!P%#@AP[4\PZX54(P^)7CC)7}\$EICAR-STANDARD-ANTIVIRUS-TEST-FILE!\$H+H*

테스트 방식은 위 문구를 메모장 등에 붙여 넣기 하면 되며, 저장시에는 안티바이러스 백신이 바이러스가 탐지되었음을 알린다.



[그림 21] EICAR 테스트 파일 다운로드 화면 예시 <출처 : www.eicar.org>

- 2) 미허가 계정으로 무단 접근을 시도하여 식별, 인증 및 사용 통제 대책을 검증
- 3) 침입 탐지 시스템(IDS, Intrusion Detection System)의 정책을 위반하여 IDS에 탐지됨을 검증 (IDS가 제공되는 경우)
- 4) 감사 기록이 보안 정책과 절차가 요구하는 대로 발생하고 사용자가 비활성화 할 수 없음을 확인

(8) 선주의 사고 대응 및 복구 계획 지원 정보

선주의 사고 대응 및 복구 계획 지원 정보는 선주가 선박의 운항 단계에서 KR 사이버복원력 지침 2장 404.1(사고 대응 계획) 및 405.1(복구 계획)의 요건에 따라 사고 대응 계획 및 복구 계획을 수립하기 위해 필요한 기초 정보를 제공되는 문서이다. 이 문서는 다음에 대한 절차 및 설명을 포함해야 한다.

- 1) 로컬 독립 제어 (KR 사이버복원력 지침 2장 404.2 참조)
- 2) 네트워크 격리 (KR 사이버복원력 지침 2장 404.3 참조)
- 3) 감사 기록의 사용에 의한 포렌식 (필수 보안 기능 13번 참조)
- 4) 결정론적 출력 (필수 보안 기능 20번 참조)
- 5) 백업 (필수 보안 기능 26번 참조)
- 6) 복구 (필수 보안 기능 27번 참조)
- 7) 제어된 종료, 재설정, 롤백 및 재시작 (KR 사이버복원력 지침 2장 405.3 참조)

(9) 변경관리 계획

변경관리 계획은 소프트웨어의 변경에 대한 관리 문서로 소프트웨어의 변경 절차, 버전 식별, 변경 시의 영향 분석, 변경 실패시의 롤백, 변경 확인 및 검증, 기록 등을 다루고 있으며 선급 및 강선규칙 6편 2장 4절에서 또한 요구되는 항목으로 상세 내용은 관련 요건을 참고한다.

(10) 시험 보고서

승인된 보안 기능 시험절차서에 따라 시험을 진행한 후 시험 결과를 업데이트하여 우리 선급에 시험 보고서를 제출하여야 한다.

제 5 장 보안 기능 요구사항

제 1 절 일반 사항

1. 원격 연결 인터페이스의 확인

시스템 제조사는 시스템의 구성품 중에서 원격 연결 인터페이스 제공하는 장비를 식별하여야 한다. 그 이유는 원격 연결 인터페이스가 없는 구성품의 경우에는 30개의 필수 보안 기능 요구사항을 충족하면 되지만, 원격 연결 인터페이스가 있는 구성품의 경우 필수 보안 기능 요구사항에 추가하여 11개의 추가 보안 기능 요구사항을 만족해야 되기 때문이다.

실제 선박 내 시스템의 설치 시에 원격 연결 인터페이스의 사용 유무는 선박의 설계 및 건조단계에서 시스템 통합자(또는 조선소)에 의해 최종 확인될 수 있다. 그러나, 형식승인을 미리 준비해야 하는 제조사의 입장에서 형식승인의 요구사항 적용 범위가 달라지기 때문에 시스템 제조사는 사전에 시스템 통합자(조선소)와 협의하여 시스템의 원격 연결 인터페이스 제공의 필요성을 검토하고 형식승인을 준비할 필요가 있다. 원격 연결에 대한 추가 정보는 기술 가이드 3장을 참고한다.

2. 시스템의 각 구성품에 대한 보안 기능 요구사항 적용 범위 결정

시스템을 구성하고 있는 구성품 중에서 원격 연결 인터페이스를 제공 유무에 따라서 각 구성품에 대한 요구사항의 적용 범위가 아래와 같이 달라지게 된다.

(1) 원격 연결 인터페이스가 없는 경우 : 보안 기능 요구사항 30개 적용

원격 연결 인터페이스가 없는 시스템의 구성품은 아래의 필수 보안 기능 요구사항을 만족해야 한다.

1) 필수 보안 기능 (30개)

Objective	Q'ty of Requirements	Reference
FR.1 Identification and Authentication control (IAC)	7 EA	Ch.3, 401. KR Guidance for Cyber Resilience IEC62443-3-3
FR.2 Use Control (UC)	9 EA	
FR.3 System Integrity (SI)	4 EA	
FR.4 Data Confidentiality (DC)	2 EA	
FR.6 Timely Response to Events (TRE)	1 EA	
FR.7 Resource Availability (RA)	7 EA	
Total	30 EA	

[그림 22] 필수 보안 기능 요구 사항

(2) 원격 연결 인터페이스가 있는 경우 : 보안 기능 요구사항 41개 적용

원격 연결 인터페이스가 있는 시스템의 구성품은 상기의 필수 보안 기능 요구사항 30개에 추가하여 아래의 추가 보안 기능 요구사항 11개를 만족해야 한다.

1) 필수 보안 기능 (30개 요구사항)

Objective	Q'ty of Requirements	Reference
FR.1 Identification and Authentication control (IAC)	7 EA	Ch.3, 401. KR Guidance for Cyber Resilience IEC62443-3-3
FR.2 Use Control (UC)	9 EA	
FR.3 System Integrity (SI)	4 EA	
FR.4 Data Confidentiality (DC)	2 EA	
FR.6 Timely Response to Events (TRE)	1 EA	
FR.7 Resource Availability (RA)	7 EA	
Total	30 EA	

[그림 23] 필수 보안 기능 요구사항

2) 추가 보안 기능 (11개 요구사항)

Objective	Q'ty of Requirements	Reference
FR.1 Identification and Authentication control (IAC)	6 EA	Ch.3, 402. KR Guidance for Cyber Resilience / IEC 62443-3-3
FR.2 Use Control (UC)	1 EA	
FR.3 System Integrity (SI)	4 EA	
Total	11 EA	

[그림 24] 추가 보안 기능 요구사항

3. 보상 대책의 적용

제조사는 시스템의 운영 환경 및 장비의 특성 상 보안 기능의 일부를 적용하기 어려운 경우가 있다. 이 경우 KR 사이버복원력 지침 3장 104.4에 따라서 만족하기 어려운 하나 이상의 보안 기능들을 대신하여 보상 대책의 적용이 가능하다.

보상 대책의 적용하는 경우 제조사는 반드시 형식승인 또는 호선용 기자재 도면승인 단계에서 제출되는 보안 기능 기술서 상에 보상 대책을 적용하는 보안 기능들을 명시하고 이에 대한 보상 대책을 기술해야 한다. 또한, 제조사는 제안한 보상 대책이 원래 의도된 보안 기능의 동등이상 수준의 보안을 제공할 수 있는지에 대한 유효성을 문서상에서 입증해야 한다.

제 2 절 필수 보안 기능 요구사항 해설 및 적용 사례

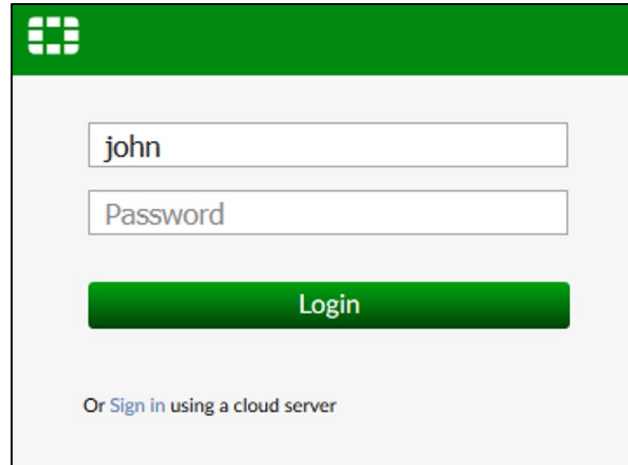
1. 식별 및 인증 (KR 사이버복원력 지침 3장 401)

(1) 보안 기능 설명

식별(Identification)은 시스템이 사용자가 누구인지를 확인하는 것을 의미하며, 인증(Authentication)은 이에 대한 신원 검증을 의미한다. 서비스를 제공하는 서버에 접속하기 위해 사용자는 ID와 패스워드를 입력하여 로그인을 해야 하며 이 경우 ID는 식별자(Identifier)에 해당하고 인증자(Authenticator)는 패스워드에 해당한다. 계정(Account)은 식별자와 인증자를 포함하는 개념이다. 인증자의 종류는 패스워드 외에도 OTP¹¹, 보안카드, 공인인증서 등 다양한 수단이 사용될 수 있다.

¹¹ OTP : One Time Password

시스템은 HMI(Human Machine Interface)와 같은 인간 사용자가 접근 가능한 인터페이스에서 시스템 사용을 위해 식별 및 인증 기능을 구현하여야 한다. 시스템에 무선 네트워크가 포함되어 있는 경우 무선 네트워크의 사용시에도 식별 및 인증 기능을 제공해야 한다. 또한 ID와 PW에 대한 생성 및 전반적인 관리 기능을 제공해야 한다. 인증자 중 패스워드를 사용하는 경우 복잡성(Complexity)에 대한 보안 기능이 요구된다. 패스워드 복잡성은 특정 자릿수 이상 및 다양한 숫자 및 문자의 조합을 패스워드 생성시 강제하여 무작위 대입공격 등으로부터 보호하는 역할을 한다. 사용자가 시스템에 인증자 입력 시 외부에 보여지는 것을 막기위해 인증자의 입력 값(피드백)은 *****와 같은 기호 등을 사용하여 보이지 않도록 해야 한다. 또한 인증자를 잘못 입력한 경우 모호한 피드백 즉, ID/PW 어느 쪽이 틀렸는지에 대한 정보를 제공하지 않도록 하여야 한다.



[그림 25] Fortinet 방화벽 로그인 화면 예시

<출처 : Fortinet>

(2) 보안 기능 요구사항 설명 및 예시

항목/목적	1. 인간 사용자 식별 및 인증	참조 표준	IEC62443-3-3/SR1.1
요구사항	CBS 는 시스템에 직접 또는 인터페이스를 통해 접근할 수 있는 모든 인간 사용자를 식별하고 인증해야 한다.		
적용대상	원칙적으로 모든 CBS 에 적용해야 한다. (단, 적용이 불가능한 경우, 보상조치 방법에 대한 설명이 요구될 수 있다.)		
적용 설명	모든 인간 사용자는 컴퓨터기반 시스템에 대한 모든 접근에 대하여 식별 및 인증을 받아야 한다. 이런 사용자 신원의 인증은 패스워드, 토큰, 생체나 이것들의 조합인 다중 인증과 같은 방법을 사용하여 수행된다. 인간 사용자의 지리적 위치가 인증 프로세스의 일부분으로 사용될 수도 있다. 이 요구사항은 컴퓨터기반 시스템의 로컬 및 원격 접속 양쪽에 적용된다. 컴퓨터기반 시스템 등급에서 모든 인간 사용자의 식별 및 인증(예: 시스템 로그인)에 추가하여, 식별 및 인증 매커니즘이 종종 애플리케이션 등급에서 적용된다. 인간 사용자가 단일 그룹(통제실 운영자와 같은)으로 동작할 경우, 사용자 식별 및 인증은 역할 기반 이거나 그룹 기반일 수도 있다. 어떤 컴퓨터기반 시스템에서, 즉시적 운영자 상호작용을 위한 역량이 필수적이다. 컴퓨터기반 시스템 필수 기능 뿐만 아니라 지역 비상 활동이 식별이나 인증 요구사항에 의해 방해 받아서는 안 된다. 이러한 시스템의 접근은 적절한 물리적 보안 매커니즘으로 제한될 수도 있다. 이런 상황의 예제는 엄격한 물리적 접근 통제와 감시가 적절하게 배치되고 교대 계획이 사용자 그룹에 책임을 배정한 작업실이다. 이러한 사용자는 동일 사용자 신원을 사용할 수도 있다. 덧붙여, 지정된 운영자 워크스테이션 클라이언트가 인증되거나 이러한 공유 계정 사용이 제한된 제어실 환경으로 제약되어야 한다.		

기능 예시	인간 사용자가 접근할 수 있는 인터페이스(e.g. HMI 등)에서 로그인과 같은 식별 및 인증 절차를 거친 후 시스템을 사용 가능하도록 한다. 다만, 가용성 이 중요한 선내 시스템의 특성상 식별 및 인증 없이 최소한의 기능을 사용하는 것이 허용된다.(e.g. 제어 시스템의 모니터링 기능, 비상 정지 기능 등은 항상 제공, 알람 설정 값 변경 등은 로그인 후 가능 등) [그림 26] Fortinet 방화벽 로그인 화면 예시 <출처 : Fortinet>
-------	---

항목/목적	2. 계정 관리	참조 표준	IEC62443-3-3/SR1.3
요구사항	CBS 는 계정 추가, 활성화, 수정, 비활성화 및 제거를 포함하여 허가된 사용자의 모든 계정 관리를 지원하는 기능을 제공해야 한다.		
적용대상	원칙적으로 모든 CBS 에 적용해야 한다. (단, 적용이 불가능한 경우, 보상조치 방법에 대한 설명이 요구될 수 있다.)		
적용 설명	계정 관리는 계정 그룹화(예: 개인, 역할 기반, 기기 기반 및 컴퓨터기반 시스템), 그룹 멤버십의 조건 설정 및 관련된 인가의 배정을 포함할 수도 있다. 어떤 컴퓨터기반 시스템 인스턴스에서, 개별 계정이 위험 분석 및/또는 규제 관점에서 불필요하다고 간주될 경우, 공유 계정은 적절한 보완 대책(제한된 물리적 접근 또는 기관 승인 대책)이 적절하게 준비되고 문서화되는 한 수용이 가능하다. 처음 시스템 설치에 사용되고 이후에 사용되지 않는 디폴트 시스템 계정은 삭제되어야 한다. 보안 강화는 계정 관리의 간소화와 지속적인 애플리케이션에 의해 좌우된다.		
기능 예시	관리자 계정과 같은 특정 계정에서 모든 계정의 관리를 지원하는 기능을 제공한다. [그림 27] 계정 관리 화면 예시 <출처 : www.phpkb.com>		

항목/목적	3. 식별자 관리	참조 표준	IEC62443-3-3/SR1.4
요구사항	CBS 는 사용자, 그룹 및 역할별 식별자 관리를 지원하는 기능을 제공해야 한다.		
적용대상	원칙적으로 모든 CBS 에 적용해야 한다. (단, 적용이 불가능한 경우, 보상조치 방법에 대한 설명이 요구될 수 있다.)		
적용 설명	식별자는 특정 컴퓨터기반 시스템 영역이나 구역 내에 수행하기 위해 개체를 허용하는 권한과 구별된다. 인간 사용자가 단일 그룹(통제실 운영자와 같은)으로 동작할 경우, 사용자 식별은 역할 기반, 그룹 기반이거나 기기 기반일 수도 있다. 일부 컴퓨터기반 시스템의 경우 즉각적인 운영자 상호작용을 위한 기능이 매우 중요하다. 컴퓨터기반 시스템에 대한 일부 비상 조치가 식별 요건에 의해 방해되지 않아야 한다. 이러한 시스템의 접근은 적절한 보안 대책으로 제한될 수도 있다. 식별자가 컴퓨터기반 시스템의 일부분으로 요구될 수도 있지만, 전체 컴퓨터기반 시스템일 필요는 없다. 예를 들어, 무선 기기에는 일반적으로 유선 기기가 요구하지 않는 식별자가 필요하다.		
기능 예시	각 사용자별 식별자(ID-Identifier)에 대한 관리 기능을 제공한다.		

항목/목적	4. 인증자 관리	참조 표준	IEC62443-3-3/SR1.5
요구사항	CBS 는 다음의 능력을 제공해야 한다. - 인증자 내용을 초기화 - 제어 시스템 설치 시 모든 기본 인증자를 변경 - 모든 인증자를 변경/새로고침 - 저장 및 전송 시 모든 인증자를 무단 공개 및 수정으로부터 보호		
적용대상	원칙적으로 모든 CBS 에 적용해야 한다. (단, 적용이 불가능한 경우, 보상조치 방법에 대한 설명이 요구될 수 있다.)		
적용 설명	식별자 이외에 신원을 증명하기 위한 인증자가 필요하다. 컴퓨터기반 시스템 인증자는 토큰, 대칭 키, 개인 키(공개/개인 키 쌍의 부분), 생체 인식, 암호, 물리적 키 및 키 카드와 같은 것을 포함하지만 이에 국한되지는 않는다. 인간 사용자는 개인 인증자의 소유를 유지하고 다른 사람과 인증자를 공유하거나 대여하지 않으며, 분실 또는 손상된 인증자를 즉시 보고하게 하는 등 인증자를 보호하는 합리적인 수단을 가져야 한다. 인증자는 생애주기를 가진다. 계정이 생성되면 계정 소유자가 인증을 받을 수 있도록 자동적으로 신규 인증자가 생성된다. 예를 들어 패스워드 기반 시스템인 경우, 계정은 계정과 관련된 패스워드를 가진다. 초기 인증자 내용의 정의는 계정 관리 시스템이 모든 신규 계정에 설정하는 초기 패스워드를 관리자가 정의하는 것으로 해석할 수 있다. 이런 초기값을 설정하는 것은 공격자가 계정 생성과 처음 계정 사용(계정 소유자에 의한 신규 패스워드 설정을 포함) 사이에 패스워드를 추측하는 것을 더 어렵게 만든다. 일부 컴퓨터기반 시스템은 모든 필요한 계정을 디폴트 패스워드로 생성하는 무인 설치 방식으로 설치되고 일부 임베디드 기기는 디폴트 패스워드로 출하된다. 시간이 지날수록, 이러한 패스워드는 점점 일반적인 지식이 되고 인터넷 상에 문서로 남는다. 디폴트 패스워드를 변경하는 것은 미허가 사용자가 접근 권한을 얻기 위해 디폴트 패스워드를 사용하는 공격으로부터 시스템을 보호한다. 패스워드는 네트워크 인증에 사용될 때 전송되거나 저장소로부터 획득될 수 있다. 이러한 복잡성은 패스워드 전송을 결코 요구하지 않는 핸드셰이크 프로토콜 또는 암호화나 해싱과 같은 암호 기반 보호에 의해 증가될		

	수 있다. 여전히 패스워드는 공격 대상이 될 수도 있다(예를 들어, 저장 또는 전송 중인 패스워드의 암호 기반 보호를 깨거나 무작위로 추측하는 공격). 정기적으로 패스워드를 변경하거나 새로고침으로 공격 기회를 줄일 수 있다. 유사한 고려사항이 암호 키 기반의 인증시스템에도 적용된다. 신뢰 플랫폼 모듈(TPM, Trusted Platform Modules)과 같은 하드웨어 보안 모듈 방식의 하드웨어 메커니즘을 사용하여 보호를 강화할 수 있다. 인증자 관리는 적용 가능한 보안 정책과 절차에 명시해야 한다. 예를 들어, 디폴트 인증자 변경에 대한 제약사항, 새로고침 주기, 인증자 보호를 위한 세부 사항 또는 비상호출 절차가 있다. 보안 대책으로 인한 제어 손실이나 잠금은 허용되지 않는다. 만일 컴퓨터기반 시스템에 높은 수준의 가용성이 요구된다면, 대책이 높은 수준의 가용성을 유지하기 위해 고려되어야 한다(보안 물리적 대책, 이중 키 및 관리상 무시). 이 요구사항에 명시된 인증자 관리 역량 외에, 인증자 메커니즘의 강도는 선택한 인증자의 강도(e.g. 패스워드 복잡도 또는 공개 키 인증의 키 길이)와 인증 프로세스에서 인증자를 검증하는 정책(예를 들어, 패스워드가 얼마 동안 정당한지, 어떤 검사가 공개 키 인증서 검증에서 수행되는지)에 따라 다르다.
기능 예시	인증자에 대한 관리 기능을 제공하며, 인증자가 패스워드인 경우의 예시는 다음을 참고할 수 있음 - 패스워드를 사용자가 잊어버리거나 다른 이유로 사용이 불가능한 경우 관리자 권한 혹은 별도의 사용자 확인 등을 통해 패스워드를 초기화 하는 기능을 제공 - 시스템 사용시 할당된 초기 패스워드를 변경 후 사용하도록 강제화 하는 기능을 제공 - 주기적인 패스워드 변경 기능을 제공 - 패스워드를 서버내 DB(Data Base)에 저장 시 패스워드 대신 패스워드의 해시 값으로 저장하여 외부 유출시에도 실제 사용자의 패스워드를 알 수 없도록 하는 기능을 제공

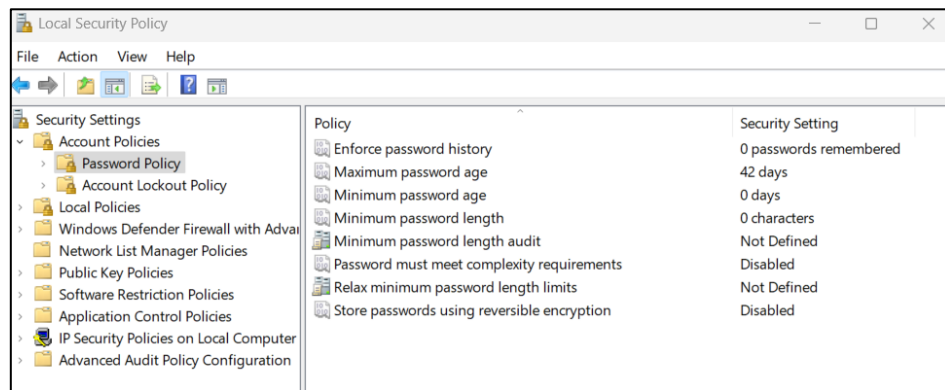
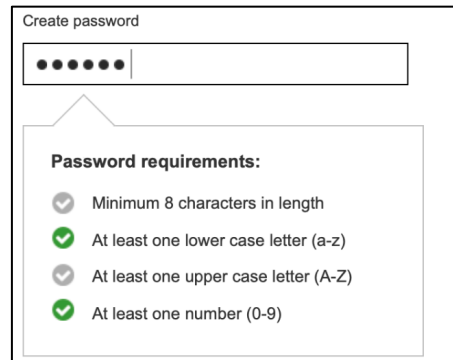
항목/목적	5. 무선 접근 관리	참조 표준	IEC62443-3-3/SR1.6
요구사항	CBS 는 무선통신에 관계되는 모든 사용자(인간, 소프트웨어 프로세스 또는 장치)를 식별하고 인증할 수 있는 기능을 제공해야 한다.		
적용대상	CBS 가 무선으로 네트워크 통신을 사용하는 경우에만 적용한다.		
적용 설명	무선 통신은 대부분의 경우에 또 다른 통신 프로토콜 선택사항으로 고려될 수 있다. 그러므로 무선 통신은 컴퓨터기반 시스템에서 활용되는 다른 통신 유형과 동일한 컴퓨터기반 시스템 보안 요구사항을 따라야 한다. 그러나 보안 관점에서, 유선 통신과 무선 통신 간에는 최소한 하나의 큰 차이가 존재한다: 물리적 보안 대책은 무선 통신 사용 시에 일반적으로 덜 효과적이다. 이런 것과 다른 이유(e.g. 규제 차이)로, 위험 분석은 동일한 사용 사례에서 사용되는 유선 프로토콜에 대비하여 무선 통신에서 더 높은 보안 수준이 요구될 수도 있다. 무선 기술은, 국한되지는 않지만, 마이크로웨이브, 인공위성, 패킷 라디오, IEEE 802.11x, IEEE 802.15.4 (Zigbee), IEC 62591 – Wireless HART®, ISA-100.11a, IEEE 802.15.1(Bluetooth), 무선 LAN 모바일 라우터, 테더링을 가진 모바일 폰 및 다양한 적외선 기술을 포함한다.		
기능 예시	무선 네트워크 장치가 시스템에 포함되는 경우, 무선을 사용하는 모든 사용자에 대한 식별 및 인증 기능을 제공		



[그림 28] 무선 네트워크 사용자에게 대한 설정 화면 예시

항목/목적	6. 패스워드 기반 인증 강도	참조 표준	IEC62443-3-3/SR1.7
요구사항	CBS 는 최소 길이와 다양한 문자 유형에 기반하여 설정 가능한 패스워드 강도를 시행하는 있는 기능을 제공해야 한다.		
적용대상	CBS 가 패스워드를 통해 인증자를 관리하는 경우에 적용한다. (즉, “4. 인증자 관리” 요구사항에서 패스워드를 인증자로 사용하는 경우)		
적용 설명	사용자 이름 및 패스워드를 기반한 사용자 인증은 아주 일반적으로 사용되는 메커니즘이다. 이러한 메커니즘의 대부분 공격은 패스워드 추정(e.g. 사전 공격 또는 표적화된 사회 공학)이나 저장된 패스워드 표기의 암호적 보호 깨기(e.g. 레인보우 테이블 또는 해시 충돌 무차별 대입 공격)에 집중한다. 공격이 더 어렵도록 허용 문자 수를 늘려 적당한 패스워드 크기를 증가시킬 뿐만 아니라, 오직 증가된 세트 크기만이 실제로 사용되게 한다(일반적으로 사용자는 기억하기가 힘들기 때문에 패스워드에 특수 문자를 포함하지 않으려는 경향이 있음). 패스워드 수명주기를 제한하면 공격자가 해당 패스워드 보안성을 파괴하는 기회 기간이 감소한다. 사용자가 새로운 패스워드로 변경한 다음에 즉시 원래 패스워드로 변경하여 이러한 통제를 피해 가는 것을 방지하기 위해, 일반적으로 패스워드의 최소 수명주기도 마찬가지로 강제되어야 한다. 폐기 전에 패스워드 변경 통지를 통하여, 사용자가 프로세스 운용 상태에 따라 편한 시간에 패스워드를 변경할 수 있게 한다. 이러한 보호는 패스워드의 재사용을 제한함으로써 더욱 강화될 수 있다(소규모의 대체 패스워드를 방지함). 이는 한 번 해독된 패스워드의 유용성을 더욱 떨어뜨린다. 암호 기반 메커니즘을 넘어 확장된 보호는 멀티 팩터 인증을 사용하여 달성할 수 있다.		
기능 예시	사용자의 패스워드 설정시 복잡성(Complexity)을 강제하는 기능을 제공 복잡성의 예시는 다음과 같음 패스워드는 최소한 6 자 이상의 길이를 사용하는 것으로 강제하며 다음 네 가지 범주 중 세 가지의 문자를 포함하도록 강제함		

- 영문 대문자(A - Z)
- 영문 소문자(a - z)
- 기본 10 개 숫자(0 - 9)
- 알파벳 이외의 문자(예: !, \$, #, %)



[그림 29] 패스워드 복잡성 화면 예시

항목/목적	7. 인증자 피드백	참조 표준	IEC62443-3-3/SR1.10
요구사항	CBS 는 인증 과정 중에 피드백을 잘 보이지 않게 해야 한다.		
적용대상	원칙적으로 모든 CBS 에 적용해야 한다. (단, 적용이 불가능한 경우, 보상조치 방법에 대한 설명이 요구될 수 있다.)		
적용 설명	피드백을 불명확하게 하는 것은 인가되지 않은 개인의 악용 가능성으로부터 정보를 보호한다. 예를 들어, 인간 사용자가 사용자 이름 또는 패스워드를 입력할 때 별표(*)나 임의의 문자 표시로 인증 정보 피드백을 불명확하게 한다. 다른 예로는, WEP(Wired Equivalent Privacy) 키의 입력, SSH(Secure Socket Shell) 토큰과 RSA(Rivest, Shamir, Adleman) OTP(One Time Passwords) 입력이 있다. 인증 개체는 “알 수 없는 사용자 이름(unknown user name)”과 같이 인증 실패의 근거를 말하는 힌트를 제공하지 않는다.		

기능 예시	패스워드를 사용하는 경우 입력이 **** 등으로 가려져 입력 값이 보이지 않으며, ID/PW 를 틀리게 입력한 경우 어느 쪽이 틀렸는지를 알려주지 않음 [그림 30] 인증자 피드백 예시
-------	--

2. 사용 통제 및 감사 기록

(1) 보안 기능 설명

사용 통제(Use control)는 인증된 사용자의 권한 할당을 강제하고 권한의 사용을 모니터링 하기위한 보안 기능 요구 사항을 다루고 있다. 권한은 직무(duty)에 필요한 최소한으로 할당되어야 하며, 적용 범위는 가능한 부분에서 모두 적용이 되어야 한다. 우선 인간 사용자가 접근 가능한 모든 인터페이스에서 권한을 할당해야 한다. 무선 네트워크를 사용하는 경우 무선 연결에 대한 허가, 감시 및 사용 제한 기능이 제공되어야 한다. 휴대용 및 모바일 장치(e.g. 노트북, USB 등)가 사용 가능하거나 제공되는 경우 사용에 대한 통제 기능이 제공되어야 한다. 모바일 코드는 수신자가 명시적으로 설치하지 않아도 실행되는 자산들 사이에 전송되는 프로그램을 의미하며 예시로는 JavaScript, ActiveX 컨트롤, 크롬의 확장 프로그램 등이 있다. 모바일 코드를 사용하는 경우, 이에 대한 통제 역시 필요하다.

세션은 둘 이상의 통신 구성품 사이의 반영구적이고, 네트워크 연결 상태를 추적할 수 있는 상태를 유지하며, 상호작용하는 정보 교환을 의미한다. 시스템에 로그인한 경우 페이지 이동시마다 로그인을 하지 않고도 사용할 수 있는 이유는 사용자 측과 데이터를 송수신하는 서버 상호간에 세션이 수립되어 있기 때문이다. 문제는 세션이 탈취되는 경우로 이를 악용해 로그인 과정 없이(사용자가 아님에도 불구하고) 로그인 상태가 될 수 있으므로 세션 탈취로부터 시스템을 보호하기 위한 기능이 제공되어야 한다. 이를 위해 시스템에서는 사전에 설정된 시간 동안의 미사용시 자동 로그아웃 혹은 사용자의 수동 로그아웃과 같은 세션을 비활성화 시킬 수 있는 기능을 제공해야 하며 원격 접속을 지원하는 경우 원격 접속에서도 이러한 기능을 제공해야 한다.

시스템은 또한 보안 관련 감사 기록을 생성하고 감사 처리의 실패에 대응하기 위한 기능을 제공해야 한다. 보안 관련 감사 기록에 최소한으로 포함되어야 항목은 다음과 같다.

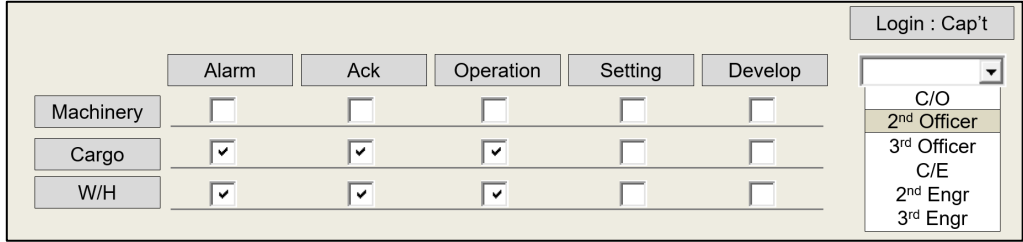
- 접근 통제(Access control)
- 운영 체제 사건(Operating system events)
- 백업 및 복구 사건(Backup and restore events)
- 설정 변경(Configuration changes)
- 통신 상실(Loss of communication)

접근 통제 감사 기록의 예시로는 사용자의 로그인/로그아웃 및 로그인 실패 등이 있다. 운영 체제 사건의 감사 기록은 재부팅, 셧다운 등에 대한 기록이 예시가 될 수 있으며 통신 상실 감사 기록의 예시로는 시스템의 내외부간 통신연결 상태에 대한 모니터링 기능을 제공하고 통신이 실패한 경우 이를 기록으로 남기는 기능 등이 있다. 감사 기록은 사용자가 사건(Event)이 발생한 시간을 알 수 있도록 사건 별로 감사 사건의 발생 시간(타임스탬프)을 기록하는 기능이 제공되어야 한다.

감사 처리 실패로 인해 시스템의 중요 서비스 및 기능의 손실을 초래해서는 안 되며 이를 방지하기 위한 기능이 제공되어야 한다. 예를 들어 시스템에서 사용하는 감사 기록의 저장 공간이 시스템의 중요 서비스를 제공하기 위해 사용하는 저장 공간과 공유되어 운영되는 경우, 시간이 지남에 따라 감사 기록이 누적되어 중요 서비스가 사용할 저장 공간이 부족한 문제를 발생시킬 수 있다. 이러한 현상을 방지하기 위해 시스템에서는 감사 기록이 사용할 수 있는 저장 용량을 할당하고 할당 범위를 초과할 수 없도록 일정 수준 이상의 저장 용량을 차지하게 되는 경우 오래된 기록부터 삭제하거나 혹은 새로운 기록을 저장하지 못하게 하고 사용자에게 이에 대한 알람을 제공해 주는 등의 기능을 제공해야 한다. 또한 감사 기록은 사용자의 임의 수정/삭제 등을 막기 위해 읽기 전용으로만 접근이 가능하도록 해야 한다.

(2) 보안 기능 요구사항 설명 및 예시

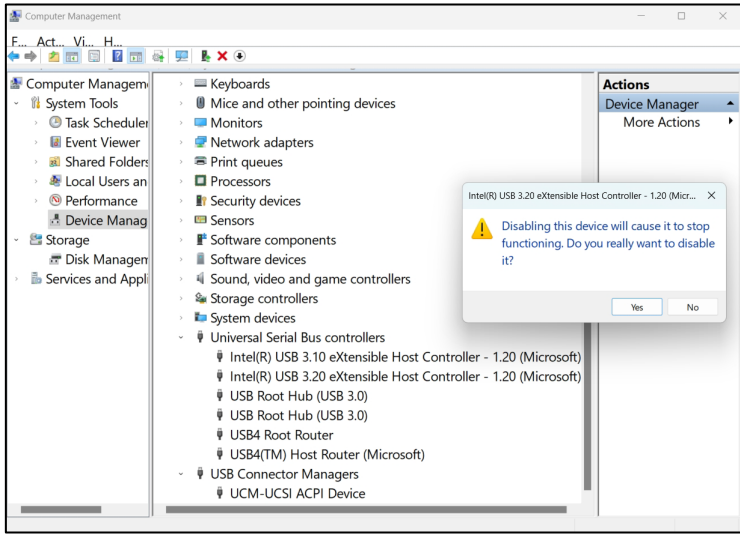
항목/목적	8. 권한부여 시행	참조 표준	IEC62443-3-3/SR2.1
요구사항	모든 인터페이스에서 인간 사용자는 직무 분리와 최소 특권의 원칙에 따라서 권한이 할당되어야 한다.		
적용대상	원칙적으로 모든 CBS 에 적용해야 한다. (단, 적용이 불가능한 경우, 보상조치 방법을 설명이 요구될 수 있다.)		
적용 설명	사용 통제 정책(e.g. 신원 기반 정책, 역할 기반 정책 및 규칙 기반 정책)과 연관된 읽기/쓰기 접근 부여 메커니즘(e.g. 접근 통제 목록, 접근 통제 매트릭스 및 암호 방식)은 사용자(사람, 소프트웨어 프로세스나 기기)와 자산(e.g. 기기, 파일, 레코드, 소프트웨어 프로세스, 프로그램 및 영역) 간의 사용을 통제하기 위해 채택한다. 컴퓨터기반 시스템이 사용자(사람, 소프트웨어 프로세스나 기기)의 신원을 검증한 후, 요청된 작업이 정의된 보안 정책 및 절차에 따라 실제로 허용되는지도 검증해야 한다. 예를 들어, 역할 기반 접근 통제 정책인 경우에서 컴퓨터기반 시스템은 검증된 사용자 또는 자산에 배정된 역할과 이러한 역할에 배정된 권한을 점검한다. 만일 요청된 작업이 허가 범위 안에 있는 경우 실행되고 그렇지 않다면 거부 된다. 이것은 직무 분리 및 최소 권한의 시행을 허용한다. 권한 부여 메커니즘의 사용은 컴퓨터기반 시스템의 운영 성능에 부정적인 영향을 끼치지 않아야 한다.		

	컴퓨터기반 시스템 컴포넌트에 대하여 계획된 또는 계획되지 않은 변경은 컴퓨터기반 시스템의 전반적인 보안에 중대한 영향을 끼칠 수 있다. 따라서 자격이 있고 인가된 개인만이 업그레이드 및 수정을 포함하여 변경을 시작하기 위한 목적으로 컴퓨터기반 시스템의 컴포넌트 사용 권한을 가져야 한다.
기능 예시	직무별로 시스템의 사용 권한을 분리하고 각 직무에 맞는 최소한의 권한만을 할당할 수 있는 기능을 제공  [그림 31] 권한 부여 설정 화면 예시

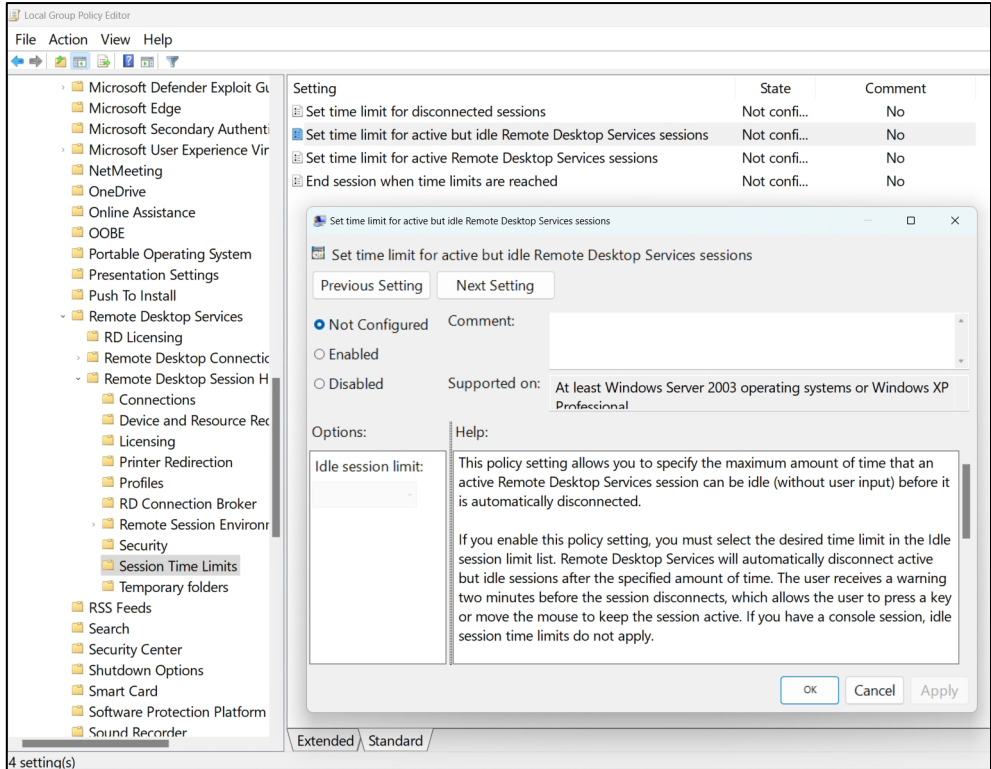
항목/목적	9. 무선 사용 통제	참조 표준	IEC62443-3-3/SR2.2
요구사항	CBS 는 일반적으로 허용되는 보안 산업 관행에 따라 시스템에 대한 무선 연결에 대해 허가, 감시 및 사용 제한을 시행하는 기능을 제공해야 한다.		
적용대상	CBS 가 무선으로 네트워크 통신을 사용하는 경우에만 적용한다.		
적용 설명	무선 통신은 대부분의 경우에 또 다른 통신 프로토콜 선택사항으로 고려될 수 있다. 그러므로 무선 통신은 컴퓨터기반 시스템에서 활용되는 다른 통신 유형과 동일한 컴퓨터기반 시스템 보안 요구사항을 따라야 한다. 그러나 위험 분석은 동일한 사용 사례에서 사용되는 유선 프로토콜에 대비하여 무선 통신에서 더 높은 보안 수준을 요구할 수도 있다. 또한 규제 차이는 유선과 무선 통신 간에 다른 필수 역량을 유발할 수도 있다.		

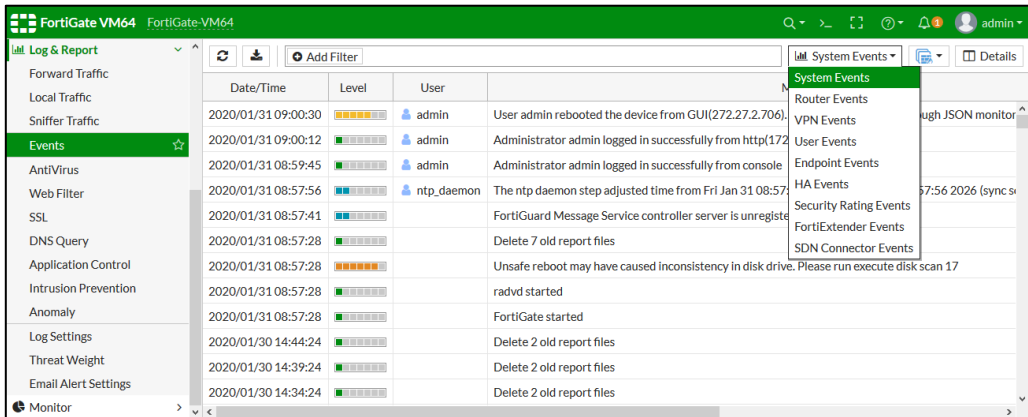
기능 예시	무선 네트워크 장치가 시스템에 포함되는 경우, 허가된 사용자만 무선 사용이 가능하도록 하며 사용자의 무선 네트워크 접속 현황을 모니터링하고 필요에 따라 사용을 제한할 수 있는 기능을 제공  [그림 32] 무선 연결에 대한 감시 화면 예시
-------	---

항목/목적	10. 휴대용 및 모바일 장치의 사용 통제	참조 표준	IEC62443-3-3/SR2.3
요구사항	CBS가 휴대용 및 모바일 장치 사용을 지원하는 경우 시스템은 다음의 기능을 포함해야 한다. a) 휴대용 및 모바일 장치 사용은 설계상 허용된 대상으로만 제한 b) 휴대용 및 모바일 장치로의/로부터 코드 및 데이터 전송을 제한 (비고) 포트 제한/블록커 (및 실리콘)은 특정 시스템에 대하여 허용될 수 있다.		
적용대상	원칙적으로 모든 CBS에 적용해야 한다. (단, 휴대용 및 모바일 장치의 사용이 없는 경우, 이 요구사항은 적용되지 않음)		
적용 설명	휴대용 및 모바일 기기는 원하지 않는 네트워크 트래픽, 멀웨어 및/또는 정보 공개를 유발할 수도 있기 때문에, 일반적인 컴퓨터 기반 시스템 환경에서 사용과 관련하여 특정 통제가 존재해야 한다. 보안 정책과 절차가 휴대용 및 모바일 기기를 통한 특정 기능이나 활동을 허용하지 않을 수도 있다. 휴대용 및 모바일 기기에 내재하는 정보 보호(예를 들어, 통제된 영역을 벗어났을 때 전송 중이거나 저장되는 동안에 기밀성 및 무결성 보호를 제공하기 위한 암호학적 메커니즘을 적용)는 기밀성 요구 사항에 명시되어 있다.		

기능 예시	노트북, USB 와 같은 휴대용 및 모바일 장치의 사용을 지원하는 경우 허가된 장치만 사용이 가능한 기능을 제공. 불가능한 경우 이를 대신하여 물리적인 포트 제한/블록커 등을 제공    [그림 33] 휴대용 및 모바일 장치 사용 통제 예시
-------	--

항목/목적	11. 모바일 코드	참조 표준	IEC62443-3-3/SR2.4
요구사항	CBS 는 자바스크립트, ActiveX 및 PDF 와 같은 모바일 코드의 사용을 통제해야 한다.		
적용대상	원칙적으로 모든 CBS 에 적용해야 한다. (단, CBS 가 운영체제(OS)가 없거나 웹 브라우저의 접근이 불가능한 경우, 이 요구사항은 적용되지 않을 수 있으며 보상조치 방법에 대한 설명이 요구될 수 있다.)		
적용 설명	모바일 코드 기술은 한정되지는 않지만 Java, JavaScript, ActiveX, PDF, PostScript, Shockwave 동영상, Flash 애니메이션 및 VBScript 를 포함한다. 사용 제한은 서버에 설치된 모바일 코드의 사용과 선택 및 개별 워크스테이션에 다운로드되고 실행되는 모바일 코드 둘 다에 적용된다. 통제 절차는 컴퓨터기반 시스템 내에 승인되지 않은 모바일 코드의 개발, 획득 또는 도입을 방지해야 한다. 예를 들어, 모바일 코드 교환은 컴퓨터기반 시스템 내에 직접적으로 허용되지 않지만, 컴퓨터 기반 시스템 직원이 유지하는 통제된 인접 환경에서 허용할 수도 있다.		
기능 예시	모바일 코드를 사용하는 경우, 사용 통제에 대한 기능을 제공		

항목/목적	12. 세션 잠금	참조 표준	IEC62443-3-3/SR2.5
요구사항	CBS 는 설정이 가능한 비활성 시간 이후 또는 수동 세션 잠금의 활성화에 따라 추가 접근을 방지할 수 있어야 한다.		
적용대상	원칙적으로 모든 CBS 에 적용해야 한다. (단, 비상상황에서 즉시 운영자 대응이 필요한 CBS 의 경우, 이 요구사항은 적용되지 않을 수 있다.)		
적용 설명	컴퓨터기반 시스템을 책임지는 기업은 지정된 워크스테이션이나 노드에 대한 접근을 방지하기 위해 세션 잠금을 채택해야 한다. 컴퓨터기반 시스템은 지정된 워크스테이션이나 노드의 설정 가능한 시간 이후에 자동적으로 세션 잠금 매커니즘을 활성화해야 한다. 어떤 경우에, 컴퓨터기반 시스템 운영자 워크스테이션이나 노드의 세션 잠금은 권고되지 않는다(예를 들어, 비상 상황에서 즉시 운영자 대응이 필요한 세션). 컴퓨터기반 시스템이 세션 잠금을 지원할 수 없는 경우에는, 책임 있는 개체가 적절한 보안 대책을 적용해야 한다(e.g. 증대된 물리적 보안, 직원 보안 및 감사 수단).		
기능 예시	사전에 설정된 시간 동안의 시스템 미사용 혹은 사용자의 수동적인 작업을 통해 시스템의 세션 잠금 기능을 제공  [그림 34] 세션 잠금 기능 설정 예시		

항목/목적	13. 감사가능 사건	참조 표준	IEC62443-3-3/SR2.8
요구사항	CBS 는 최소한 다음의 사건에 대한 보안 관련 감사 기록을 생성해야 한다. 접근 통제, 운영 체제 사건, 백업 및 복구 사건, 설정 변경, 통신 상실		
적용대상	원칙적으로 모든 CBS 에 적용해야 한다. (단, 적용이 불가능한 경우, 보상조치 방법에 대한 설명이 요구될 수 있다.)		
적용 설명	이 요구사항의 목적은 컴퓨터기반 시스템 보안과 연관되고 중요하여 감사될 필요가 있는 중요한 이벤트의 발생을 기록하는 것이다. 감사 활동은 컴퓨터기반 시스템 성능에 영향을 미칠 수 있다. 보안 감사 기능은 다른 구역에 있을 수도 있는 네트워크 상태 모니터링 기능과 대개 공동으로 작업한다. 일반적으로 인지되고 인정된 점검표와 구성 지침이 감사 이벤트 목록을 편집할 때 고려되어야 한다. 보안 정책과 절차가 보안 사고의 사후 조사를 지원하기에 적합한 감사 이벤트를 정의해야 한다. 추가하여, 감사 기록은 요구사항에 맞게 활용되는 보안 메커니즘의 효율성과 적절한 운용을 모니터링하기에 충분해야 한다. 이벤트는 모든 컴퓨터기반 시스템 컴포넌트(e.g. 로그인 이벤트)에서 발생할 수도 있고, 전용 모니터로 관측될 수도 있다. 예를 들어, 포트 스캐닝은 IDS(Intrusion Detection System)나 IPS(Intrusion Prevention System)로 탐지될 수 있다.		
기능 예시	시스템에서 보안 관련 감사 기록을 생성하는 기능을 제공하며, 기록에는 최소한 다음의 항목이 포함되도록 함 - 접근 통제(e.g. 로그인의 성공/실패, 로그 아웃 등) - 운영 체제 사건(e.g. 재부팅, 셧다운 등) - 백업 및 복구 사건 - 설정 변경(e.g. 권한 변경, alarm 값 설정 변경 등 제조사에서 정의한 시스템의 설정 변경 등) - 통신 상실(e.g. 내외부의 통신 연결이 실패한 경우의 기록 등)  [그림 35] 보안 감사 기록 예시		

항목/목적	14. 감사 저장 용량	참조 표준	IEC62443-3-3/SR2.9
요구사항	CBS는 일반적으로 인정되는 로그 관리 권고사항에 따라 감사 기록 저장 용량을 할당하는 기능을 제공해야 한다. 감사 메커니즘이 이러한 용량을 초과할 가능성을 줄이기 위해 구현해야 한다.		
적용대상	원칙적으로 모든 CBS 에 적용해야 한다.		

	(단, 적용이 불가능한 경우, 보상조치 방법에 대한 설명이 요구될 수 있다.)
적용 설명	컴퓨터 기반 시스템은 충분한 감사 저장 용량을 제공하고, 보존 정책, 수행된 감사, 그리고 온라인 감사 처리 요구사항을 고려해야 한다. 감사 저장 용량은 적용 가능한 정책과 규제 또는 비즈니스 요구사항에 필요한 기간 동안에 로그를 보존하기에 충분해야 한다.
기능 예시	보안 관련 감사 기록이 저장되는 공간을 할당하는 기능을 제공. 할당 공간의 사용량 등을 모니터링하여 사전에 설정된(e.g. 80%, 90% 등) 수준을 초과하는 경우 알람을 발생하여 사용자가 알 수 있도록 하고 오래된 기록부터 삭제하거나 새로운 기록이 저장되지 않도록 하는 기능 등을 제공

항목/목적	15. 감사 처리 실패 대응	참조 표준	IEC62443-3-3/SR2.10
요구사항	CBS 는 감사 처리 실패 시 중요 서비스 및 기능의 손실을 방지하는 기능을 제공해야 한다.		
적용대상	원칙적으로 모든 CBS 에 적용해야 한다. (단, 적용이 불가능한 경우, 보상조치 방법에 대한 설명이 요구될 수 있다.)		
적용 설명	감사 생성은 일반적으로 이벤트 소스에서 발생한다. 감사 처리는 감사 레코드의 전송, 추가 사항(타임스탬프 추가와 같은) 및 지속적 저장소를 포함한다. 예를 들어, 감사 처리 실패는 소프트웨어/하드웨어 오류, 감사 추출 메커니즘의 실패 및 감사 저장 용량 초과와 같은 것이다. 감사 저장 용량 초과 시에 오래된 감사 레코드를 덮어쓰거나 감사 로그 생성을 중단하는 것은 가능한 방안이지만, 필수적인 포렌식 정보의 손실을 감수해야 한다. 또한 직원에게 경고하는 것은 감사 처리 실패 대응에 적절한 지원 활동이 될 수 있다.		
기능 예시	보안 관련 감사 기록이 저장되는 공간을 할당하는 기능을 제공. 할당 공간의 사용량 등을 모니터링하여 사전에 설정된(e.g. 80%, 90% 등) 수준을 초과하는 경우 알람을 발생하여 사용자가 알 수 있도록 하고 오래된 기록부터 삭제하거나 새로운 기록이 저장되지 않도록 하는 기능 등을 제공		

항목/목적	16. 타임스탬프	참조 표준	IEC62443-3-3/SR2.11
요구사항	CBS 는 감사 기록에 타임스탬프를 포함해야 한다.		
적용대상	원칙적으로 모든 CBS 에 적용해야 한다. (단, 적용이 불가능한 경우, 보상조치 방법에 대한 설명이 요구될 수 있다.)		
적용 설명	감사 기록의 타임스탬프는 내부 시스템 시계를 사용하여 생성되어야 한다. 만일 시스템 전체 시간 동기화가 제공되지 않는다면(일반적으로 대부분 설치 시), 알려진 오프셋이 이벤트 순서 분석을 지원하기 위해 필요하다. 게다가 외부 이벤트와 내부 생성 감사 기록의 동기화는 일반적으로 인정된 외부 시간 소스[GPS(Global Positioning System, GLONASS(Global Navigation Satellite System) 및 Galileo]와 동기화가 필요할 수도 있다. 시간 소스는 인가 받지 않은 변경으로부터 보호되어야 한다.		
기능 예시	보안 관련 감사 기록에 사건(Event) 별로 사건이 발생한 시간(타임스탬프)을 포함		

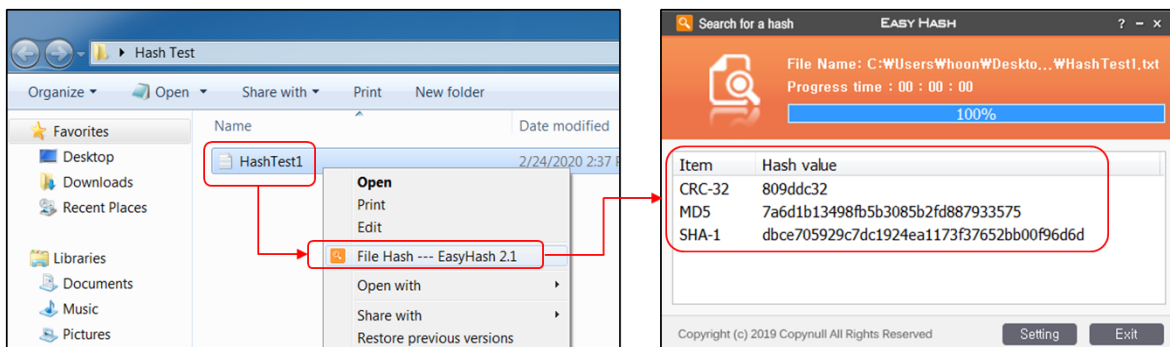
항목/목적	23. 감사 로그 접근성	참조 표준	IEC62443-3-3/SR6.1
요구사항	CBS 는 허가된 사용자 및/또는 도구에 의해 읽기 전용 기반으로 감사 로그에 접근하는 능력을 제공해야 한다.		
적용대상	원칙적으로 모든 CBS 에 적용해야 한다. (단, 적용이 불가능한 경우, 보상조치 방법에 대한 설명이 요구될 수 있다.)		
적용 설명	컴퓨터기반 시스템은 해당 컴퓨터기반 시스템에서 발생한 이벤트에 대한 감사 레코드를 생성할 수 있어야 한다. 이런 감사 로그에 대한 접근은 보안 사고의 사후 조사 중 감사 로그 필터링, 중복 정보 식별 및 제거, 검토 및 보고 활동을 지원하기 위해 필요하다. 일반적으로 감사 축약 및 보고서 생성은 별개의 정보 시스템에서 수행된다. 감사 레코드에 대한 수동적 접근(화면 보기나 인쇄)으로 요구사항이 충족될 수 있다. 프로그램적 접근은 보안 정보 및 이벤트 관리(SIEM, Security Information and Event Management)와 같은 분석 메커니즘에 감사 로그 정보를 제공하기 위해 일반적으로 사용한다.		
기능 예시	보안 관련 감사 기록에 사용자가 읽기 전용으로만 접근 가능(수정/삭제 불가)		

3. 기밀성 및 무결성 보호

(1) 보안 기능 설명

보안을 지키기 위한 목표와 관련하여 보안의 3 요소인 기밀성(Confidentiality), 무결성(Integrity) 그리고 가용성(Availability)이 있다.

기밀성은 정보 접근 및 공개를 제한하는 속성을 의미한다. 특정 파일에 암호를 걸어 암호화하고 암호를 알고 있는 사람만이 이를 복호화 하여 정보에 접근이 가능하게 하는 기능이 기밀성을 지키기 위한 기능의 예시가 될 수 있다.



[그림 36] 상용 도구를 활용한 해시 값 확인 예시

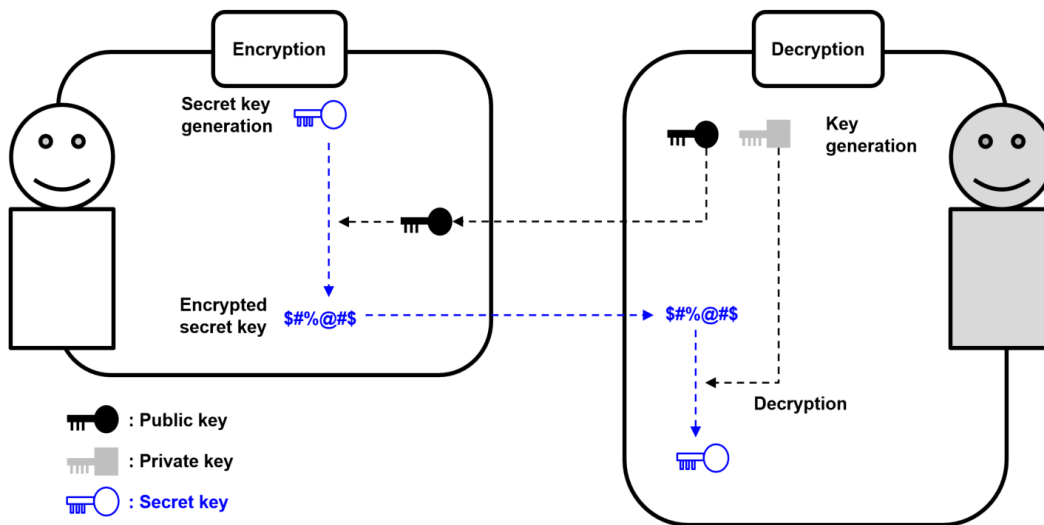
무결성은 자산의 정확성과 완전성을 보호하는 속성을 의미한다. 예를 들어 시스템의 실행 파일에 악성코드가 심어진 상태이거나 저장 디스크의 물리적인 문제로 파일이 훼손된 경우, 실행 파일은 원본과 다른 상태이며 무결성이 훼손된 상태이다. 무결성을 보호하기 위한 기능을 구현하기 위해 우선 암호화에 대한 이해가 필요하다.

해시는 단방향 암호화 기법의 하나로 해시 함수(Hash function)는 임의 길이의 비트 문자열(e.g. 파일, 데이터 등)을 고정 길이의 비트 문자열에 매핑하는 함수이다. 해시 값은 해시 함수를 통해 입력에 매핑 된 출력 값을 의미하며, 해시 값을 구하기 위해 다양한 암호화 알고리즘이 사용될 수

있다. [그림 36]은 상용 도구를 이용하여 샘플 파일(텍스트 파일)의 해시 값을 구한 예시이다. CRC-32, MD5, SHA-1 은 해시 값을 구하는데 사용되는 해시 알고리즘의 종류이다.

해시 함수의 주요한 특성은 다음과 같다.

- 1) 항상 고정된 길이의 해시 값을 출력한다¹²
- 2) 동일한 입력 값은 항상 동일한 해시 값을 출력한다
- 3) 출력된 해시 값으로 입력 값을 유추할 수 없다 (단방향)



[그림 37] 비대칭키 암호화를 이용한 대칭키 공유 방식 예시

동일한 입력 값에는 동일한 해시 값을 출력하는 특성을 이용하여 데이터의 무결성을 확인할 수 있다. 예를 들어 업데이트 파일을 전송 받아 설치하는 경우, 전달 받은 업데이트 파일이 원본 그대로의 상태 즉, 파일이 손상되지 않았음을 확인하기 위해 송신처에서는 업데이트 파일을 보낼 때 해시 값을 같이 보낸다. 수신처에서는 전달 받은 업데이트 파일을 송신자가 사용했던 암호화 알고리즘을 이용하여 해시 값을 구한 뒤 전달 받은 해시 값과 비교하여 동일한 경우 업데이트 파일의 손상이 없음 즉, 무결성이 훼손되지 않았음을 확인할 수 있다.

기밀성 보호에도 암호화 기법이 사용되며 이에 대한 예시로 양방향 암호화 방식인 대칭키(Symmetric key) 및 비대칭키(Asymmetric key) 방식의 암호화가 있다. 암호화만 가능하고 복호화가 불가능한 단방향 암호화 방식과 달리 양방향 암호화는 암호화된 데이터를 복호화 할 수 있다. 암호화와 복호화에는 키가 사용되며 동일한 키를 사용하는 경우는 대칭키 방식, 서로 다른 키를 사용하는 경우 비대칭키 방식이라고 한다. 대칭키 방식 암호화에 사용되는 키를 비밀키(Secret key)라고 하며 비대칭키 방식은 두개의 키를 사용하며 공개키(Public key)와 개인키(Private key)가 있다. 대칭키 방식의 암호화는 비대칭키 방식에 비해 동일한 수준의 보안 강도(Security strength)를 위해 좀더 낮은 수준의 키 길이를 가질 수 있으며 연산 속도 또한 빨라 실제 통신 데이터의

¹² 암호화 알고리즘 별로 해시 값의 길이는 다를 수 있으나, 동일한 암호화 알고리즘을 사용하는 경우 항상 동일한 길이의 해시 값을 출력함

암호화에는 대칭키 방식이 사용된다. 다만, 이 경우 통신을 하는 상호간에 암호화와 복호화에 사용되는 키(비밀키, Secret key)를 보유하고 있어야 한다. 사용자가 처음으로 서비스를 제공 받기 위해 서버에 접속하는 경우, 한쪽에서 생성한 비밀키를 상대방에게 안전하게 공유해주기 위한 방법이 필요하게 되며 이 경우 비대칭키 방식의 암호화 알고리즘을 이용하여 대칭키를 공유한다.

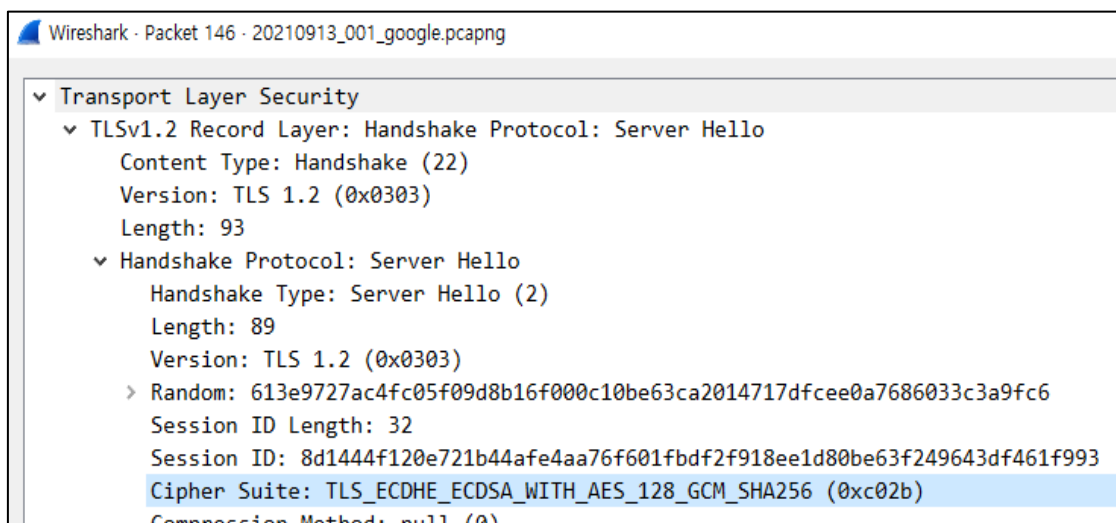
비대칭키(공개키+개인키) 암호화는 암호화와 복호화에 사용되는 키가 서로 다르며 암호화에 사용되는 키로 복호화를 할 수 없고 반대로 복호화에 사용되는 키로 암호화를 할 수 없다. [그림 37]는 비대칭키 암호화를 이용한 대칭키(비밀키) 공유 방식을 설명하는 그림이다. 비밀키를 공유 받고자 하는 쪽에서는 공개키와 개인키 한 쌍을

Security Strength		Through 2030	2031 and Beyond
< 112	Applying protection	Disallowed	
	Processing	Legacy-use*	
112	Applying protection	Acceptable	Disallowed
	Processing		Legacy use
128	Applying protection and processing information that is already protected	Acceptable	Acceptable
192		Acceptable	Acceptable
256		Acceptable	Acceptable

[그림 38] NIST SP 800-57, 보안 강도 권고 예시

생성하고 공개키를 상대방에게 전달한다. 비밀키를 공유하고자 하는 쪽에서는 비밀키를 생성하고, 전달 받은 공개키로 암호화 한 뒤 상대방에게 전달한다. 전달 받은 암호화 된 비밀키를 가지고 있던 개인키로 복호화 하게 되면 대칭키(비밀키)의 안전한 공유는 완료된다. 이 과정에서 전달되는 (외부에 노출되는) 데이터는 공개키와 암호화된 비밀키이다. 암호화된 비밀키를 복호화 하기 위해서는 개인키가 필요하며, 비대칭키 방식 암호화의 특성상 공개키로는 복호화를 할 수 없다. 다만 안전한 공유는 개인키가 외부에 유출되지 않음을 전제로 하며 이와 관련하여 보안 개발 수명주기(SDLC) 문서에서는 코드 서명에 사용되는 개인 키를 보호하기 위한 절차 및 기술적 통제를 마련할 것을 요구하고 있다.

실제 비대칭키와 대칭키 암호화를 복합적으로 사용하는 대표적인 보안 통신의 예시로는 TLS 프로토콜이 있다. TLS(Transport Layer Security) 프로토콜은 정보를 암호화해서 송수신하는 보안 통신 프로토콜이다. [그림 39]은 통신 데이터 패킷 중 일부를 캡처한 것으로 TLS 프로토콜이 사용되고 있음을 알 수 있다. Cipher suite 는 TLS 통신에서 사용되는 암호화 알고리즘의 집합을



[그림 39] TLS 통신 패킷 확인 예시

의미한다. ECDHE 는 비밀키 교환에 사용되는 비대칭키 방식의 암호화 알고리즘을 의미하며, AES 128 은 실제 통신 데이터의 암호화를 위한 대칭키 암호화 알고리즘을 의미한다. SHA 256 은 무결성 확인을 위한 해시 함수의 암호화 알고리즘을 의미한다.

보안의 관점에서 새로운 위협들은 끊임없이 발견되고 있고 해킹의 기술은 지속적으로 발전하고 있으며 이에 따른 보안 기술 또한 지속적으로 발전하고 있다. 이에 따라 NIST¹³에서는 NIST SP 800-57 을 통해 보안 강도의 개념을 설명하고 시기별로 권고 되는 보안 강도를 안내하였다.

보안 강도(Security strength)는 bit 단위로 표현되며, n bit 보안 강도를 가지는 암호화 알고리즘은 해당 암호화 알고리즘의 취약성을 알아내기 위해 2^n 번의 연산이 필요함을 의미한다. NIST 권고안에 따른 권고되는 보안 강도는 2030 년까지는 112 bit 이상이며 이후는 128 bit 이상의 보안 강도가 권고 된다. 보안 강도는 개념적인 것이므로 실제 사용되는 암호화 알고리즘이 어느 정도의 보안 강도를 지니고 있는지를 알 수 있어야 한다. 이를 위해 NIST SP 800-57 에서는 또한 각 알고리즘의 키길이 별로 보안 강도를

매핑하고 이에 대한 정보를 제공한다. [그림 40]는 암호화 알고리즘 및 키길이에 따른 보안 강도에 대한 비교표이다. 예를 들어 키길이가 2048 bit 인 RSA 암호화 알고리즘은 128 bit 의 보안 강도를 가진다. [그림 38]에 따라 2030 년까지 권고되는 보안 강도는 112 bit 이므로 암호화 알고리즘 RSA 2048 을 사용하는 경우 사용이 권고되는 암호화 알고리즘으로 볼 수 있다.

Table 2: Comparable security strengths of symmetric block cipher and asymmetric-key algorithms

Security Strength	Symmetric Key Algorithms	FFC (DSA, DH, MQV)	IFC* (RSA)	ECC* (ECDSA, EdDSA, DH, MQV)
≤ 80	2TDEA	$L = 1024$ $N = 160$	$k = 1024$	$f = 160-223$
112	3TDEA ⁶⁸	$L = 2048$ $N = 224$	$k = 2048$	$f = 224-255$
128	AES-128	$L = 3072$ $N = 256$	$k = 3072$	$f = 256-383$
192	AES-192	$L = 7680$ $N = 384$	$k = 7680$	$f = 384-511$

[그림 40] NIST SP 800-57, 암호화 알고리즘 별 보안 강도 비교표

(2) 보안 기능 요구사항 설명 및 예시

항목/목적	17. 통신 무결성	참조 표준	IEC62443-3-3/SR3.1
요구사항	CBS 는 전송된 정보의 무결성을 보호해야 한다. (비고) 암호화 메커니즘이 무선 네트워크에 적용되어야 한다.		
적용대상	다른 CBS 와 네트워크로 연결된 모든 CBS 에 적용한다. (단, Serial link 와 같은 통신환경에는 적용하지 않음)		
적용 설명	일반 네트워크 공격의 대부분이 네트워크 패킷 조작과 같은 전송 중인 데이터의 조작을 기반으로 한다. 스위칭 또는 라우팅 네트워크는 공격자가 탐지되지 않고 패킷을 조작할 수 있는 아주 좋은 기회를 제공하며, 스위칭과 라우팅 메커니즘 자체가 전송된 정보에 대하여 더 많은 접근을 획득하기 위해 조작될 수도 있다. 컴퓨터기반 시스템 환경에서 조작은 센서에서 수신기로		

¹³ NIST(National Institute of Standards and Technology) : 미국 국립표준기술 연구소

	전송되는 측정값의 변경 또는 제어 애플리케이션에서 액추에이터(actuator)로 보내진 명령 파라미터의 변경과 같은 것이다. 전송에 사용되는 네트워크 유형(e.g. TCP/IP 대 로컬 시리얼 링크)과 환경(e.g. 로컬 네트워크 세그먼트 내 전송 대 신뢰되지 않은 네트워크를 통한 전송)에 따라, 실현 가능하고 적합한 메커니즘이 다르다. 직접 연결(point-to-point)된 소규모 네트워크상에서, 종단점의 무결성이 마찬가지로 보호되는 경우 모든 노드의 물리적 접근 보호는 낮은 보안 수준으로도 충분할 수 있다. 그러나 직원이 상주할 수 없는 구역의 분산된 네트워크 또는 광대역 네트워크인 경우, 물리적 접근 보호를 강제할 수 없다. 통신서비스를 제공하기 위해 완전한 전용서비스가 아닌 일반적인 상품으로 상용서비스를 사용하는 경우, 통신 무결성(예를 들어, 법적 제약 때문에)을 위해 필요한 보안 통제 구현과 관련하여 필요한 보증을 획득하기가 더 어려워질 수도 있다. 필수 보안 요구사항에 맞추기가 불가능하거나 비현실적인 경우, 적절한 보완 대책을 구현하거나 추가 위험을 명시적으로 수용하는 것이 적합할 수도 있다. 산업 장비는 종종 무결성 문제나 오탐(false-positive) 사고를 유발할 수 있는 환경적 조건의 대상이 된다. 환경은 종종 통신선과 신호의 무결성에 영향을 주는 조건을 유발할 수 있는 분진, 액체, 진동, 가스, 방사선 및 전자기파 간섭(EMI, Electromagnetic Interference)을 포함한다. 네트워크 인프라는 통신 무결성에 물리적/환경적 영향을 최소화하도록 설계되어야 한다. 예를 들어, 분진, 액체 및/또는 가스가 문제가 될 경우, 유선에 상용급 RJ-45 커넥터 대신에 밀봉된 RJ-45 나 M12 커넥터를 사용하는 것이 필요할 수 있다. 케이블 자체는 분진, 액체 및/또는 가스를 처리하기 위해 별도 피복을 사용할 수 있다. 진동이 문제가 되는 경우 RJ-45 커넥터 대신 M12 커넥터를 사용할 수 있다. 방사선 및/또는 EMI 가 문제가 되는 경우, 통신 신호의 영향을 방지하기 위해 차폐 연선 또는 광 케이블을 사용할 수 있다. 또한 무선 네트워크를 사용할 계획이 있는 경우 실행 가능한 솔루션인지 확인하기 위해 해당 구역의 무선 스펙트럼을 분석할 필요가 있다.
기능 예시	무결성을 보호하기 위한 통신 프로토콜을 사용

항목/목적	18. 악성코드 보호	참조 표준	IEC62443-3-3/SR3.2
요구사항	CBS 는 악성코드 또는 무단 소프트웨어로 인한 영향을 예방, 탐지 및 완화하기 위한 적절한 보호조치를 구현하는 기능을 제공해야 한다. 보호 메커니즘을 업데이트하는 기능이 있어야 한다.		
적용대상	일반적인 운영체제(OS)를 사용하는 CBS 에 적용한다. (예, Windows, Android 등)		
적용 설명	컴퓨터 기반 시스템은 전자 메일, 전자 메일 첨부, 인터넷 접속, 이동 매체[예: USB(Universal Serial Bus) 기기, 디스켓이나 콤팩트디스크], PDF 문서, 웹 서비스, 네트워크 연결과 감염된 랩톱이나 다른 일반 수단으로 전송되는 탐지된 악성 코드의 실체를 방지, 탐지, 완화 및 보고하는 보호 메커니즘을 사용해야 한다. 탐지 메커니즘은 애플리케이션 바이너리와 데이터 파일의 무결성 위반을 탐지할 수 있어야 한다. 기법은, 국한되지는 않지만, 바이너리 무결성 및 속성 모니터링, 해싱 및 서명 기법을 포함할 수 있다. 완화 기법은, 국한되지는 않지만, 파일 정제, 격리, 파일 삭제, 호스트 통신 제한 및 IPS 를 포함한다. 방지 기법은, 국한되지는 않지만, 제거 가능한 매체(이동식 매체) 통제, 샌드박스 기법 및 특정 컴퓨팅 플랫폼 메커니즘(제한된 업데이트 역량과 같은), 비실행(NX, No Execute) 비트, 데이터 실행 방지(DEP, Data Execution Prevention), 주소 공간 배치 무작위화(ASLR, Address Space		

	Layout Randomization), 스택 변형 탐지 및 강제적 접근 통제(MAC, Mandatory Access Control)와 같은 것이다.
기능 예시	안티바이러스 프로그램 설치 또는 악성코드 유입방지 솔루션 제공  [그림 41] 안티바이러스 프로그램 예시

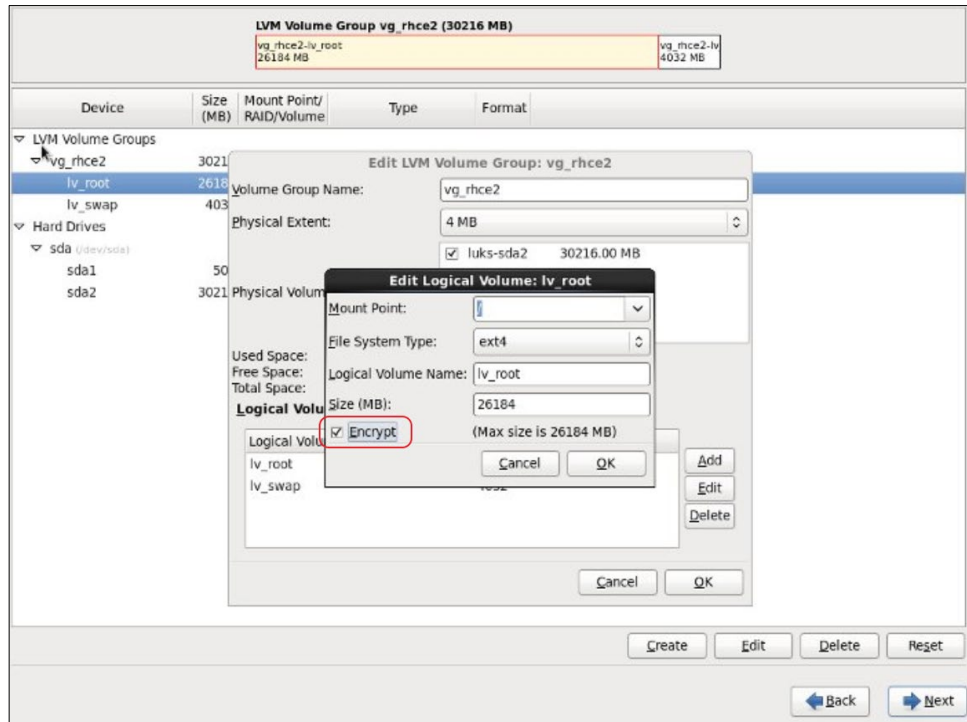
항목/목적	19. 보안 기능 검증	참조 표준	IEC62443-3-3/SR3.3
요구사항	CBS 는 보안 기능의 의도된 작동의 검증을 지원하고 유지보수 중 이상이 발생 시 보고하는 기능을 제공해야 한다.		
적용대상	원칙적으로 모든 CBS 에 적용해야 한다. (단, 적용이 불가능한 경우, 보상조치 방법에 대한 설명이 요구될 수 있다.)		
적용 설명	제품 공급자 및/또는 시스템 통합 사업자는 설계된 보안 통제를 테스트하는 방법에 관한 가이드를 제공해야 한다. 자산 소유자는 정상 운영 동안에 이런 검증 테스트를 실행할 경우에 가능한 영향을 인지할 필요가 있다. 이러한 검증 실행의 세부 사항은 지속적 운영 요구사항의 고려사항으로 주의 깊게 명시될 필요가 있다(e.g. 스케줄링 또는 사전 알림). 보안 검증 기능의 예는 다음과 같다: - 컴퓨터기반 시스템 대상 파일 시스템에 대한 유럽 컴퓨터 안티바이러스 연구소(EICAR, European Institute for Computer Antivirus Research) 테스트에 의한 안티바이러스 대책 검증. 안티바이러스 소프트웨어는 EICAR 테스트 샘플을 탐지하고 적절한 사고 처리 절차가 기동(triggered)되어야 한다. - 인가받지 않은 계정으로 접근을 시도하여 식별, 인증 및 사용 통제 대책을 검증(어떤 기능은 자동화될 수 있음). - 악성 트래픽은 아니지만 불규칙적으로 기동하는 침입 탐지 시스템(IDS, Intrusion Detection System) 규칙을 포함하여 보안 통제로서의 IDS 검증. 테스트는 이 규칙을 기동하는 트래픽과 적절한 IDS 모니터링 및 사고 처리 절차를 도입하여 수행될 수 있다. - 감사 로깅이 보안 정책과 절차가 요구하는 대로 발생하고 내외부 개체에 의해 비활성화되지 않음을 확인.		

기능 예시	보안 기능 검증 기능을 제공하며 예시는 다음을 참고할 수 있으며 이에 대한 방법을 안내하는 문서를 작성하고 참고 문서인 ‘CBS의 유지보수 및 검증 계획’ 문서로 제출 - EICAR 테스트 파일을 이용한 안티바이러스 백신 기능 검증 - 인가 받지 않은 계정으로 로그인 실패 및 감사 기록됨 - IPS/IDS가 제공되는 경우, 정책에 따른 이상 트래픽을 발생시키고 탐지됨을 확인 - 감사 기록이 제조사가 정의한 조건에 따라 발생함을 확인하고, 사용자가 수정할 수 없음을 확인
-------	--

항목/목적	20. 결정론적 출력	참조 표준	IEC62443-3-3/SR3.6
요구사항	CBS는 공격의 결과로 정상적인 작동을 유지할 수 없는 경우 미리 결정된 상태로 출력을 설정하는 기능을 제공해야 한다. 미리 결정된 상태의 예시는 다음과 같다. - 무전원 상태, - 마지막 알려진 값, 또는 - 고정값		
적용대상	원칙적으로 모든 CBS에 적용해야 한다. (단, 적용이 불가능한 경우, 보상조치 방법에 대한 설명이 요구될 수 있다.)		
적용 설명	컴퓨터 기반 시스템에 대한 위협 활동의 결과로서 컴퓨터 기반 시스템의 사전 결정된 출력 동작은 정상 작업의 무결성을 보장하는 중요한 특성이다. 이상적으로는, 컴퓨터 기반 시스템은 공격받는 중에도 정상적으로 작동해야 하지만, 컴퓨터 기반 시스템이 정상 작업을 유지할 수 없는 경우, 컴퓨터 기반 시스템 출력은 사전에 결정된 실패(fail) 상태로 전환해야 한다. 컴퓨터 기반 시스템의 사전 결정된 출력 동작은 기기에 따라 다르고 사용자가 구성할 수 있는 옵션 중에 하나는 다음과 같다: - 전원이 공급되지 않음 : 출력에서 전원이 공급되지 않는 상태가 됨 - 보류 : 출력이 마지막으로 확인된 유효값(good value)으로 실패함 - 고정 : 출력이 자산 소유자 또는 애플리케이션에 의해 결정되는 고정 가치에 도달하지 못함		
기능 예시	시스템에 이상이 발생한 경우 시스템의 고장 영향을 최소화하고 안전을 보장하기 위해서 사전에 정의된 출력의 작동 상태로 설정하는 기능 제공.		

항목/목적	21. 정보 기밀성	참조 표준	IEC62443-3-3/SR4.1
요구사항	CBS는 미사용 또는 전송 중인 명시적 읽기 권한이 지원되는 정보의 기밀성을 보호하는 기능을 제공해야 한다. (비고) 무선 네트워크의 경우 전송 중인 모든 정보의 기밀성을 보호하기 위해 암호화 메커니즘을 사용해야 한다.		
적용대상	다른 CBS와 네트워크로 연결된 모든 CBS에 적용 (단, Serial link와 같은 통신환경에는 적용하지 않음)		
적용 설명	유희(at rest) 또는 전송 중(in transit)인 정보 보호는 물리적 수단, 구획화나 암호 및 기타 기법을 통하여 유지관리 될 수 있다. 선택된 기법이 시스템 장애나 공격으로부터 복구하는 컴퓨터 기반 시스템 역량과 성능의 잠재적 영향을 고려하는 것이 중요하다.		

	주어진 정보를 보호해야 하는지 여부는 상황(context)에 따라 결정되며, 제품 설계 시 결정할 수 없다. 그러나 기관이 컴퓨터기반 시스템에 명시적인 읽기 권한을 설정하여 정보 접근을 제한한다는 사실은 기관이 이 정보를 보호해야 한다는 의미이다. 그러므로 컴퓨터기반 시스템이 명시적인 읽기 권한을 배정하는 역량을 지원하는 모든 정보는 잠재적으로 민감하게 고려되어야 하며 따라서 컴퓨터기반 시스템은 기밀성을 보호하기 위한 역량을 제공해야 한다. 어떤 상황에서는, 스위치와 라우터에 저장되고 처리되는 네트워크 구성 정보가 기밀로 고려될 수도 있다. 공개된 정보 전송을 포함한 통신은 도청과 변조에 취약할 수도 있다. 만일 컴퓨터기반 시스템이 외부 통신 서비스 제공자에 의존한다면, 통신 기밀에 필요한 보안 요구사항 구현과 관련된 필요 보증을 확보하기가 더 어려울 수도 있다. 이런 경우에, 보완 대책을 구현하거나 추가 위험을 명확하게 수용하는 것이 적합할 수도 있다. 또한 개체는 휴대용 및 모바일 기기가 활용될 때(e.g. 기술자 랩탑과 USB 스틱), 정보 기밀성을 인지해야 한다.
기능 예시	저장 데이터 및 통신 데이터의 기밀성 보호를 위한 암호화 기능을 제공 혹은 도구 사용 - 저장 데이터 암호화 예시 : BitLocker, 암호화 파일 시스템(EFS, Encrypting File System), LUKS(Linux Unified Key Setup-on-disk-format) 등 - 통신 데이터 암호화 예시 : TLS 프로토콜, VPN(Virtual Private Network) 등



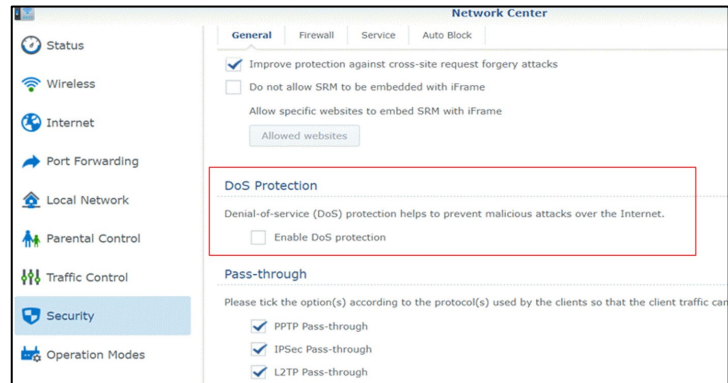
[그림 42] 저장 및 통신 데이터 암호화 예시

항목/목적	22. 암호 사용	참조 표준	IEC62443-3-3/SR4.3
요구사항	암호가 사용되는 경우, CBS 는 일반적으로 허용되는 보안 산업 관행 및 권고에 따라서 암호 알고리즘, 키 길이 및 메커니즘을 사용해야 한다.		
적용대상	다른 CBS 와 네트워크로 연결된 모든 CBS 에 적용 (단, Serial link 와 같은 통신환경에는 적용하지 않음)		
적용 설명	암호학적 보호 방식의 선택은 보호되는 정보의 가치, 정보의 기밀성 및 무결성의 침해 결과, 정보의 기밀성 유지 기간, 그리고 컴퓨터기반 시스템 운영 제약조건을 포함하여 위험 및 위험 분석을 기반으로 해야 한다. 이러한 대상은 유희정보(data at rest)나 전송 중 정보, 또는 양쪽 모두를 포함할 수 있다. 백업은 유희 정보의 예이고, 데이터 기밀성 및 무결성 평가 프로세스의 일부분으로 고려해야 한다. 컴퓨터기반 시스템 제품 공급자는 암호 키 설정 및 관리와 관련된 사례와 절차를 문서화해야 한다. 컴퓨터기반 시스템은 AES(Advance Encryption Standard)와 SHA(Secure Hash Algorithm)와 같은 검증된 암호 및 해시 알고리즘을 사용해야 하고, 표준을 기반으로 한 키 길이(key size)를 활용해야 한다. 키 생성은 효율적인 난수 생성기를 사용하여 수행해야 한다. 키 관리의 보안 정책 및 절차는 정의된 표준에 따라 주기적인 키 변경, 키 폐기, 키 배포 및 암호 키 백업을 다룰 필요가 있다. 일반적으로 수용되는 설계 및 권고사항은 NIST SP 800-57 Recommendation for Key Management 에서 확인할 수 있다. 구현 요구사항은 KS X ISO/IEC 19790 정보기술 - 보안기술 - 암호모듈 보안 요구사항에서 확인할 수 있다.		
기능 예시	보안강도 112 bit 이상의 암호화 알고리즘 사용		

4. 가용성 보호

(1) 보안 기능 설명

가용성은 시스템 정보 및 기능에 대한 적시의 신뢰성 있는 접근 및 사용을 보장하는 속성을 의미한다. 본절에서는 시스템이 제공하는 기능을 사용자가 필요한 시점에 문제없이 공급 받을 수 있도록 하기 위한 네트워크, 전원, 데이터 등 다양한 관점에서 요구되는 보안 기능 요구 사항에 대해 설명한다. DoS(Denial of Service, 서비스 거부) 공격은 서버 등의 장치에서 제공 가능한 수준 이상의



[그림 43] 네트워크 장치의 DoS 보호 기능 제공 예시

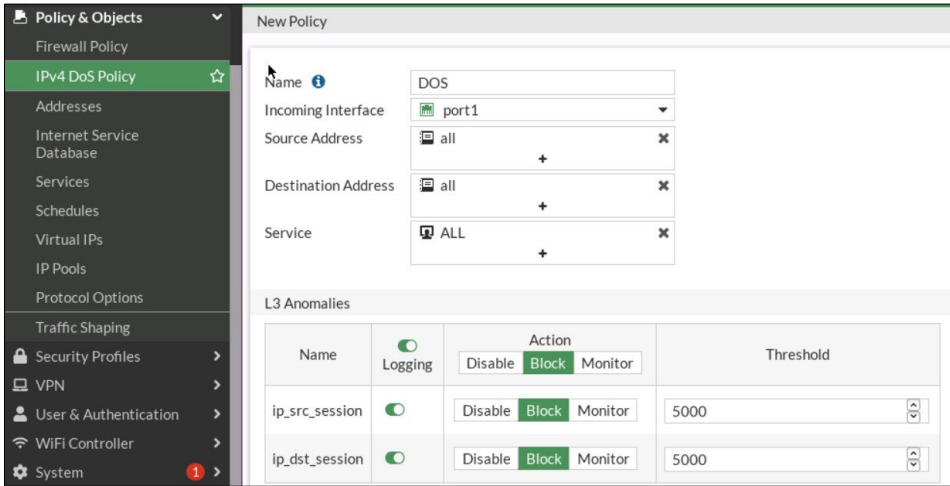
대량의 트래픽¹⁴을 발생시켜 실제 서비스를 공급받고자 하는 사용자에게 서비스 제공이 불가하도록 만드는 공격을 의미한다. 일반적으로 사용자는 서버에 접근하여 다양한 서비스를 제공 받는다. 서버에 접속한 사용자는 서버에서 제공하는 다양한 서비스를 제공 받을 수 있다. 하지만 서버에서 동시간대에 제공할 수 있는 데이터의 양(트래픽)은 무한하지 않으며, 악의적인 사용자(들)의 과도한 데이터 요청으로 실제 서비스를 공급받고자 하는 사용자가 적절한 서비스를 공급 받지 못하는 경우가 발생할 수 있다. 이러한 공격에 대한 보호를 위한 기능이 제공되어야 하며 일반적으로 네트워크 장치에서는 DoS 보호 기능을 제공한다. [그림 43]은 네트워크 장치에서 제공하는 DoS 보호 기능 제공 화면 예시이다.

시스템의 장애 또는 잘못된 설정으로부터 복구를 위해 백업 기능 또한 제공되어야 하며, 백업 수행시에도 시스템의 정상적인 작동에는 영향이 없어야 한다. 시스템은 비상 전원 공급기로 전환하거나 혹은 전원을 공급 받을 수 있어야 한다. 이를 위해 UPS(Uninterruptible Power Supply)가 공급되거나 그렇지 않은 경우 Blackout 과 같은 갑작스러운 전원의 차단 후 전원이 재 공급된 경우 사용자가 시스템을 즉시 사용할 수 있도록 자동으로 부팅이 되어야 하며 시스템의 작동에 필요한 모든 S/W application은 자동으로 실행되어야 한다. 또한 사용자 계정, 권한, 비밀번호, 권장 설정, 방화벽 정책 등 시스템에서 보안을 위해 가능한 설정 기능을 제공하고 이를 문서화 하여 참고문서인 보안 설정 지침으로 제출하여야 한다.

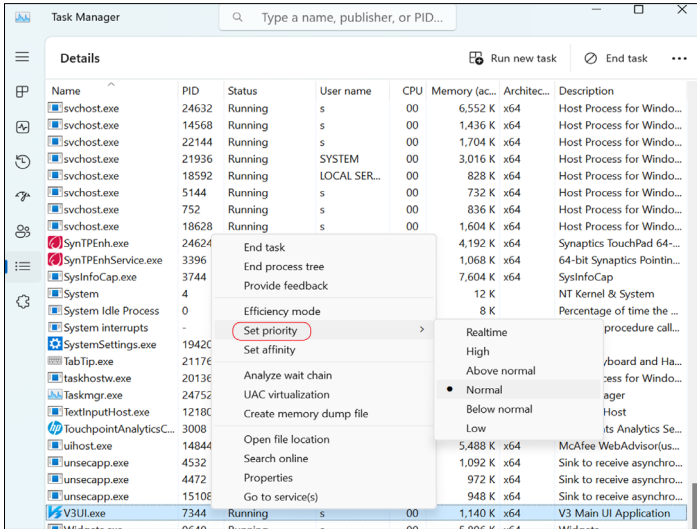
(2) 보안 기능 요구사항 설명 및 예시

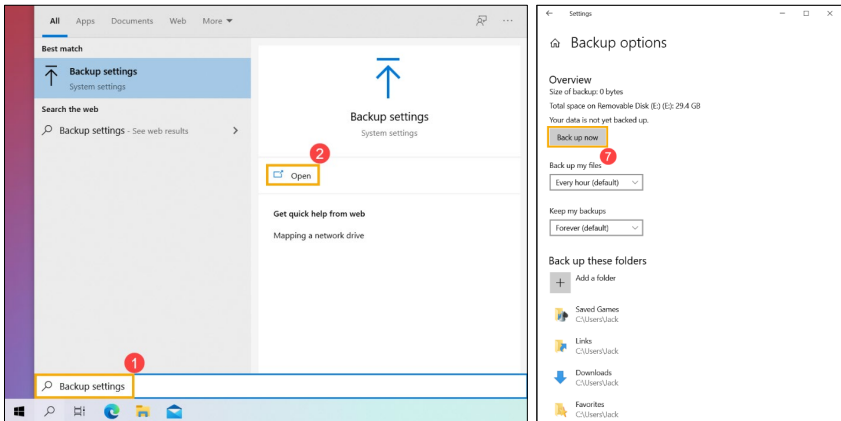
항목/목적	24. 서비스 거부 (DoS) 보호	참조 표준	IEC62443-3-3/SR7.1
요구사항	CBS는 DoS 사건 중 중요 기능들을 유지하는 최소 능력을 제공해야 한다. (비고) DoS 사건 시 CBS가 성능 저하 모드에서 작동하는 것이 허용될 수 있지만, 위험한 상황을 초래할 수 있는 방식으로 실패하지 않아야 한다. 네트워크 용량이 초과되는 경우와 컴퓨터의 리소스가 소모되는 경우와 같이 과부하 기반 DoS 이벤트를 고려해야 한다.		

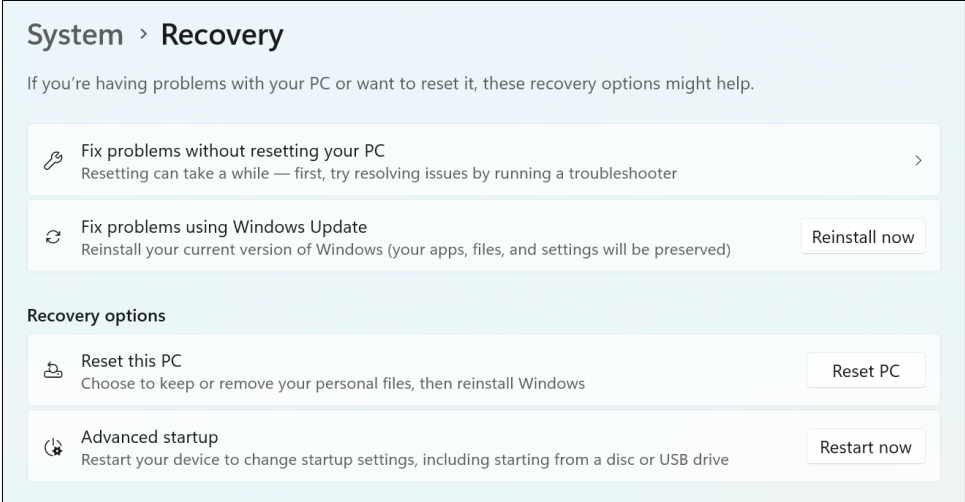
¹⁴ 트래픽(Traffic) : 네트워크 내부에 일정 시간 동안 흐르는 데이터의 양

적용대상	원칙적으로 모든 CBS 에 적용해야 한다. (단, 적용이 불가능한 경우, 보상조치 방법에 대한 설명이 요구될 수 있다.)
적용 설명	DoS 상황 영향을 제한하거나 어떤 경우에는 제거하기 위한 다양한 기술이 존재한다. 예를 들어, 경계 보호 기기는 한 방향으로 발신되는 정보 흐름을 제한하거나, DoS 이벤트에 직접적으로 영향을 받는 내부 신뢰 네트워크에서 기기를 보호하기 위해 특정 유형의 패킷을 필터링할 수 있다. 컴퓨터기반 시스템의 DoS 이벤트는 안전 관련 시스템에 악영향을 주어서는 안 된다.
기능 예시	네트워크 장치가 있는 경우, 네트워크의 과부하와 같은 DoS 상태에서부터 보호 하는 기능을 제공 (e.g. 네트워크 장치에서 제공하는 DoS 보호 기능 등)  [그림 44] 방화벽의 DoS 보호 정책 설정 화면 예시 <출처 : Fortinet>

항목/목적	25. 자원(resource) 관리	참조 표준	IEC62443-3-3/SR7.2
요구사항	시스템은 자원 부족을 방지하기 위해 보안 기능의 자원 사용을 제한하는 능력을 제공해야 한다.		
적용대상	보안 기능 소프트웨어가 설치 된 CBS 에 적용 (즉, “18. 악성코드 보호” 요구사항이 적용되는 경우)		
적용 설명	자원관리(e.g. 네트워크 분할 또는 우선순위 스킴)는 우선순위가 낮은 소프트웨어 프로세스가 우선순위가 높은 소프트웨어 프로세스를 관리하는 컴퓨터기반 시스템을 지연 또는 간섭하는 것을 방지한다. 예를 들어, 네트워크 스캔 개시, 운영 체제의 패치 및/또는 안티바이러스 점검은 정상 운영에 심각한 방해로 유발할 수 있다. 트래픽 비율 제한 스킴을 완화 기술로 고려해야 한다.		

기능 예시	필수 기능 및 보안 기능을 구분하고 필수 기능의 리소스 사용이 보안 기능에 우선하도록 하는 기능을 제공 (e.g. 운영체제에서 소프트웨어 별 리소스 우선순위 할당 기능 제공 등)  [그림 45] 리소스 관리 화면 예시
-------	---

항목/목적	26. 시스템 백업	참조 표준	IEC62443-3-3/SR7.3
요구사항	중요 파일의 식별자와 위치와 사용자 및 시스템 정보(시스템 상태 정보 포함)의 백업을 수행하는 능력은 정상 작동에 영향이 없도록 CBS에서 지원해야 한다.		
적용대상	원칙적으로 모든 CBS에 적용해야 한다. (단, 펌웨어로 구성된 임베디드 시스템 등에는 이 요구사항을 적용하지 않을 수 있음)		
적용 설명	최신 백업의 가용성은 컴퓨터 기반 시스템의 장애 및/또는 잘못된 설정으로부터 복구를 위해 필수적이다. 이 기능의 자동화는 모든 필요 파일이 추출되며 운영자의 부담을 줄일 수 있다. 비록 컴퓨터 기반 시스템 복구가 항상 요구되는 것이 아니더라도, 사고 후 포렌식 활동에 필요한 정보가 백업에 포함되어야 한다. 만일 백업 결과가 기밀 정보를 가진다면, 암호화가 고려되어야 한다.		
기능 예시	시스템에 대한 백업 기능을 제공하되 백업 중 시스템의 필수 기능이 정상적으로 작동함  [그림 46] 백업 기능 예시		

항목/목적	27. 시스템 복구 및 재구성	참조 표준	IEC62443-3-3/SR7.4
요구사항	CBS는 중단 또는 고장 후 알려진 보안 상태로 복구하거나 및 재구성할 수 있는 기능을 제공해야 한다.		
적용대상	원칙적으로 모든 CBS에 적용해야 한다. (단, 펌웨어로 구성된 임베디드 시스템 등에는 이 요구사항을 적용하지 않을 수 있음)		
적용 설명	알려진 안전한 상태로 컴퓨터기반 시스템을 복구 및 재구성한다는 것은 모든 시스템 파라미터(디폴트 또는 설정 가능한)를 안전한 값으로 설정하고, 보안 필수 패치를 재설치하고, 보안 관련 구성 설정을 재설정하며, 시스템 문서와 운영 절차를 사용할 수 있으며, 컴퓨터기반 시스템을 재설치하고 설정된 값으로 구성하며, 가장 최신의 안전한 백업을 적재하였으며, 시스템을 완전하게 테스트하여 작동시킨다는 의미이다.		
기능 예시	시스템에 대한 복구 기능을 제공  [그림 47] 복구 기능 예시		

항목/목적	28. 대체 전원	참조 표준	IEC62443-3-3/SR7.5
요구사항	CBS는 기존 보안 상태 또는 문서로 된 성능 저하 모드에 영향을 주지 않고 대체 전원 공급으로/으로부터 전환할 수 있는 능력을 제공해야 한다.		
적용대상	원칙적으로 모든 CBS에 적용해야 한다. (단, 적용이 불가능한 경우, 보상조치 방법에 대한 설명이 요구될 수 있다.)		
적용 설명	물리적 도어 접근 제어와 같은 보안 대책이 기본 전원공급장치의 상실에 의해 영향을 받을 수 있는 경우가 있을 수 있으며, 이 경우 비상 전원공급장치가 관련 시스템을 커버해야 한다. 만약 이것이 가능하지 않다면, 그러한 비상 상황 동안에 다른 보안 대책이 필요할 수 있다.		
기능 예시	UPS를 공급하거나 혹은 Blackout 시 제어 중인 외부 장비에 영향을 주지 않으며 Blackout recovery 후 자동으로 시스템이 재실행 및 사용자가 사용 가능한 상태로 되는 기능 등을 제공		

항목/목적	29. 네트워크 및 보안 구성 설정	참조 표준	IEC62443-3-3/SR7.6
요구사항	CBS 는 공급자가 제공한 지침에 기술된 바와 같이 권장되는 네트워크 및 보안 구성에 따라 설정할 수 있는 능력을 제공해야 한다. CBS 는 현재 배치된 네트워크 및 보안 구성 설정에 대한 인터페이스를 제공해야 한다.		
적용대상	원칙적으로 모든 CBS 에 적용해야 한다. (단, 적용이 불가능한 경우, 보상조치 방법에 대한 설명이 요구될 수 있다.)		
적용 설명	이러한 구성 설정은 컴퓨터기반 시스템 컴포넌트의 조정 가능한 파라미터이다. 승인된 구성 설정 및/또는 권장 구성 설정으로부터의 이탈을 감지하고 수정할 수 있도록 컴퓨터기반 시스템은 보안 정책 및 절차에 따라 구성 설정 변경에 대한 모니터링 및 제어를 지원할 필요가 있다. 보안을 강화하기 위해 에이전트에 의해 현재 설정이 자동으로 수집되고 승인된 설정과 비교되는 자동 검사를 수행할 수 있다.		
기능 예시	보안 구성 설정의 예시는 다음과 같으며 해당 기능을 구현하고 이를 안내하는 문서인 보안 설정 지침을 참고 문서로 제출 - 사용자 계정 - 권한 부여 - 비밀번호 정책 - 제품의 안전 상태(권장 설정) - 방화벽 정책(제공되는 경우) 등		

항목/목적	30. 최소화 기능	참조 표준	IEC62443-3-3/SR7.7
요구사항	다음에 대한 설치, 가용성 및 접근 권한은 CBS 에서 제공하는 기능의 엄격한 필요성에 제한되어야 한다. - 운영 체제 소프트웨어 구성요소, 프로세스 및 서비스 - 네트워크 서비스, 포트, 프로토콜, 경로 및 호스트 접근 및 소프트웨어		
적용대상	원칙적으로 모든 CBS 에 적용해야 한다. (단, 적용이 불가능한 경우, 보상조치 방법에 대한 설명이 요구될 수 있다.)		
적용 설명	컴퓨터기반 시스템은 광범위하고 다양한 기능과 서비스를 제공하는 역량을 가진다. 제공되는 기능과 서비스 중 일부는 컴퓨터기반 시스템 기능을 지원하는 데 필요하지 않을 수도 있다. 그러므로 기본적으로 기본 구성 설정 이외의 기능은 비활성화하여야 한다. 추가적으로 컴퓨터기반 시스템의 단일 컴포넌트에서 각종 서비스를 제공하는 것이 편리하지만, 그렇게 하는 경우 단일 컴포넌트가 제공하는 서비스의 제한과 비교하여 위험이 증가한다. COTS(commercial-off-the-shelf) 장비가 일반적으로 제공하는 기능과 서비스의 대부분이 제거 후보이다. 예를 들어, 이메일, VoIP(Voice over internet protocol), IM(instant messaging), FTP(file transfer protocol), HTTP(hypertext transfer protocol) 및 파일 공유가 해당된다.		
기능 예시	시스템에서 제공하는 S/W Application 에서 운영 체제 등으로 접근을 제한 하는 기능을 제공. 허가된 사용자(계정)에 한해서 접근이 가능하도록 제한하는 기능을 제공		

제 3 절 추가 보안 기능 요구 사항 설명 및 적용 예시

1. 추가 보안 기능

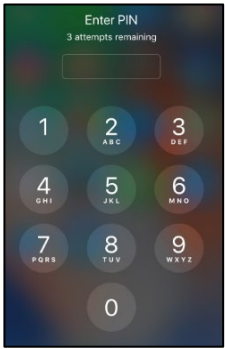
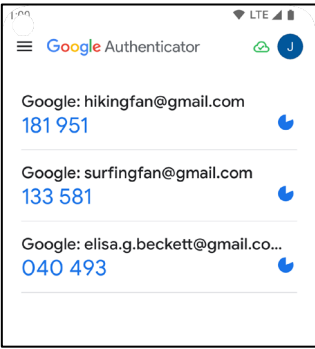
(1) 추가 보안 기능 설명

시스템에 비신뢰 네트워크와의 원격 연결이 있는 경우 KR 사이버복원력 지침 3 장 401.에 따른 필수 보안 기능 30 개 요구 사항에 402. 추가 보안 기능 11 개 요구 사항을 더하여 총 41 개의 보안 기능 요구사항이 구현되어야 한다.

비신뢰 네트워크와의 연결 시 즉, 사이버복원력 지침의 적용을 받지 않는 네트워크와 시스템이 연결 되는 경우 시스템은 다음의 기능을 추가로 제공해야 한다. 첫번째로는 다중요소 인증(Multifactor authentication) 기능이 요구된다. 다중요소 인증은 두가지 이상 방식을 이용하여 인증하는 것으로 인증 시 요소(factor) 또한 서로 달라야 한다. 요소에는 세가지 종류가 있다. 지식 기반 요소(Knowledge based factor)는 사용자만 알고 있는 것으로 패스워드나 PIN 코드 등이 이에 대한 예시가 된다. 소유 기반 요소는 사용자만 소유하고 있는 것으로 보안카드나 OTP 등이 이에 대한 예시가 된다. 마지막으로 속성 기반 요소는 사용자만의 고유한 속성으로 지문인식, 홍채인식 등이 이에 대한 예시가 된다. 두번째로는 인간 사용자에게 추가하여 소프트웨어 프로세스 및 장치를 식별하고 인증해야 한다. 세번째로는 사전에 시스템에서 정의된 횟수 이상의 로그인 실패 시 특정 시간 동안은 로그인이 불가능한 것과 같은 로그인에 대한 실패 시도를 제한하는 기능이 제공되어야 한다. 네번째로는 시스템에 대한 인증 전 사용자에게 알림 메시지를 제공하는 기능이 제공되어야 한다. IEC 62443 3-3 SR 1.12의 근거 및 보충 지침에 따른 알림 메시지의 예시는 다음과 같다.

- 1) 개인 자산 소유자가 소유한 시스템에 접근함
- 2) 시스템 사용은 모니터링, 기록 및 감사 대상이 될 수 있음
- 3) 인가 받지 않은 시스템 사용은 금지되고 민형사상의 처벌 대상임
- 4) 시스템의 사용은 모니터링과 기록에 동의함을 의미함

시스템 인증 전 사용자 알림 기능은 또한 허가된 선원에 의해 설정 즉, 관련 문구를 수정할 수 있는 기능을 제공해야 한다. 마지막으로 비신뢰 네트워크로부터의 접근 시 선내 선원의 승인 후 시스템에 대한 접근이 가능하도록 하는 기능을 제공해야 한다.

		
지식 기반 요소	소유 기반 요소	속성 기반 요소

[그림 48] 다중요소 인증 예시

(2) 보안 기능 요구사항 설명 및 예시

항목/목적	31. 인간 사용자에 대한 다중요소 인증	참조 표준	IEC62443-3-3/SR1.1, RE2
요구사항	비신뢰 네트워크를 통해 CBS 에 접근하는 경우 다중요소 인증이 인간 사용자에 대해 요구된다.		
기능 예시	비신뢰 네트워크를 통한 인간 사용자 접속시 다중요소 인증을 강제하는 기능을 제공 다중요소 인증은 다음 세가지 요소 중 2 가지 이상의 요소를 사용하여 인증하여야 함 - 지식 기반 요소(e.g. 패스워드, PIN 코드 등) - 소유 기반 요소(e.g. 보안카드, OTP 등) - 속성 기반 요소(e.g. 지문인식, 홍채인식 등) Multi-Factor Authentication (MFA) POSSESSION + KNOWLEDGE + BEING Something you have. + Something you know. + Something you are. [그림 49] 다중요소 인증 설정 화면 예시 <출처 : Fortinet>		

항목/목적	32. 소프트웨어 프로세스 및 장치 식별 및 인증	참조 표준	IEC62443-3-3/SR1.2
요구사항	CBS 는 소프트웨어 프로세스와 장치를 식별하고 인증해야 한다.		
적용 설명	식별 및 인증 기능은 데이터 교환을 허용하기 전에 알 수 없는 소프트웨어 프로세스나 기기(이항에서는 개체로 칭함.)에 알려진 신원을 매핑하여 알리는 것이다. 불량 개체가 컴퓨터기반		

	시스템 특정 데이터를 송수신할 수 있도록 허용하면 정당한 컴퓨터기반 시스템에 유해한 행위가 발생할 수 있다. 모든 개체는 컴퓨터기반 시스템에 대한 모든 접근에 대해 식별되고 인증되어야 한다. 이러한 개체의 신원 인증은 패스워드, 토큰 또는 위치(물리적 및 논리적)와 같은 방법을 사용하여 수행되어야 한다. 이 요구사항은 컴퓨터기반 시스템의 로컬 및 원격 접속에 모두 적용해야 한다. 그러나 개별 개체들이 서로 다른 대상 시스템을 연결하는 데 사용되는 경우에는(e.g. 원격 벤티 지원), 개체가 여러 신원을 가지는 것이 기술적으로 불가능할 수도 있다. 이런 경우에는 보완 대책을 적용해야 한다. 모든 개체의 식별 및 인증이 중간자 공격이나 메시지 스푸핑과 같은 공격에 대응하여 보호하기 위해 필요하다. 어떤 경우에, 이런 메커니즘은 각자가 자체 신원을 가지고 동일 물리적 서버에 실행하는 다중 소프트웨어 프로세스를 포함할 수도 있다. 다른 경우에, 신원이 해당 PLC 에 실행하는 모든 프로세스와 같이 물리적 기기로 국한될 수도 있다. 휴대용 및 모바일 기기의 식별 및 인증 시에는 특별한 주의가 필요하다. 이런 유형의 기기는 다른 방법으로 격리된 네트워크를 포함하여 컴퓨터기반 시스템에 원하지 않는 네트워크 트래픽, 악성코드 및/또는 정보 노출을 유발할 수 있다. 개체가 단일 그룹으로 동작하는 경우, 식별 및 인증은 역할 기반, 그룹 기반 또는 개체 기반이 될 수도 있다. 현장에서의 비상 조치 뿐만 아니라 컴퓨터기반 시스템 필수 기능이 식별 또는 인증 요구사항에 의해 방해 받아서는 안 된다. 예를 들어, 공통의 보호 및 제어 방식(schemes)에서, 기기 그룹은 보호 기능을 공동으로 수행하고, 그룹 내의 기기 간에 멀티캐스트 메시지로 통신한다. 이런 경우에, 공유 계정 또는 공유 대칭 키 기반의 그룹 인증이 일반적으로 사용된다. 식별 및 인증 통제 정책을 지원하기 위해, 컴퓨터기반 시스템은 첫 단계로 모든 개체의 신원을 검증한다. 두 번째 단계로 식별된 개체에 배정된 권한(permission)을 강제해야 한다.
기능 예시	시스템에 연결되는 외부 소프트웨어 프로세스 및 장치를 식별 및 인증하는 기능을 제공

항목/목적	33. 실패한 로그인 시도	참조 표준	IEC62443-3-3/SR1.11
요구사항	CBS 는 지정된 시간 동안 비신뢰 네트워크로부터 연속적으로 무효한 로그인 시도 제한을 시행해야 한다.		
적용 설명	서비스 거부 가능성으로 인하여, 연속된 부정 접근 시도 횟수가 제한되어야 한다. 만일 가능하다면, 애플리케이션 또는 기기는 가용 보안 정책과 절차에 의해 설정한 기존 지정 시간 후에 접근 시도 횟수를 0 으로 자동 재설정할 수도 있다. 접근 시도를 0 으로 재설정하는 것은 사용자(사람, 소프트웨어 프로세스나 기기)가 정확한 로그인 자격증명(credentials)을 가질 경우에 접근을 획득할 수 있게 한다. 컴퓨터기반 시스템 운영자 워크스테이션 또는 노드의 자동(사람 개입 없는) 접근 거부는 비상 상황에서 즉각적인 운영자 응답이 필요한 경우에는 사용해서는 안 된다. 모든 잠금 해제 메커니즘은 지속적 운전을 위한 기능적 요구사항을 고려하여, 시스템의 안전성을 훼손하거나 시스템 장애를 유발할 수 있는 부정적 서비스 거부 운영 상태를 완화해야 한다. 필수 서비스에 사용되는 계정에 대화형 로그인을 허용하면 서비스 거부나 다른 오용을 유발할 수 있다.		
기능 예시	특정 횟수 이상의 로그인 시도 실패시 일정시간 동안 로그인 불가하도록 강제하는 기능을 제공		

항목/목적	34. 시스템 사용 알림	참조 표준	IEC62443-3-3/SR1.12
요구사항	CBS 는 인증 전에 시스템 사용 알림 메시지를 표시하는 능력을 제공해야 한다. 시스템 사용 알림 메시지는 허가된 선원에 의해서 설정될 수 있어야 한다.		
적용 설명	프라이버시 및 보안 정책과 절차는 적용 가능한 법령, 지침, 정책, 규제, 표준 및 가이드와 부합해야 한다. 종종 이러한 요구사항의 주된 목적은 고의적인 위반을 입증하고 위반자를 기소하는 것이다. 그러므로 이 역량은 정책 요구사항을 지원할 필요가 있고, 제지사항으로 사용될 수 있기 때문에 컴퓨터기반 시스템 보안을 향상할 수 있다. 시스템 사용 알림 메시지는 개인이 컴퓨터기반 시스템에 로그인할 때 보이는 경고 배너 형식으로 구현될 수 있다. 컴퓨터기반 시스템 설비에 물리적으로 부착된 경고 배너는 원격 로그인 문제를 보호할 수 없다. 시스템 사용 알림 메시지에 포함되는 요소의 예는 다음과 같다: - 개인 자산 소유자가 소유한 시스템에 접근함. - 시스템 사용은 모니터링, 기록 및 감사 대상이 될 수 있음. - 인가받지 않은 시스템 사용은 금지되고 민형사상의 처벌 대상임. - 시스템의 사용은 모니터링과 기록에 동의함을 의미함.		
기능 예시	로그인 전 안내 문구 표시 기능을 제공하며, 안내 문구는 허가된 사용자(선원)에 의해 수정이 가능		

항목/목적	35. 비신뢰 네트워크를 통한 접근	참조 표준	IEC62443-3-3/SR1.13
요구사항	CBS 는 비신뢰 네트워크를 통한 어떤 접근이 감시되고 통제되어야 한다.		
적용 설명	비신뢰 네트워크를 통한 컴퓨터기반 시스템 접근의 예로는 원격 접속 방법(다이얼 업, 브로드밴드 및 무선) 뿐만 아니라 회사 사무실(비컴퓨터기반 시스템) 네트워크로부터 연결이 포함된다. 컴퓨터기반 시스템은 다이얼 업 연결로 달성된 접속을 제한하고(예: 요청한 소스 기반의 다이얼 업 접속 제한), 인가받지 않은 연결 또는 인가된 연결이 변질(subversion)된 경우에 대응하여 보호해야 한다. 지역적으로 원격인 컴퓨터기반 시스템 컴포넌트 위치의 비신뢰 네트워크를 통한 접속은 필요하고 인증받았을 경우에만 활성화되어야 한다. 보안 정책과 절차는 컴퓨터기반 시스템의 원격 사용자 접속을 위해 다중 인증을 요구할 수도 있다.		
기능 예시	비신뢰 네트워크로부터 시스템 접근시 선원의 명시적 승인 후에 접근이 가능하도록 강제하는 기능을 제공(e.g. 선원이 특정 화면의 버튼을 클릭 후 사용자가 접근 가능, 도구/프로그램 등을 이용하여 접속 코드를 생성하고 접근하고자 하는 사용자는 선원으로부터 이를 송부 받아 입력 후 접근 가능 등)		

항목/목적	36. 명시적 접근 요청 승인	참조 표준	IEC62443-3-3/SR1.13, RE1
요구사항	CBS 는 선내 허가된 선원이 명시적으로 승인하는 경우를 제외하고 비신뢰 네트워크를 통한 접근을 거부해야 한다.		
기능 예시	비신뢰 네트워크로부터 시스템 접근시 선원의 명시적 승인 후에 접근이 가능하도록 강제하는 기능을 제공(e.g. 선원이 특정 화면의 버튼을 클릭 후 사용자가 접근 가능, 도구/프로그램 등을 이용하여 접속 코드를 생성하고 접근하고자 하는 사용자는 선원으로부터 이를 송부 받아 입력 후 접근 가능 등)		

항목/목적	37. 원격 세션 종료	참조 표준	IEC62443-3-3/SR2.6
요구사항	CBS 는 설정된 미사용 시간 이후 자동으로 또는 세션을 시작한 사용자가 수동으로 원격 세션을 종료하는 기능을 제공해야 한다.		
적용 설명	원격 세션은 위험 평가를 기반으로 자산 소유자가 정의한 구역의 경계에 걸쳐 컴퓨터기반 시스템이 접근될 때마다 개시된다. 이 요구사항은 보안 정책 및 절차와 컴퓨터기반 시스템의 위험 평가를 기반으로 컴포넌트 모니터링 및 유지보수 활동(중요한 작업이 아님.)에 사용되는 세션으로 제한될 수도 있다. 일부 컴퓨터기반 시스템은 세션이 컴포넌트 필수 기능의 부분일 경우에 세션 종료를 허가하지 않을 수도 있다.		
기능 예시	원격 접속에 대해 사전에 설정된 시간 동안의 시스템 미사용 혹은 사용자의 수동적인 작업을 통해 시스템의 세션 잠금 기능을 제공		

항목/목적	38. 암호 무결성 보호	참조 표준	IEC62443-3-3/SR3.1, RE1
요구사항	CBS 는 비신뢰 네트워크를 통해 통신하는 동안 정보의 변경을 인식하기 위해 암호 메커니즘을 적용해야 한다.		
기능 예시	무결성을 보호하기 위한 암호화된 통신 프로토콜을 사용		

항목/목적	39. 입력 검증	참조 표준	IEC62443-3-3/SR3.5
요구사항	CBS 는 프로세스 제어 입력 또는 CBS 의 동작에 직접 영향을 주는 입력으로서 사용되는 비신뢰 네트워크를 통한 입력 데이터의 구문(syntax), 길이 및 내용을 입증해야 한다.		
적용 설명	설정값(set point)과 같은 컴퓨터기반 시스템 입력의 유효한 구문을 확인하는 규칙을 마련하여 이 정보가 규격에 맞게 변경되지 않았는지 확인해야 한다. 인터프리터에게 전달되는 입력은 내용이 본의 아니게 명령어로 해석되지 않도록 사전 차단해야 한다. 이 사항은 보안 SR 이므로, 예상된 범위를 벗어났으나 유효한 정수를 입력하는 것과 같은 인적 오류를 다루지 않는다. 일반적인 입력 데이터 검증과 관련된 실증 사례는 필드 유형에 정의된 범위 외의 값, 데이터 필드의 유효하지 않은 문자, 누락되거나 불완전한 데이터 및 버퍼 오버플로와 같은 것이다. 부당한 입력이 시스템 보안 문제를 유발하는 예로는 SQL 삽입 공격, 크로스사이트 스크립팅(XSS) 또는 잘못된 형식의 패킷(프로토콜 퍼저가 일반적으로 생성하는)과 같은 것이다.		
기능 예시	제어 입력에 사용되는 범위 외의 값 입력시 받아들이지 않고 이상 작동이 없으며 사용자에게 경고 문구 로 안내 등의 기능을 제공		

항목/목적	40. 세션 무결성	참조 표준	IEC62443-3-3/SR3.8
요구사항	CBS 는 세션의 무결성을 보호하는 기능을 제공해야 한다. 무효한 세션 ID 는 거부되어야 한다.		
적용 설명	요구사항은 패킷 수준 대비 세션에서의 통신 보호에 초점을 맞춘다. 요구사항의 목적은 통신 세션의 각 끝에서 상대방의 지속적인 정체성과 전송되는 정보의 유효성에 대한 신뢰의 근거를 확립하는 것이다. 예를 들어, 세션 가로채기, 세션에 잘못된 정보의 삽입 또는 재생 공격을 포함한 중간자 공격을 다룬다. 세션 무결성 메커니즘의 사용은 상당한 오버헤드를 가질 수 있으므로 실시간 통신 요건에 비추어 이들의 사용을 고려해야 한다.		

기능 예시	사전에 설정된 시간 동안의 시스템 미사용 혹은 사용자의 수동적인 작업을 통해 세션이 무효화된 경우 시스템 사용을 위해 새로운 세션 수립을 강제하는 기능(e.g. 로그인 등)을 제공
-------	--

항목/목적	41. 세션 종료 후 세션 ID 무효화	참조 표준	IEC62443-3-3/SR3.8, RE1
요구사항	시스템은 사용자 로그아웃 또는 기타 세션 종료 시(브라우저 세션을 포함) 세션 ID 를 무효화해야 한다.		
기능 예시	사전에 설정된 시간 동안의 시스템 미사용 혹은 사용자의 수동적인 작업을 통해 세션이 무효화된 경우 시스템 사용을 위해 새로운 세션 수립을 강제하는 기능(e.g. 로그인 등)을 제공		



Marine and Ocean Equipment Team Website : www.krs.co.kr
36, Myeongji ocean city 9-ro, Gangseo-gu, Busan, 46762 Republic of Korea.

Copyright by Korean Register. All rights reserved.